

YAMBA — CAHIER DE RECETTE .

PARTIE ADMIN (back-office)

Yamba — documentation générée le 06/09/2026 depuis `docs/recette/RECETTE-02-ADMIN.md`

Table des matières

1. Objet et périmètre

- 1.1 Ce que ce cahier couvre
- 1.2 Ce que ce cahier ne couvre pas
- 1.3 Les documents de référence

2. Prérequis

- 2.1 Environnement technique
- 2.2 Rejouer le jeu d'essai
- 2.3 Les comptes membres du jeu d'essai
- 2.4 Ce que le jeu d'essai pose déjà dans chaque file admin
- 2.5 Créer les quatre comptes admin de recette
- 2.6 Deux profils simultanés
- 2.7 Outillage de vérification du journal

3. Conventions

- 3.1 Numérotation
- 3.2 Verdicts
- 3.3 Gravité d'une anomalie
- 3.4 La règle des deux vérifications
- 3.5 Conventions de lecture des fiches

4. Sécurité d'accès

- 4.1 Connexion en deux étapes
- 4.2 Séparation des sessions et durée de vie
- 4.3 La matrice des permissions, profil par profil

5. Les écrans, un chapitre par écran

- 5.1 Accueil et compteurs (/home)
- 5.2 Alertes de seuil (/alerts)
- 5.3 Utilisateurs : recherche et fiche
- 5.4 Sanctions : proposer, appliquer, lever
- 5.5 Suppression d'adresse email
- 5.6 Exports CSV
- 5.7 Trajets : liste, fiche et masquage
- 5.8 Billets à vérifier (/tickets)
- 5.9 Médiation : la file, le dossier, la décision
- 5.10 Retenue d'annulation tardive
- 5.11 Finances : les files d'exception (/finances)
- 5.12 Fiche argent d'un deal (/deals/[id])
- 5.13 Rapprochement avec le fournisseur de paiement
- 5.14 Versements : rejeu et renversement
- 5.15 Remboursement manuel en deux gestes
- 5.16 Rapport mensuel et export finances (/finances/report)
- 5.17 Pilotage et drilldown (/pilotage)
- 5.18 Conversations (/conversations/[bookingId])
- 5.19 Signalements : deux files (/reports)
- 5.20 Paramètres de la plateforme (/settings)
- 5.21 Données personnelles et effacement RGPD
- 5.22 État des services (/status)
- 5.23 Maintenance
- 5.24 Journal d'audit (/audit)
- 5.25 Comptes admin (/admins)
- 5.26 Mes sessions (/sessions)

6. Cas de bout en bout

- ADM-E2E-1 — Un litige, de la file à la décision, jusqu'à l'argent
- ADM-E2E-2 — Une sanction proposée, appliquée, puis levée
- ADM-E2E-3 — Un membre signalé trois fois devient prioritaire

- ADM-E2E-4 — Un changement de paramètre et son effet en moins de 30 secondes
- ADM-E2E-5 — Une mise en lecture seule et sa levée
- ADM-E2E-6 — Une demande d'effacement RGPD reçue par email
- ADM-E2E-7 — Un versement en échec, du bandeau d'alerte à la clôture
- ADM-E2E-8 — Un billet, un masquage, et la lecture croisée

7. Non-régression

- ADM-NRG-1 — Les sous-titres périmés
- ADM-NRG-2 — Les filtres d'URL de la file d'arbitrage
- ADM-NRG-3 — Le libellé du signalement traité
- ADM-NRG-4 — La clé React de la page Paramètres
- ADM-NRG-5 — Les alertes ont quitté l'accueil
- ADM-NRG-6 — Le journal se filtre et se fouille
- ADM-NRG-7 — Les cinq écarts documentaires connus

8. Consignation

- 8.1 Tableau de suivi
- 8.2 Fiche d'anomalie
- 8.3 Critères de sortie

Application testée : `apps/admin-ui`, servie sur **`http://localhost:3001`**, adossée au gateway `http://localhost:8080`. Version du code de référence : branche `feat/f3-messaging-admin` (base dev), état au 06/09/2026. Document de recette **exécutable par un testeur seul**. Chaque scénario se conclut par un verdict binaire : **conforme** ou **non conforme**.

1. Objet et périmètre

1.1 Ce que ce cahier couvre

Ce cahier vérifie le **back-office Yamba** : les 23 écrans de `apps/admin-ui`, la connexion en deux étapes, la matrice des permissions des six profils admin, et — c'est la particularité du back-office — **la trace laissée par chaque geste dans le journal d'audit**.

Le périmètre exact :

Domaine	Écrans concernés
Accès	<code>/login</code> , <code>/invite</code> , <code>/sessions</code> , <code>/admins</code>
Pilotage quotidien	<code>/home</code> , <code>/alerts</code>
Membres	<code>/users</code> , <code>/users/[id]</code>
Offre	<code>/trips</code> , <code>/trips/[id]</code> , <code>/tickets</code>
Médiation	<code>/disputes</code> , <code>/disputes/[id]</code>
Argent	<code>/finances</code> , <code>/finances/report</code> , <code>/deals/[id]</code>
Mesure	<code>/pilotage</code>
Modération	<code>/reports</code> , <code>/conversations/[bookingId]</code>
Gouvernance	<code>/settings</code> , <code>/settings/docs</code> , <code>/privacy</code> , <code>/status</code> , <code>/audit</code>

1.2 Ce que ce cahier ne couvre pas

- Les parcours **membres** (publication d'un trajet, réservation, paiement, remise, notation, messagerie côté Expéditeur / Voyageur) : voir `docs/recette/RECETTE-01-MEMBRE.md`.
- Les **contrats d'API** pris isolément (codes de retour, schémas OpenAPI, en-têtes) : voir `docs/recette/RECETTE-03-API.md`.
- L'**exploitation** au sens infrastructure (déploiement, variables d'environnement, sauvegardes, moniteur externe, Sentry) : voir `docs/recette/RECETTE-04-EXPLOITATION.md`.

Quand un scénario admin a un effet visible côté membre (une suspension qui bloque une réservation, un masquage qui retire un trajet de la recherche, un paramètre qui change un prix), ce cahier **exige la vérification côté membre** mais ne détaille pas le parcours membre : il renvoie au cahier 01.

1.3 Les documents de référence

Document	Ce qu'on y trouve
<code>docs/livrables/02-YAMBA-DOCUMENTATION-ADMIN.md</code>	La documentation fonctionnelle complète du back-office : 22 écrans, la matrice 32 permissions × 6 profils, les 81 règles de gestion, les 40 actions de journal

Document	Ce qu'on y trouve
context/YAMBA-DOC-METIER.md	Les grilles de règles numérotées (RG-ADM, RG-MED, RG-FIN, RG-PIL, RG-ALR, RG-PAR, RG-RGP, RG-MNT, RG-FCH, RG-SIG, RG-TRU, RG-EML, RG-MON)
packages/libs/api-contracts/src/admin/admin-users.schema.ts	La source unique des permissions par profil
packages/libs/admin-audit/src/index.ts	La liste des actions journalisées
context/YAMBA-PARAMETRES.md	Le catalogue des paramètres réglables (classes A / B / C)

Règle de précedence en cas de divergence : le code fait foi. Un écart entre un document et le comportement observé se consigne comme anomalie **documentaire** (gravité mineure) ; un écart entre le comportement observé et le code se consigne comme anomalie **fonctionnelle**.

2. Prérequis

2.1 Environnement technique

Élément	Commande / valeur	Vérification
Base MongoDB	DATABASE_URL dans le .env de la racine	npx prisma db push répond sans erreur
Redis	REDIS_DATABASE_URI	indispensable aux sessions admin, aux battements de cron, aux compteurs de pilotage
Redpanda (Kafka)	facultatif	son arrêt est volontairement utilisé au scénario ADM-ETA-5
Services	npm run dev (tout) ou service par service	gateway :8080, auth :6001, trip :6002, deal :6003, notification :6004, message :6005
Back-office	npx nx dev admin-ui	http://localhost:3001
Front membre	npx nx dev user-ui	http://localhost:3000 — nécessaire aux scénarios à effet croisé
Mailpit (ou équivalent SMTP local)	EMAIL_PROVIDER=smtp + SMTP_HOST	obligatoire : une dizaine de scénarios vérifient un email
Fournisseur de paiement	PaymentProvider Fake en local	les scénarios exigeant Stripe réel sont marqués ►►

Avertissement CORS. Le gateway n'autorise que les ports 3000 (front membre) et 3001 (back-office) sur localhost, 192.168.x.x et 10.x.x.x. Un back-office lancé sur un autre port répond « Not allowed by CORS » sur **tous** les appels : ce n'est pas une anomalie fonctionnelle, c'est une erreur de mise en place.

2.2 Rejouer le jeu d'essai

Le jeu d'essai est la **remise à zéro de recette** : il efface puis recrée les trajets et les réservations des douze comptes de démonstration, sans toucher aux autres comptes.

```
npx tsx --env-file=.env packages/libs/prisma/scripts/seed-deals.ts
```

Il écrit un fichier `seed-output.json` qui donne les identifiants réels des trajets et des réservations créés : **garde-le ouvert pendant la recette**, il évite de chercher les identifiants Mongo à la main.

Pour remettre les paramètres de la plateforme à leurs valeurs par défaut (sans écrire au journal) :

```
npx tsx --env-file=.env packages/libs/prisma/scripts/seed-settings.ts      # remise à zéro
npx tsx --env-file=.env packages/libs/prisma/scripts/seed-settings.ts --show  # inspection seule
```

2.3 Les comptes membres du jeu d'essai

Les douze comptes partagent le mot de passe **Yamba-Dev-2026!** .

Rôle	Prénom Nom	Email
Voyageur	Thomas Nkounkou	thomas.carrier@seed.yamba.dev
Voyageur	Marc Tremblay	marc.carrier@seed.yamba.dev
Voyageur	Inês Ferreira	ines.carrier@seed.yamba.dev
Voyageur	Adebayo Okonkwo	adebayo.carrier@seed.yamba.dev
Voyageur	Linh Nguyễn	linh.carrier@seed.yamba.dev
Voyageur	Joséphine Ilunga	josephine.carrier@seed.yamba.dev
Expéditeur	Aminata Diallo	aminata.shipper@seed.yamba.dev
Expéditeur	João Santos	joao.shipper@seed.yamba.dev
Expéditeur	Chinwe Eze	chinwe.shipper@seed.yamba.dev
Expéditeur	Marie-Claire Bouchard	marieclaire.shipper@seed.yamba.dev
Expéditeur	Mai Trần	mai.shipper@seed.yamba.dev
Expéditeur	Pauline Lemaire	pauline.shipper@seed.yamba.dev

Code de livraison commun aux réservations passées par la remise : **742891** .

2.4 Ce que le jeu d'essai pose déjà dans chaque file admin

C'est la table la plus utile du cahier : elle dit ce que le testeur doit **voir** en arrivant, avant tout geste.

File / écran	Ce qui est posé	Repère
À arbitrer — litiges	2 litiges ouverts : YAM-2041 (Paris → Brazzaville, Expéditeur Chinwe Eze, Voyageur Thomas Nkounkou, catégorie « Contenu manquant », ouvert il y a 1 jour) et YAM-2042 (Londres → Lagos, Expéditeur Mai Trần, Voyageur Adebayo Okonkwo, ouvert il y a 8 heures)	les deux deals sont DISPUTED , versement FROZEN
À arbitrer — retenues	1 retenue conservée : deal <code>bzv-held</code> (Paris → Brazzaville, Expéditeur Aminata Diallo), annulé après le départ, remboursé à 50 %, <code>retentionDisposition = HELD_FOR_MEDIATION</code>	montant retenu = la moitié du total payé
Billets	1 billet PENDING de type <code>TICKET_PROOF</code> déposé sur le premier trajet à venir (Paris → Brazzaville, départ à J+10, Voyageur Thomas Nkounkou) ; le trajet porte <code>ticketVerificationStatus = PENDING</code>	la file affiche une carte
Finances — versements en échec	1 versement FAILED : deal <code>bzv-completed-blocked</code> , motif <code>CARRIER_ACCOUNT_NOT_READY</code> , 4 tentatives , dernière tentative et prochaine relance datées d'hier (donc immédiatement rejouable)	alimente aussi l'alerte PAYOUT_FAILED_48H

File / écran	Ce qui est posé	Repère
Finances — transferts renversés	1 transfert REVERSED : deal <code>bzv-reversed</code> , motif <code>PROVIDER_REVERSED</code> , <code>transferId tr_fake_seed_bzv-reversed</code> , aucune clôture	alimente l'alerte <code>REVERSAL_OPEN_48H</code>
Finances — remboursements proposés	aucun : c'est au testeur d'en créer un (scénario <code>ADM-REM-1</code>)	la file est vide au départ
Signalements — messages	1 signalement OPEN de motif <code>OFF_PLATFORM</code> (« Veut sortir de Yamba ») sur un message du Voyageur du deal <code>bzv-accepted</code> , précisions « Il propose de régler hors de Yamba. »	file « Messages » de <code>/reports</code>
Signalements — trajets et membres	aucun : à créer depuis le front membre (scénario <code>ADM-SIG-1</code>)	file « Trajets et membres » vide
Conversations	1 fil sur le deal <code>bzv-accepted</code> : 2 messages, 1 rendez-vous <code>PROPOSED</code> au terminal 2E de Paris CDG, 1 message signalé	ouvrable depuis le signalement
Utilisateurs	12 comptes, tous <code>ACTIVE</code> , aucune sanction ni proposition	
Demandes RGPD	vide (aucun <code>DataRequest</code>)	à alimenter par le scénario <code>ADM-RGP-1</code>
Paramètres	toutes les valeurs par défaut si <code>seed-settings.ts</code> vient d'être joué	l'écran affiche « toutes les valeurs sont celles par défaut »

Note. Le jeu d'essai ne crée **aucun** compte admin. C'est l'objet du paragraphe suivant.

2.5 Créer les quatre comptes admin de recette

Le rôle ADMIN ne s'obtient **jamais** par l'inscription ni par une route publique : uniquement par le script `grant-admin.ts`, sur le poste de l'opérateur (RG-ADM-01).

Étape 1 — créer quatre comptes membres normaux depuis le front (<http://localhost:3000>, « S'inscrire »), avec quatre adresses dont tu contrôles la boîte (Mailpit accepte n'importe quel domaine) :

Rôle de recette	Adresse suggérée	Prénom / nom suggérés
Super administrateur	<code>super@recette.yamba.dev</code>	Sacha Superviseur
Médiateur	<code>mediateur@recette.yamba.dev</code>	Nadia Médiatrice
Support	<code>support@recette.yamba.dev</code>	Sami Support
Exploitation	<code>exploitation@recette.yamba.dev</code>	Olivier Exploitation

Note le mot de passe de chacun : le back-office utilise **le même mot de passe** que le compte membre.

Étape 2 — poser les profils admin. Syntaxe exacte du script (les profils acceptés sont `SUPER_ADMIN` | `MEDIATOR` | `SUPPORT` | `FINANCE` | `OPS` | `PRIVACY`) :

```
npx tsx --env-file=.env packages/libs/prisma/scripts/grant-admin.ts super@recette.yamba.dev
npx tsx --env-file=.env packages/libs/prisma/scripts/grant-admin.ts mediateur@recette.yamba.dev --role MEDIATOR
npx tsx --env-file=.env packages/libs/prisma/scripts/grant-admin.ts support@recette.yamba.dev --role SUPPORT
npx tsx --env-file=.env packages/libs/prisma/scripts/grant-admin.ts exploitation@recette.yamba.dev --role OPS
```

Sans `--role`, le script pose **SUPER_ADMIN**. Pour un compte à profils cumulés (nécessaire au scénario ADM-PRM-7) :

```
npx tsx --env-file=.env packages/libs/prisma/scripts/grant-admin.ts cumul@recette.yamba.dev --roles SUPPORT,FINANCE
```

Réponses attendues du script : - succès → Profils <PROFILS> posés sur <email> – la 2FA sera exigée à la première connexion admin. - compte inexistant → Aucun compte pour <email> (code de sortie 1) - profils déjà posés à l'identique → <email> est déjà <PROFILS> (2FA à activer à la première connexion) - profil inconnu → Profil inconnu dans « ... » (attendu : SUPER_ADMIN | MEDIATOR | SUPPORT | FINANCE | OPS | PRIVACY, séparés par des virgules)

Pour retirer un accès (efface aussi le secret 2FA et les codes de secours) :

```
npx tsx --env-file=.env packages/libs/prisma/scripts/grant-admin.ts <email> --revoke
```

Étape 3 — activer la double authentification pour chacun. Elle est **obligatoire** : aucun écran admin ne s'ouvre sans elle. Pour chaque compte, dérouler le scénario ADM-SEC-2 (premier enrôlement avec le code QR) :

1. Ouvrir <http://localhost:3001> en **navigation privée** (une fenêtre privée par profil : les cookies admin sont partagés par navigateur).
2. Saisir l'email et le mot de passe → « Continuer ».
3. L'écran affiche un **code QR** et le secret en clair. Le scanner avec une application TOTP (Google Authenticator, Aegis, 1Password...) ou saisir le secret à la main.
4. Entrer le code à six chiffres → « Activer la 2FA ».
5. **Recopier les huit codes de secours** dans le carnet de recette : ils ne sont montrés **qu'une fois**. Ils servent aux scénarios ADM-SEC-4 et ADM-SEC-5.
6. Cliquer « J'ai enregistré mes codes ».

Astuce de recette. Prévois **deux** codes de secours par compte : le scénario du blocage après cinq échecs consomme du temps, celui du code de secours consomme un code.

Il n'existe aucun écran pour régénérer des codes ou réinitialiser la 2FA. Si l'application d'authentification est perdue, le seul chemin est `grant-admin.ts --revoke` puis une nouvelle attribution de profil (le retrait efface le secret TOTP), ce qui **réenrôle** au prochain accès.

2.6 Deux profils simultanés

Douze scénarios de ce cahier exigent **deux sessions admin ouvertes en même temps** (un profil propose, un autre applique). Ils portent la mention ► **deux profils**. Utilise deux navigateurs différents (ou une fenêtre privée par profil) : deux onglets du même navigateur partagent les cookies `admin_access_token` et se marchent dessus.

2.7 Outillage de vérification du journal

Presque chaque scénario demande de vérifier une ligne de journal. Trois chemins, du plus rapide au plus sûr :

Chemin	Qui peut	Comment
Écran /audit	audit.read (Finance, super administrateur)	filtres période / auteur / action / type de cible / identifiant / IP
Bloc « Actions admin sur ce ... »	tout profil qui lit la fiche	en bas des fiches membre, trajet, argent : le journal filtré sur cette cible
Base Mongo	développeur	collection AdminAction , tri createdAt décroissant

Le testeur se connecte donc au moins une fois avec le compte super administrateur pour contrôler le journal des gestes faits par les autres profils.

3. Conventions

3.1 Numérotation

ADM--<ÉCRAN>--<n>

Code écran	Écran ou domaine
SEC	Sécurité d'accès : connexion, 2FA, sessions
PRM	Matrice des permissions, profil par profil
ACC	Accueil et compteurs
ALR	Alertes de seuil (/alerts)
USR	Utilisateurs : recherche et fiche
SNC	Sanctions : proposer / appliquer / lever
EML	Suppression d'adresse email
EXP	Exports CSV (nominatif et opérationnels)
TRJ	Trajets : liste, fiche, masquage
BIL	Billets à vérifier
MED	Médiation : file, dossier, décision
RET	Retenue d'annulation tardive
FIN	Finances : files d'exception
ARG	Fiche argent d'un deal
RAP	Rapprochement avec le fournisseur de paiement
VER	Versements : rejeu, renversement
REM	Remboursement manuel
RPT	Rapport mensuel et export finances
PIL	Pilotage et drilldown
CNV	Conversations
SIG	Signalements (deux files)

Code écran	Écran ou domaine
PAR	Paramètres de la plateforme
RGP	Données personnelles et effacement
ETA	État des services
MNT	Maintenance
JRN	Journal d'audit
CPT	Comptes admin
SES	Mes sessions
E2E	Cas de bout en bout
NRG	Non-régression

3.2 Verdicts

Verdict	Quand l'employer
Conforme	Le résultat attendu et la ligne de journal attendue sont tous deux observés
Non conforme	L'un des deux manque, ou diffère
Bloqué	Le scénario ne peut pas être joué (précondition impossible à poser)
Non applicable »»	Le scénario exige une configuration absente de l'environnement de recette

Un écran juste avec un journal muet est **non conforme**. C'est la règle centrale de ce cahier.

3.3 Gravité d'une anomalie

Gravité	Définition	Exemples
Bloquante	Un geste d'argent, de sanction ou de sécurité est impossible, ou s'exécute sans trace	Un remboursement appliqué sans ligne REFUND_MANUAL_APPLIED ; un profil Support qui applique une sanction
Majeure	Un geste métier est faux ou une file ne se vide pas	Une décision de litige qui verse le mauvais montant ; un signalement traité qui reste « à traiter »
Mineure	Gêne d'usage sans perte de données ni faute métier	Un filtre d'URL non lu, un compteur mal arrondi
Cosmétique	Texte, libellé, alignement	Un sous-titre périmé, un libellé d'action affiché en code brut
Documentaire	Le code est juste, le document ment	Une règle de gestion qui dit « quatre profils » alors qu'il y en a six

3.4 La règle des deux vérifications

Tout geste se vérifie deux fois : à l'écran et dans le journal.

Le back-office repose sur un principe non négociable (RG-ADM-06) : « *un geste dont le journal ne s'écrit pas n'a pas eu lieu* ». La ligne `AdminAction` est écrite **dans la même transaction Mongo** que le geste ; elle n'est jamais « au mieux ».

Chaque fiche de scénario porte donc deux blocs distincts :

- **Résultat attendu** — ce que voit le testeur : bandeau, badge, compteur, email, effet côté membre.
- **Ligne de journal attendue** — quatre colonnes : **action** (le code exact, ex. `USER_RESTRICTED`), **cible** (type et identifiant, ex. `USER · 64f...`), **avant**, **après**.

Le testeur relève l'horodatage et l'auteur de la ligne : ils doivent correspondre à la seconde et au compte qui a agi.

Trois nuances à connaître avant de commencer :

1. **Les lectures sensibles sont journalisées elles aussi.** Ouvrir une fiche membre, un dossier de médiation, une fiche trajet, un billet, une fiche argent, une conversation ou le registre RGPD écrit une ligne. Un testeur qui « regarde juste » laisse une trace : c'est voulu.
2. **Certaines actions écrivent une ligne par élément.** Une modification de trois paramètres écrit **trois** lignes `SETTING_CHANGED`, pas une.
3. **Le journal n'est jamais purgé** (RG-MNT-07). Une ligne de recette y reste : n'y écris rien qui ressemble à une donnée réelle.

3.5 Conventions de lecture des fiches

Marque	Sens
► deux profils	Le scénario exige deux sessions admin simultanées, de profils différents
»»	Scénario non jouable dans l'environnement de recette local ; la raison est donnée
	Scénario destructeur : rejouer le jeu d'essai avant de continuer
✉	Le scénario vérifie un email : garder Mailpit ouvert

Les libellés entre « guillemets » sont **recopiés du code**. Un écart de libellé se consigne comme anomalie cosmétique.

4. Sécurité d'accès

Ce chapitre passe en premier : tout le reste du cahier suppose qu'une session admin s'ouvre correctement et qu'elle ne donne accès qu'à ce que le profil autorise.

4.1 Connexion en deux étapes

ADM-SEC-1 — Première étape : email et mot de passe

Gravité : bloquante. Préconditions : un compte admin existe (§2.5), 2FA déjà activée.

Étapes : 1. Ouvrir `http://localhost:3001` dans une fenêtre privée. 2. Observer la redirection automatique vers `/login`. 3. Vérifier le titre « Yamba · Back-office » et le sous-titre « Accès réservé, double authentification obligatoire. ». 4. Saisir l'email du compte Médiateur et un mot de passe **faux**. Cliquer « Continuer ». 5. Corriger le mot de passe. Cliquer « Continuer ».

Résultat attendu : - Étape 4 : message rouge exactement « Email ou mot de passe incorrect. ». **Aucune** indication ne dit si c'est l'email ou le mot de passe qui est faux, ni si le compte existe. - Étape 5 : le formulaire est remplacé par le champ de code à six chiffres, avec le texte « Saisis le code de ton application d'authentification, ou un code de secours. » et le bouton « Se connecter ». - Un cookie `admin_preauth` est posé (durée 5 minutes). Aucun cookie `admin_access_token` à ce stade.

Ligne de journal attendue : aucune. La première étape ne journalise rien — la ligne `ADMIN_LOGIN` n'est écrite qu'à l'ouverture effective de la session.

Verdict : ☐ conforme ☐ non conforme

ADM-SEC-2 — Premier enrôlement avec le code QR

Gravité : bloquante. Préconditions : un compte admin **neuf**, dont la 2FA n'a jamais été activée (par exemple `exploitation@recette.yamba.dev` juste après `grant-admin.ts`).

Étapes : 1. Se connecter avec email et mot de passe corrects. 2. Constaté que l'écran suivant n'est **pas** le champ de code, mais un écran d'enrôlement. 3. Vérifier la présence d'un **code QR** (image, texte alternatif « QR code TOTP ») et, dessous, du **secret en clair** en police à chasse fixe. 4. Scanner le QR avec une application TOTP. 5. Saisir le code à six chiffres. Cliquer « Activer la 2FA ». 6. Relever l'écran des codes de secours. 7. Cliquer « J'ai enregistré mes codes ».

Résultat attendu : - Étape 5 → écran intitulé « 2FA activée. Codes de secours, montrés une seule fois : ». - **Huit** codes affichés, au format `ABCDE-FGHIJ`, sur deux colonnes. - Mention « Range-les hors de ce poste (gestionnaire de mots de passe). Chaque code ne sert qu'une fois. ». - Étape 7 → arrivée sur `/home`. - ✉ Un email « Nouvelle connexion au back-office Yamba » arrive dans Mailpit, avec l'adresse IP, l'appareil et la date. - En base, le secret est **chiffré** (champ `totpSecretEncrypted`) : il ne doit jamais apparaître en clair dans un `AdminAction`.

Lignes de journal attendues : deux, dans cet ordre.

Action	Cible	Avant	Après
<code>ADMIN_TOTP_ENABLED</code>	<code>USER · <id de l'admin></code>	—	—
<code>ADMIN_LOGIN</code>	<code>USER · <id de l'admin></code>	—	—

Verdict : ☐ conforme ☐ non conforme

ADM-SEC-3 — Connexion courante par code TOTP et anti-rejeu

Gravité : bloquante. Préconditions : compte avec 2FA active, application TOTP synchronisée.

Étapes : 1. Email + mot de passe → « Continuer ». 2. Saisir le code à six chiffres affiché par l'application. « Se connecter ». 3. Se déconnecter (bouton « Se déconnecter » de la barre latérale). 4. Recommencer aussitôt la connexion en saisissant **le même code**, avant qu'il ne change (pas de 30 secondes).

Résultat attendu : - Étape 2 → arrivée sur `/home`. - Étape 4 → refus : message « Code invalide. ». Le code déjà consommé dans le même pas de 30 secondes est rejeté (protection anti-rejeu). - Attendre le code suivant : la connexion passe.

Lignes de journal attendues :

Action	Cible	Quand
<code>ADMIN_LOGIN</code>	<code>USER · <id></code>	à l'étape 2
<code>ADMIN_LOGOUT</code>	<code>USER · <id></code>	à l'étape 3
—	—	l'étape 4 refusée n'écrit rien
<code>ADMIN_LOGIN</code>	<code>USER · <id></code>	à la reprise avec le code suivant

Verdict : ☐ conforme ☐ non conforme

ADM-SEC-4 — Connexion par code de secours

Gravité : majeure. Préconditions : avoir noté les huit codes de secours à l'enrôlement. Ce scénario **consomme** un code.

Étapes : 1. Email + mot de passe → « Continuer ». 2. Au lieu du code à six chiffres, saisir un **code de secours** au format ABCDE-FGHIJ (le champ accepte du texte quand le mode code de secours est permis). 3. « Se connecter ». 4. Se déconnecter, puis retenter la connexion **avec le même code de secours**. 5. Observer la barre latérale une fois connecté.

Résultat attendu : - Étape 3 → session ouverte, arrivée sur /home . - Étape 4 → refus « Code invalide. » : un code de secours ne sert **qu'une fois**. - Étape 5 → quand il reste **deux codes ou moins**, la barre latérale affiche « Il te reste n code(s) de secours ». Au-dessus de deux, aucun avertissement.

Lignes de journal attendues : deux lignes pour une seule connexion.

Action	Cible	Avant	Après
ADMIN_BACKUP_CODE_USED	USER · <id>	—	—
ADMIN_LOGIN	USER · <id>	—	—

Verdict : ☐ conforme ☐ non conforme

ADM-SEC-5 — Blocage après cinq échecs

Gravité : bloquante. Préconditions : un compte admin dédié à ce scénario (le blocage dure quinze minutes et immobilise le compte).

Étapes : 1. Email + mot de passe corrects → « Continuer ». 2. Saisir cinq fois de suite un code à six chiffres faux (000000 , 111111 , ...), en validant à chaque fois. 3. À la sixième tentative, saisir le **vrai** code de l'application. 4. Attendre quinze minutes, puis retenter avec le vrai code.

Résultat attendu : - Étapes 2 (tentatives 1 à 5) → « Code invalide. ». - Étape 3 → le vrai code est **refusé** malgré tout : le compteur d'échecs est atteint. Le message du serveur est « Too many attempts. Try again in 15 minutes. » (l'écran peut l'afficher tel quel ou l'encapsuler). - Étape 4 → la connexion passe de nouveau. Le compteur Redis (admin_totp_fail:<userId> , TTL 15 minutes) a expiré. - Point de contrôle : le compteur est **par compte**, pas par adresse IP. Changer de navigateur ne débloque pas.

Lignes de journal attendues : **aucune** pour les tentatives refusées. Seule la connexion réussie de l'étape 4 écrit ADMIN_LOGIN . Une tentative échouée qui écrirait une ligne serait une anomalie (bruit dans un journal jamais purgé).

Verdict : ☐ conforme ☐ non conforme

ADM-SEC-6 — Le délai de pré-authentification

Gravité : mineure.

Étapes : 1. Email + mot de passe → « Continuer ». 2. Laisser l'écran du code ouvert **plus de cinq minutes** sans rien saisir. 3. Saisir alors un code valide.

Résultat attendu : l'écran revient au formulaire du mot de passe avec le message « Délai dépassé : recommence depuis le mot de passe. ». Le cookie `admin_preauth` a expiré.

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

4.2 Séparation des sessions et durée de vie

ADM-SEC-7 — La session membre n'ouvre aucune route admin

Gravité : bloquante. **deux fronts** **Préconditions :** le compte `super@recette.yamba.dev` est aussi un compte membre (c'est le même `User`).

Étapes : 1. Dans un navigateur, se connecter sur le **front membre** (`http://localhost:3000`) avec `super@recette.yamba.dev`. Vérifier l'accès à l'espace membre. 2. **Dans le même navigateur**, ouvrir `http://localhost:3001/home`. 3. Depuis le même navigateur, appeler directement une route admin, par exemple `http://localhost:8080/api/admin/kpis`. 4. Ouvrir le back-office et s'y connecter (deux étapes). 5. Revenir sur l'onglet du front membre et recharger.

Résultat attendu : - Étape 2 → redirection vers `/login`. La session membre ne donne **aucun** accès. - Étape 3 → réponse **401**. Le middleware `isAdminAuthenticated` ne lit jamais le cookie `access_token` : il exige `admin_access_token`. - Étape 4 → session admin ouverte. - Étape 5 → la session **membre est toujours ouverte** : ouvrir l'admin ne déconnecte pas le membre. Les deux cookies coexistent. - Contrôle complémentaire : dans l'inspecteur, on voit `access_token` / `refresh_token` **et** `admin_access_token` / `admin_refresh_token`, distincts.

Ligne de journal attendue : un seul `ADMIN_LOGIN`, à l'étape 4. Les tentatives des étapes 2 et 3 ne journalisent rien.

Verdict : ☐ conforme ☐ non conforme

ADM-SEC-8 — Expiration par inactivité (45 minutes)

Gravité : majeure. **Préconditions :** une session admin ouverte. Ce scénario dure **plus de 45 minutes** : le lancer en fond de recette.

Étapes : 1. Se connecter, arriver sur `/home`. 2. Laisser le navigateur **strictement inactif** 46 minutes (aucun onglet du back-office au premier plan, pas de navigation ; l'écran `/status` se rafraîchit tout seul, ne pas le laisser ouvert). 3. Cliquer une entrée du menu.

Résultat attendu : retour à `/login`. Le jeton d'accès (15 minutes) n'est plus renouvelable : l'enregistrement Redis `admin_jti:<userId>:<jti>` a expiré au bout de 45 minutes sans activité.

Ligne de journal attendue : aucune (une expiration n'est pas une déconnexion volontaire).

Verdict : ☐ conforme ☐ non conforme

ADM-SEC-9 — Durée de vie absolue (12 heures)

Gravité : majeure. »» partiellement

Étapes : 1. Ouvrir une session admin et noter l'heure. 2. La maintenir active (une navigation toutes les 30 minutes) pendant plus de 12 heures. 3. Naviguer.

Résultat attendu : au-delà de 12 heures depuis l'ouverture (`createdAt` de la session, **non** remis à zéro par le renouvellement du jeton), la session tombe et l'écran renvoie à `/login`, même si l'admin était actif à la seconde d'avant. Il n'existe **aucune** option « rester connecté ».

»» **Ce scénario n'est pas jouable dans une journée de recette normale.** Deux substituts acceptables, à documenter dans le carnet : - Vérifier dans Redis que le TTL posé sur `admin_jti:<userId>:<jti>` est le **minimum** entre le reste d'inactivité (45 min) et le reste de vie absolue (12 h depuis `createdAt`). - Faire vérifier par le développement que le renouvellement (`POST /auth/admin/refresh`) fait tourner le `jti` **en conservant** `createdAt`.

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme ☐ »»

ADM-SEC-10 — Révoquer une session depuis « Mes sessions »

Gravité : majeure. Préconditions : deux sessions ouvertes pour **le même compte admin**, dans deux navigateurs différents (A et B).

Étapes : 1. Depuis le navigateur A, ouvrir « Mes sessions » (`/sessions`). Titre attendu : « Mes sessions admin », sous-titre « Une alerte email part à chaque ouverture de session. Révoque ce que tu ne reconnais pas. ». 2. Vérifier que deux lignes apparaissent, avec « ouverte le », « active le », et la mention « cette session » sur l'une des deux. 3. Révoquer la session **B**. 4. Dans le navigateur B, naviguer. 5. Depuis A, révoquer sa propre session (« cette session »).

Résultat attendu : - Étape 4 → le navigateur B est renvoyé à `/login`. - Étape 5 → le navigateur A est immédiatement renvoyé à `/login`. - ☒ Deux emails « Nouvelle connexion au back-office Yamba » ont été reçus, un par ouverture de session.

Lignes de journal attendues : une par révocation.

Action	Cible	Avant	Après
ADMIN_SESSION_REVOKED	SESSION · <jti révoqué>	—	—

Verdict : ☐ conforme ☐ non conforme

4.3 La matrice des permissions, profil par profil

C'est le cœur de la sécurité du back-office. Pour **chaque** profil, on vérifie trois choses : 1. **le menu** — ce qui est affiché dans la barre latérale ; 2. **ce qu'il peut faire** — au moins un geste d'écriture réussi ; 3. **un refus** — au moins un écran ou un appel qui doit répondre 403.

Point de méthode capital. Le back-office **cache** les boutons interdits (miroir `apps/admin-ui/src/lib/permissions.ts`), mais c'est **le serveur qui juge**. Un bouton caché ne prouve rien. Chaque

scénario de refus se joue donc **en appel direct** sur le gateway, avec les cookies de la session concernée, pour vérifier le **403** — par exemple depuis la console du navigateur :

```
js await fetch("/api/admin/settings", { method: "PATCH", credentials: "include", headers: {  
"Content-Type": "application/json" }, body: JSON.stringify({ changes: {}, reason: "",  
expectedVersion: 1 }) }).then(r => r.status)
```

Un **200** ou un **400** là où on attend un **403** est une anomalie **bloquante** : la garde serveur est absente.

Le menu complet, dans l'ordre exact du code, et la permission qui le gouverne :

#	Entrée	Chemin	Permission
1	Accueil	/home	aucune (toute session admin)
2	Alertes	/alerts	kpi.read
3	À arbitrer	/disputes	disputes.read
4	Billets	/tickets	tickets.review
5	Trajets	/trips	trips.read
6	Signalements	/reports	reports.review
7	Finances	/finances	finances.read
8	Pilotage	/pilotage	pilotage.read
9	Utilisateurs	/users	users.read
10	Journal	/audit	audit.read
11	Paramètres	/settings	settings.read
12	Données personnelles	/privacy	privacy.requests.read
13	État des services	/status	status.read
14	Comptes admin	/admins	admins.manage
15	Mes sessions	/sessions	aucune

ADM-PRM-1 — Profil Super administrateur

Gravité : bloquante.

Étapes : 1. Se connecter avec `super@recette.yamba.dev`. 2. Relever **tout** le menu latéral. 3. Vérifier le libellé de profil sous le nom, dans la barre latérale. 4. Ouvrir successivement les quinze entrées. 5. Ouvrir `/deals/<id>` d'un deal du jeu d'essai, `/settings/docs`, `/finances/report`.

Résultat attendu : - Les **quinze** entrées sont présentes, dans l'ordre du tableau ci-dessus. - Le libellé de profil affiche « Super administrateur ». - Aucune page ne répond 403. - Le super administrateur porte les 32 permissions, y compris les trois qu'aucun autre profil ne détient : `admins.manage`, `refunds.manual.apply`, `settings.business.write`.

Refus attendu malgré tout : le super administrateur reste soumis aux **conflits d'intérêts**. Sur sa propre fiche membre (`/users/<son id>`), la mention « (c'est toi : aucune action possible) » s'affiche et les cartes d'action sont masquées ; un appel direct `POST /api/admin/users/<son id>/suspension` répond **403** « You cannot act on your own account. ».

Ligne de journal attendue : un `USER_VIEWED` par fiche membre ouverte, un `TRIP_VIEWED` par fiche trajet, un `DEAL_MONEY_VIEWED` par fiche argent, un `DATA_REQUESTS_VIEWED` à l'ouverture de `/privacy`. Le simple parcours du menu laisse donc déjà plusieurs lignes.

Verdict : ☐ conforme ☐ non conforme

ADM-PRM-2 — Profil Médiateur

Gravité : bloquante.

Étapes : 1. Se connecter avec `mediateur@recette.yamba.dev`. 2. Relever le menu. 3. Ouvrir `/disputes`, ouvrir le dossier `YAM-2041`, vérifier la présence du formulaire « Trancher ». 4. Ouvrir la fiche de Thomas Nkounkou depuis le dossier : vérifier la présence de la carte Sanction avec le bouton « Appliquer ». 5. Tenter d'ouvrir `/settings` en tapant l'URL, puis `/admins`, puis `/privacy`. 6. Appel direct : `PATCH /api/admin/settings`.

Résultat attendu — le menu contient exactement : Accueil, Alertes, À arbitrer, Billets, Trajets, Signalements, Finances, Pilotage, Utilisateurs, Paramètres, État des services, Mes sessions. **Absents :** Journal, Données personnelles, Comptes admin.

Ce qu'il peut faire : trancher un litige et une retenue, appliquer et lever une sanction, masquer et rétablir un trajet, vérifier un billet, relancer un versement, clore un renversement, lire une conversation, traiter un signalement, exporter les trajets / billets / dossiers (identifiants seulement), lire le pilotage et les finances.

Refus attendus : - `/admins` → l'écran ne s'ouvre pas ; l'API répond **403**. - `/privacy` → **403**. - `PATCH /api/admin/settings` → **403** (il lit les paramètres, il ne les écrit pas ; message de portée « Your admin profile cannot change: ... »). - `GET /api/admin/audit` → **403** (`audit.read` appartient à Finance et au super administrateur). - Export nominatif des membres (`exports.personal`) → **403**, et le bouton rouge « Exporter en CSV (données personnelles) » n'apparaît pas sur `/users`.

Ligne de journal attendue : `DISPUTE_VIEWED` sur `BOOKING` · `<id du deal>` à l'ouverture du dossier, `USER_VIEWED` sur la fiche. Les tentatives refusées n'écrivent rien.

Verdict : ☐ conforme ☐ non conforme

ADM-PRM-3 — Profil Support

Gravité : bloquante.

Étapes : 1. Se connecter avec `support@recette.yamba.dev`. 2. Relever le menu. 3. Ouvrir `/tickets`, ouvrir le billet en attente, le **valider**. 4. Ouvrir une fiche membre : vérifier que la carte Sanction propose « Proposer » et **pas** « Appliquer ». 5. Ouvrir `/reports` et lire la conversation depuis le message signalé. 6. Tenter `/finances`, `/pilotage`, `/audit`. 7. Appel direct : `POST /api/admin/users/<id>/suspension` avec un motif de plus de 20 caractères.

Résultat attendu — menu : Accueil, Alertes, À arbitrer, Billets, Trajets, Signalements, Utilisateurs, Paramètres, État des services, Mes sessions. **Absents :** Finances, Pilotage, Journal, Données personnelles, Comptes admin.

Ce qu'il peut faire : lire les fiches, vérifier et rejeter un billet, **proposer** une sanction, **proposer** un masquage, traiter les signalements des deux files, lire une conversation, **proposer** un remboursement manuel (mais sans voir la file Finances : il y accède par le lien « argent » d'une fiche), lever une suppression d'adresse email.

Refus attendus : - Étape 6 : `/finances` → 403, `/pilotage` → 403, `/audit` → 403. - Étape 7 : **403** — c'est le refus le plus important du profil. Le Support **propose**, il n'applique jamais. - Il ne tranche aucun litige : sur `/disputes/<id>`, à la place du formulaire, le texte « Ton profil lit ce dossier mais ne tranche pas ».

Lignes de journal attendues :

Étape	Action	Cible	Après
3 (ouvrir)	DOCUMENT_VIEWED	TRIP · <id>	{ documentId }
3 (valider)	TICKET_VERIFIED	TRIP · <id>	{ documentId, reason: null }
4	USER_VIEWED	USER · <id>	—
5	CONVERSATION_VIEWED	CONVERSATION · <id>	{ bookingId, messages }
7	aucune	—	un 403 ne journalise pas

Verdict : ☐ conforme ☐ non conforme

ADM-PRM-4 — Profil Exploitation (OPS)

Gravité : bloquante. Préconditions : `exploitation@recette.yamba.dev` en profil OPS seul.

Étapes : 1. Se connecter. 2. Relever le menu. 3. Ouvrir `/settings` : vérifier que les clés de portée **exploitation** sont saisissables et que les clés de portée **métier** affichent « super administrateur seul ». 4. Modifier une clé d'exploitation (par exemple `alerts.payoutFailedHours`) avec un motif d'au moins 20 caractères. 5. Ouvrir `/status` et vérifier l'accès à l'éditeur de maintenance. 6. Tenter `/users`, `/disputes`, `/finances`, `/audit`. 7. Appel direct : modifier une clé **métier** (commission) via `PATCH /api/admin/settings`.

Résultat attendu — menu : Accueil, Alertes, Paramètres, État des services, Mes sessions. **Absents :** À arbitrer, Billets, Trajets, Signalements, Finances, Pilotage, Utilisateurs, Journal, Données personnelles, Comptes admin.

Ce qu'il peut faire : écrire les paramètres d'exploitation (seuils d'alerte, relances, conservation, documents, comptes neufs), planifier / activer / lever la maintenance, lire l'état des services, lire les compteurs d'accueil et les alertes de seuil.

Refus attendus : - Étape 6 : les quatre écrans répondent 403 — l'Exploitation ne touche **ni à l'argent, ni aux comptes, ni aux fiches membres**. - Étape 7 : **403** avec un message de portée nommant la clé refusée : « Your admin profile cannot change: pricing.commissionPct. »

Lignes de journal attendues :

Étape	Action	Cible	Avant / Après
4	SETTING_CHANGED	SETTINGS · <code>alerts.payoutFailedHours</code>	{ key, before, after, reason, version }

Verdict : ☐ conforme ☐ non conforme

ADM-PRM-5 — Profil Finance

Gravité : bloquante. Préconditions : créer un cinquième compte : `npx tsx --env-file=.env packages/libs/prisma/scripts/grant-admin.ts finance@recette.yamba.dev --role FINANCE`, puis enrôler la 2FA.

Étapes : 1. Se connecter, relever le menu. 2. Ouvrir `/finances`, puis la fiche argent d'un deal, puis `/finances/report`. 3. Télécharger l'export CSV du rapport mensuel. 4. Ouvrir `/audit`. 5. Ouvrir un dossier de médiation `/disputes/<id>`. 6. Tenter d'ouvrir une conversation `/conversations/<bookingId>`. 7. Appel direct : trancher un litige.

Résultat attendu — menu : Accueil, Alertes, À arbitrer, Trajets, Finances, Pilotage, Utilisateurs, Journal, Paramètres, État des services, Mes sessions. **Absents :** Billets, Signalements, Données personnelles, Comptes admin.

Ce qu'il peut faire : files d'exception, fiche argent, rapprochement, relancer un versement, clore un renversement, **proposer** un remboursement manuel, rapport mensuel et export finances, exports opérationnels, pilotage, journal d'audit.

Refus attendus : - Étape 6 : `/conversations/<bookingId>` → **403**. La Finance n'a rien à lire dans un fil de discussion : c'est une garde de vie privée, pas un oubli. - Étape 7 : **403** — la Finance ne tranche pas. - Le bouton « Rembourser maintenant » n'apparaît jamais : `refunds.manual.apply` est réservé au super administrateur.

Lignes de journal attendues :

Étape	Action	Cible	Après
2	DEAL_MONEY_VIEWED	BOOKING · <id>	—
3	FINANCE_EXPORTED	BOOKING (sans identifiant)	{ from, to, rows, filename }
5	DISPUTE_VIEWED	BOOKING · <id>	—

Verdict : ☐ conforme ☐ non conforme

ADM-PRM-6 — Profil Données personnelles (PRIVACY)

Gravité : bloquante. Préconditions : `npx tsx --env-file=.env packages/libs/prisma/scripts/grant-admin.ts privacy@recette.yamba.dev --role PRIVACY`, puis enrôlement 2FA.

Étapes : 1. Se connecter, relever le menu. 2. Ouvrir `/home` et observer la zone des compteurs. 3. Ouvrir `/privacy`. 4. Ouvrir `/users` puis une fiche membre : vérifier la présence du bouton d'export nominatif et de la carte « Effacer ce compte (RGPD) ». 5. Ouvrir `/status`. 6. Tenter `/disputes`, `/finances`, `/trips`, `/settings`.

Résultat attendu — menu : Accueil, Données personnelles, État des services, Mes sessions. C'est le menu le plus court.

Comportement particulier de l'accueil : le profil PRIVACY **n'a pas** `kpi.read`. La page `/home` s'ouvre, mais l'appel `GET /admin/kpis` répond 403 et l'écran affiche le message d'erreur en rouge à la place des tuiles. **Ce n'est pas une anomalie :** c'est le comportement attendu, à consigner tel quel. L'entrée « Alertes » n'apparaît pas non plus.

Ce qu'il peut faire : lire le registre RGPD, effacer un compte à la demande, exporter les membres en CSV nominatif (permission `exports.personal`, partagée avec le super administrateur seul), lever une suppression d'adresse email, lire l'état des services.

Refus attendus : les quatre écrans de l'étape 6 répondent 403.

Note de non-conformité documentaire connue : RG-ADM-33, `CLAUDE.md` et le commentaire d'en-tête de `ExportButton.tsx` disent « super administrateur seul » pour l'export nominatif. Le code teste la permission

`exports.personal`, que PRIVACY détient depuis A143. **Le comportement observé (PRIVACY exporte) est le bon** ; consigner l'écart en anomalie **documentaire**.

Lignes de journal attendues :

Étape	Action	Cible	Après
3	<code>DATA_REQUESTS_VIEWED</code>	USER (sans identifiant)	<code>{ rows }</code>
4	<code>USER_VIEWED</code>	USER · <code><id></code>	—

Verdict : ☐ conforme ☐ non conforme

ADM-PRM-7 — Cumul de profils : Support + Finance

Gravité : majeure. Préconditions : un compte `cumul@recette.yamba.dev` avec `--roles SUPPORT,FINANCE`, 2FA enrôlée.

Étapes : 1. Se connecter, relever le menu et le libellé de profil dans la barre latérale. 2. Ouvrir `/finances` et `/tickets`. 3. Ouvrir un dossier de médiation. 4. Sur une fiche argent, proposer un remboursement manuel. 5. Tenter de trancher le litige `YAM-2041`.

Résultat attendu : - Le libellé de profil affiche les deux profils cumulés, dans l'ordre canonique : « Support + Finance ». - Le menu est l'**union** des deux : Accueil, Alertes, À arbitrer, Billets, Trajets, Signalements, Finances, Pilotage, Utilisateurs, Journal, Paramètres, État des services, Mes sessions. - Étape 4 → la proposition passe (la permission vient du profil Finance **et** du profil Support). - Étape 5 → **refus** : ni Support ni Finance ne portent `disputes.decide`. L'union ne crée jamais un droit qu'aucun des deux profils n'a.

Ligne de journal attendue : `REFUND_MANUAL_PROPOSED` sur `BOOKING · <id>`, `after: { amountCents, reason }`.

Verdict : ☐ conforme ☐ non conforme

ADM-PRM-8 — Les conflits d'intérêts

Gravité : bloquante. ► deux profils Préconditions : le compte Médiateur possède aussi un trajet publié et un deal en tant que partie (à poser depuis le front membre ; sinon, se limiter aux deux premiers cas).

Étapes et résultats attendus :

#	Situation	Geste	Réponse serveur attendue
1	L'admin ouvre sa propre fiche membre	Chercher la carte Sanction	Mention « (c'est toi : aucune action possible) », cartes masquées ; appel direct → 403 « You cannot act on your own account. »
2	Un Médiateur veut sanctionner le compte du Support (qui porte un profil admin)	« Appliquer » une restriction	403 « Only a super administrator can act on an admin account. »
3	L'admin est le Voyageur d'un trajet	Ouvrir <code>/trips/<son trajet></code>	La carte Masquage est absente ; appel direct → 403 « You cannot act on your own trip. »
4	L'admin a déposé le billet	Ouvrir le billet dans <code>/tickets</code> puis valider	403 « You cannot review your own ticket. »

#	Situation	Geste	Réponse serveur attendue
5	L'admin est partie au deal	Ouvrir /disputes/<id> puis trancher	403 ; sur la fiche argent, les <code>allowedActions</code> sont à <code>false</code> et les boutons sont inertes
6	Un super administrateur veut effacer son propre compte	« Effacer définitivement »	403 « You cannot erase your own account from the back-office. »
7	Un super administrateur veut retirer son propre accès admin	« Retirer » sur sa ligne dans /admins	403
8	Il ne reste qu'un super administrateur, on veut le rétrograder	Décocher SUPER_ADMIN	403 « The last super administrator cannot be downgraded / revoked. »

Ligne de journal attendue : aucune dans les huit cas. Un refus ne s'écrit pas au journal — c'est un point d'attention : le journal ne prouve pas ce qui a été **tenté**, seulement ce qui a été **fait**.

Verdict : ☐ conforme ☐ non conforme

ADM-PRM-9 — Le bouton caché ne remplace pas la garde serveur

Gravité : bloquante.

Objet : vérifier systématiquement que chaque interdiction est **aussi** appliquée côté serveur. Le testeur joue ce scénario une fois avec chaque profil non-super-administrateur.

Étapes : avec la session ouverte, appeler directement depuis la console du navigateur (les cookies partent avec `credentials: "include"`) chacune des routes suivantes que le profil ne doit pas atteindre :

Route	Méthode	Permission
/api/admin/admins	GET	<code>admins.manage</code>
/api/admin/settings	PATCH	portée métier / exploitation
/api/admin/audit	GET	<code>audit.read</code>
/api/admin/privacy/requests	GET	<code>privacy.requests.read</code>
/api/admin/finances	GET	<code>finances.read</code>
/api/admin/pilotage/series	GET	<code>pilotage.read</code>
/api/admin/conversations/<bookingId>	GET	<code>conversations.read</code>
/api/admin/deals/<id>/refund/apply	POST	<code>refunds.manual.apply</code>
/api/admin/users/<id>/suspension	POST	<code>users.suspension.apply</code>
/api/admin/disputes/<id>/decision	POST	<code>disputes.decide</code>

Résultat attendu : 403 pour chaque route interdite au profil, avec un message explicite. Aucune de ces routes ne doit répondre 200, 400 ou 404 quand la permission manque — un **404** à la place d'un 403 est acceptable **uniquement** quand la ressource ne doit pas être révélée ; noter le cas dans le carnet.

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

5. Les écrans, un chapitre par écran

5.1 Accueil et compteurs (/home)

ADM-ACC-1 — Les compteurs correspondent à la réalité

Gravité : majeure. Préconditions : jeu d'essai fraîchement rejoué, session **super administrateur**.

Étapes : 1. Ouvrir /home . Vérifier le titre « Accueil » et le sous-titre « Ce qui attend une action, selon ton profil. Les chiffres de fond se lisent dans Pilotage, l'argent dans Finances. ». 2. Relever les tuiles de la section « À traiter ». 3. Relever les tuiles de la section « État de la plateforme ». 4. Lire le pied de page.

Résultat attendu — valeurs sur le jeu d'essai neuf :

Tuile	Valeur attendue	Lien
Litiges à trancher	2	/disputes
Retenues à arbitrer	1	/disputes
Billets à vérifier	1	/tickets
Masquages proposés	0	/trips?hideProposed=1
Sanctions proposées	0	/users
Versements en échec	1	/finances?kind=FAILED
Transferts renversés	1	/finances?kind=REVERSED
Remboursements proposés	0	/finances?kind=PROPOSED_REFUNDS
Invitations admin en attente	selon les comptes créés	/admins
Trajets et membres signalés	0	/reports
Messages signalés	1	/reports#messages
Trajets publiés à venir	5 (départs futurs)	/trips?status=PUBLISHED
Trajets masqués	0	/trips?hidden=1
Comptes	12 + les comptes admin de recette	/users

- Les tuiles « À traiter » dont la valeur est supérieure à zéro passent en **ambre**.
- Le pied affiche « Calculé le {date/heure} ».

Ligne de journal attendue : aucune. L'accueil ne fait aucune écriture. Si une ligne apparaît, c'est une anomalie.

Verdict : ☐ conforme ☐ non conforme

ADM-ACC-2 — Les compteurs sont filtrés par profil

Gravité : bloquante.

Étapes : 1. Ouvrir /home avec le profil **Support**. 2. Ouvrir /home avec le profil **Exploitation**. 3. Ouvrir /home avec le profil **Données personnelles**.

Résultat attendu : - **Support** : les tuiles « Versements en échec », « Transferts renversés », « Remboursements proposés » (finances.read) et « Invitations admin en attente » (admins.manage) sont **absentes**. Les autres

sont présentes. - **Exploitation** : les tuiles de file sont presque toutes absentes (il n'a ni `disputes.read`, ni `trips.read`, ni `users.read`, ni `finances.read`, ni `tickets.review`, ni `reports.review`) ; il conserve l'accès à la page et aux alertes (`kpi.read`). - **Données personnelles** : la page s'ouvre mais affiche le message d'erreur 403 de l'API en rouge à la place des tuiles (pas de `kpi.read`). **C'est le comportement attendu.**

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

ADM-ACC-3 — Le résumé des alertes et le bandeau des paramètres

Gravité : mineure. **Préconditions** : aucune alerte active (jeu d'essai neuf, seuils par défaut).

Étapes : 1. Ouvrir `/home`, lire le bandeau du haut. 2. Modifier un paramètre depuis `/settings` (profil Exploitation ou super administrateur), avec un motif. 3. Revenir sur `/home`.

Résultat attendu : - Étape 1 → bandeau vert « Aucune alerte : versements, litiges, relais, emails et liquidité dans les seuils. ». - Étape 3 → un bandeau apparaît : « Paramètres modifiés le {date} par {nom} : {clés} — voir les paramètres », le lien menant à `/settings`. - Quand des alertes existent, le bandeau devient un lien vers `/alerts` portant « {n} alertes de seuil · {n} critiques », « la plus grave : {titre} » et « Voir les alertes → ». **L'accueil ne montre plus le détail des neuf règles** (déplacé en A150).

Ligne de journal attendue : une ligne `SETTING_CHANGED` par clé modifiée à l'étape 2, cible `SETTINGS · <clé>`.

Verdict : ☐ conforme ☐ non conforme

5.2 Alertes de seuil (`/alerts`)

ADM-ALR-1 — La page existe et vit seule

Gravité : majeure.

Étapes : 1. Cliquer l'entrée « Alertes » du menu. 2. Vérifier le titre « Alertes de seuil » et le sous-titre « Neuf règles recalculées à chaque lecture, jamais stockées. Chaque alerte mène à l'écran où agir. Les seuils sont des paramètres : les changer change l'alerte, pas l'historique. ». 3. Sur un jeu d'essai neuf, lire l'état vide. 4. Lire le tableau « Seuils utilisés » en bas de page.

Résultat attendu : - Étape 3 → « Aucune alerte : versements, litiges, relais d'événements, emails et publication sont dans les clous. ». - Étape 4 → un tableau à deux colonnes, « Paramètre » et « Valeur », listant les seuils **en vigueur** (pas les constantes du code), suivi du pied « Réglables dans Paramètres » Alertes d'exploitation. Évaluées à la lecture, le {date} ; le support reçoit un email à la première apparition d'une règle dans la journée. ».

Ligne de journal attendue : aucune. La lecture des alertes n'est pas journalisée.

Verdict : ☐ conforme ☐ non conforme

ADM-ALR-2 — Faire apparaître une alerte en abaissant un seuil

Gravité : majeure. ► **deux profils** (Exploitation pour écrire le seuil, n'importe quel profil à `kpi.read` pour lire l'alerte)

Piège de recette expliqué. Les éléments du jeu d'essai sont **trop récents** pour franchir les seuils par défaut : le versement est en échec depuis 24 h (seuil 48 h), les litiges depuis 8 h et 24 h (seuil 72 h), la retenue depuis 4 jours (seuil 7 j). Sans abaisser un seuil, aucune alerte n'apparaît — et c'est correct.

Étapes : 1. Session **Exploitation**. Ouvrir `/settings`, groupe « Alertes d'exploitation ». 2. Passer `alerts.payoutFailedHours` de **48** à **1**. Motif : « Recette ADM-ALR-2 : abaissement temporaire du seuil ». 3. « Enregistrer (journalisé, email aux super administrateurs) ». 4. Attendre au plus 30 secondes, puis ouvrir `/alerts`. 5. Relever la carte apparue et cliquer « Aller traiter → ». 6. Remettre le seuil à 48 avec le lien « remettre », puis « Enregistrer ».

Résultat attendu : - Étape 4 → une carte apparaît dans le groupe « Critiques · 1 », portant le code de règle `PAYOUT_FAILED_48H`, le badge « 1 concerné » et un détail chiffré. - **Point d'attention documenté :** le nom de la règle garde son seuil historique (48H) même quand le paramètre vaut 1 h. C'est un identifiant, pas une valeur : **ce n'est pas une anomalie**. - Étape 5 → arrivée sur `/finances?kind=FAILED`, onglet « Versements en échec » présélectionné. - Étape 6 → l'alerte disparaît d'elle-même : elle n'a pas d'état.

Lignes de journal attendues : deux lignes `SETTING_CHANGED` sur `SETTINGS · alerts.payoutFailedHours` (une à l'abaissement, une au retour à 48), chacune avec `before`, `after`, `reason` et `version`.

Verdict : ☐ conforme ☐ non conforme

ADM-ALR-3 — L'email quotidien au support

Gravité : mineure. **Préconditions :** au moins une alerte active (voir ADM-ALR-2), cron `ops-alerts` du deal-service actif (`OPS_ALERTS_CRON_ENABLED` non désactivé), Mailpit ouvert.

Étapes : 1. Créer une alerte active. 2. Attendre le passage du cron horaire (minute 5 de chaque heure) ou le déclencher. 3. Lire Mailpit. 4. Attendre un second passage du cron dans la même journée.

Résultat attendu : - Étape 3 → un email en français arrive à l'adresse `SUPPORT_EMAIL` (défaut `support@yamba.app`), listant les règles **nouvelles** de la journée et un lien vers chaque file. - Étape 4 → **aucun second email** pour la même règle le même jour : une clé Redis `yamba:alerts:sent:<règle>:<jour UTC>` posée en `SET NX` (durée 2 jours) empêche la répétition. - Le lendemain, une alerte toujours active repart.

Ligne de journal attendue : aucune (un cron n'est pas un geste admin).

Verdict : ☐ conforme ☐ non conforme

ADM-ALR-4 — Les liens d'alerte mènent au bon filtre

Gravité : mineure.

Étapes : pour chaque alerte visible, cliquer « Aller traiter → » et vérifier l'écran d'arrivée.

Résultat attendu :

Règle	Destination attendue	Filtre pré-posé
<code>PAYOUT_FAILED_48H</code>	<code>/finances?kind=FAILED</code>	onglet « Versements en échec »

Règle	Destination attendue	Filtre pré-posé
DISPUTE_UNDECIDED_72H	/disputes? decidable=1	filtre « décidables maintenant » sélectionné
RETENTION_HELD_7D	/disputes? kind=RETENTION	filtre de type sur « retenues » sélectionné
REVERSAL_OPEN_48H	/finances? kind=REVERSED	onglet « Transferts renversés »
OUTBOX_PARKED , OUTBOX_LAGGING_15MIN , EMAILS_FAILED_24H , NO_TRIP_PUBLISHED_7D , ACCEPTANCE_RATE_LOW_7D	/pilotage	—

Point de non-régression. Les deux filtres de /disputes étaient auparavant **ignorés** : la file s'ouvrait sans filtre. Depuis le correctif, QueueTable lit kind, decidable, originCity, destinationCity et olderThanDays dans l'URL. Voir ADM-NRG-2.

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

5.3 Utilisateurs : recherche et fiche

ADM-USR-1 — Rechercher par tous les indices

Gravité : majeure. Préconditions : session Support, Médiateur, Finance ou super administrateur.

Étapes : 1. Ouvrir /users . Vérifier le sous-titre « Recherche par email, prénom, nom, téléphone, identifiant de deal ou ticket YAM. » et le placeholder « email, nom, +33..., 64b..., YAM-2041 ». 2. Chercher aminata.shipper@seed.yamba.dev . 3. Chercher Nkounkou . 4. Chercher +33612345601 . 5. Chercher YAM-2041 . 6. Chercher l'identifiant Mongo d'un deal (relevé dans seed-output.json). 7. Poser le filtre « Suspendu », puis cliquer « réinitialiser ».

Résultat attendu : - Étapes 2 à 4 → un résultat, la colonne « Nom » portant la mention « via email », « via name », « via phone ». - Étape 5 → **deux** résultats : l'Expéditeur **et** le Voyageur du dossier YAM-2041 (Chinwe Eze et Thomas Nkounkou), mention « via ticket ». Aucun autre filtre n'est appliqué. - Étape 6 → même comportement, mention « via dealId ». - Le compteur affiche « {n} affiché(s) · {total} au total ». - Étape 7 → le bouton « réinitialiser » n'apparaît que quand un filtre est actif ; il vide tous les filtres.

Ligne de journal attendue : aucune. Une recherche ne se journalise pas ; seule l'**ouverture d'une fiche** le fait.

Verdict : ☐ conforme ☐ non conforme

ADM-USR-2 — Ouvrir une fiche membre, et ce qu'elle montre

Gravité : majeure.

Étapes : 1. Depuis /users , ouvrir la fiche de **Thomas Nkounkou**. 2. Parcourir toutes les cartes. 3. Vérifier la carte « Risque interne (D29 ②) — invisible du membre ». 4. Descendre jusqu'à « Actions admin sur ce compte ».

Résultat attendu : - L'en-tête porte le nom, l'email, le téléphone, la langue préférée et le badge de statut (« Actif »). - Carte « Compte » : rôles client, date d'inscription, sessions actives, deals en cours. - Carte « Voyageur » : statut, **compte Stripe masqué** au format `acct_...xxxx`, encaissements / versements « oui », faits de réputation. - Carte « Expéditeur » : niveau, avis révélés, deals terminés, annulations tardives, **litiges perdus (interne)**. - Carte « Risque interne » : niveau (« Compte neuf », « Standard », « À surveiller », « À risque ») et score sur 100, facteurs, plafonds, activité du mois, puis la mention « Un score ne sanctionne rien : il éclaire une décision humaine (masquage, sanction) qui reste journalisée. ». - Carte « Trajets ({n}) » avec le lien « Ouvrir dans Trajets (fiches, masquage) », carte « Deals ({n}) » avec les liens « dossier » et « argent ». - **Jamais** : mot de passe, secret 2FA, code de livraison, identifiant Stripe complet. - La carte « Actions admin sur ce compte » contient déjà **la ligne de la consultation qu'on vient de faire** (après rechargement).

Ligne de journal attendue :

Action	Cible	Avant	Après
USER_VIEWED	USER · <id de Thomas>	—	—

Verdict : ☐ conforme ☐ non conforme

ADM-USR-3 — Le TrustScore reflète les faits

Gravité : mineure.

Étapes : 1. Ouvrir la fiche d'un membre **sans** historique (un compte admin de recette créé aujourd'hui). 2. Ouvrir la fiche de **Chinwe Eze** (Expéditeur du litige `YAM-2041`). 3. Trancher le litige `YAM-2041` par un **rejet** (scénario `ADM-MED-4`), puis rouvrir la fiche de Chinwe.

Résultat attendu : - Étape 1 → niveau « Compte neuf » (moins de 30 jours et moins de trois deals terminés), plafonds affichés (300 € déclarés, 10 kg, 5 envois par mois). - Étape 3 → le compteur « Litiges perdus (interne) » de Chinwe passe à **1** et le score augmente de **25 points** (plafond 60). Un rejet condamne l'Expéditeur. - Le score est **calculé à la lecture**, jamais stocké : deux ouvertures successives donnent la même valeur tant que rien ne change.

Ligne de journal attendue : `USER_VIEWED` à chaque ouverture. Le calcul du score n'écrit rien.

Verdict : ☐ conforme ☐ non conforme

5.4 Sanctions : proposer, appliquer, lever

ADM-SNC-1 — Proposer une sanction (Support)

Gravité : bloquante. **Préconditions :** session **Support**. Cible : **Pauline Lemaire** (aucune sanction en cours).

Étapes : 1. Ouvrir la fiche de Pauline Lemaire. Repérer la carte « Sanction ». 2. Choisir le niveau « Restreint (ni publier ni réserver) ». 3. Saisir un motif de **moins de 20 caractères** (« trop court »). Observer le bouton. 4. Saisir un motif d'au moins 20 caractères : « Trois signalements convergents pour comportement inapproprié ». 5. Vérifier que le bouton « Appliquer » n'existe pas pour ce profil. 6. Cliquer « Proposer ». 7. Recharger la fiche. 8. Vérifier côté membre (front, compte de Pauline) qu'elle peut toujours réserver.

Résultat attendu : - Étape 3 → le bouton « Proposer » reste **inactif**. La contrainte est de 20 caractères minimum (maximum 2000). - Étape 5 → seul « Proposer » est présent : le Support porte `users.suspension.propose` sans `users.suspension.apply`. - Étape 6 → message « Fait. ». - Étape 7 → un

bandeau ambre apparaît : « Proposition de {admin} le {date} : Restreint — {motif} ». - La tuile d'accueil « Sanctions proposées » passe à **1**. - Étape 8 → **rien n'a changé pour Pauline** : une proposition n'a aucun effet sur le membre.

Ligne de journal attendue :

Action	Cible	Avant	Après
USER_SUSPENSION_PROPOSED	USER · <id de Pauline>	—	{ level: "RESTRICTED", reason: "Trois signalements..." }

Verdict : ☐ conforme ☐ non conforme

ADM-SNC-2 — Appliquer la restriction (Médiateur)

Gravité : **bloquante**.  **deux profils**  **Préconditions** : la proposition d' ADM-SNC-1 existe. Session **Médiateur**.

Étapes : 1. Ouvrir la fiche de Pauline Lemaire. Lire le bandeau ambre de proposition. 2. Saisir un motif d'au moins 20 caractères. 3. Renseigner « Jusqu'au (optionnel) » avec une date **passée**. Cliquer « Appliquer ». 4. Corriger avec une date **future** (dans 7 jours). Cliquer « Appliquer ». 5. Recharger la fiche. 6. Se connecter côté membre (front) avec le compte de Pauline et tenter de publier un trajet, puis de réserver. 7. Lire Mailpit.

Résultat attendu : - Étape 3 → refus **400** « The end date must be in the future. ». - Étape 4 → message « Fait. ». - Étape 5 → le bandeau ambre de proposition a disparu, remplacé par un bandeau rouge « Restreint depuis le {date} par {admin}, jusqu'au {date} — motif : {motif} ». Le badge d'état passe à « Restreint ». - Étape 6 → POST /trips, /trips/:id/publish, /deals et /deals/payment-intents répondent **403** avec le code ACCOUNT_RESTRICTED . **Les deals en cours de Pauline continuent** — elle reste jointe à ses conversations et à ses suivis. - Étape 7 →  un email « Ton compte Yamba est restreint » arrive dans la **langue de Pauline**, avec un motif **générique** (jamais le contenu d'un signalement) et l'adresse de contestation. - La tuile « Sanctions proposées » revient à **0** ; la tuile « Comptes restreints » passe à **1**.

Ligne de journal attendue :

Action	Cible	Avant	Après
USER_RESTRICTED	USER · <id de Pauline>	{ accountStatus: "ACTIVE" }	{ accountStatus: "RESTRICTED", reason: "...", until: "<date>" }

Verdict : ☐ conforme ☐ non conforme

ADM-SNC-3 — Suspendre un compte qui a des deals en cours

Gravité : **bloquante**.   **Préconditions** : session **Médiateur**. Cible : **Thomas Nkounkou** (Voyageur, plusieurs deals en cours).

Étapes : 1. Ouvrir la fiche de Thomas. Noter le nombre de « Deals en cours ». 2. Choisir « Suspendu (connexion refusée) », motif d'au moins 20 caractères, sans date de fin. 3. Cliquer « Appliquer ». 4. Côté membre, tenter de se connecter avec le compte de Thomas. 5. Rechercher un trajet de Thomas depuis le front public. 6. Lire Mailpit.

Résultat attendu : - Étape 3 → « Fait. ». Le badge passe à « Suspendu ». - Étape 4 → la connexion est **refusée** ; une session déjà ouverte reçoit **401** avec le code ACCOUNT_SUSPENDED . Toutes ses sessions membre sont révoquées. - Étape 5 → **les trajets de Thomas sortent de la recherche**. Point capital : cet effet passe par un

filtre de lecture dans le trip-service (`user.accountStatus`), **jamais** par une écriture croisée. Le statut des trajets en base reste `PUBLISHED` . - Étape 6 → ✉ deux emails : au membre « Ton compte Yamba est suspendu » (motif générique), et **au support** « [Yamba ops] SUSPENDED : Thomas Nkounkou a n deal(s) en cours » avec la liste des deals.

Ligne de journal attendue :

Action	Cible	Avant	Après
USER_SUSPENDED	USER · <id de Thomas>	{ accountStatus: "ACTIVE" }	{ accountStatus: "SUSPENDED", reason: "...", until: null }

🔄 **Rejouer le jeu d'essai après ce scénario**, ou enchaîner immédiatement sur `ADM-SNC-4` .

Verdict : ☐ conforme ☐ non conforme

ADM-SNC-4 — Lever une sanction

Gravité : majeure. ✉

Étapes : 1. Session Médiateur, fiche de Thomas (suspendu). Cliquer « Lever » sans motif. 2. Saisir un motif d'au moins 20 caractères, puis « Lever ». 3. Recharger. 4. Retenter « Lever » sur ce compte maintenant actif. 5. Côté membre, se reconnecter et rechercher un trajet de Thomas.

Résultat attendu : - Étape 1 → bouton inactif tant que le motif fait moins de 20 caractères. - Étape 2 → « Fait. ». - Étape 3 → le badge repasse à « Actif », le bandeau rouge disparaît, les champs de sanction sont effacés. - Étape 4 → refus **400** « This account is not restricted. ». - Étape 5 → la connexion fonctionne, les trajets de Thomas réapparaissent dans la recherche. - ✉ Un email « Ton compte Yamba est rétabli » part au membre.

Ligne de journal attendue :

Action	Cible	Avant	Après
USER_REINSTATED	USER · <id de Thomas>	{ accountStatus: "SUSPENDED" }	{ accountStatus: "ACTIVE", reason: "..." }

Verdict : ☐ conforme ☐ non conforme

ADM-SNC-5 — Un Support ne peut pas appliquer, même par appel direct

Gravité : bloquante.

Étapes : session **Support**, console du navigateur :

```
await fetch("/api/admin/users/<id>/suspension", { method: "POST", credentials: "include",
  headers: { "Content-Type": "application/json" },
  body: JSON.stringify({ level: "RESTRICTED", reason: "Contournement de la garde serveur en
recette" }) })
.then(r => r.status)
```

Résultat attendu : **403**. L'état du compte visé est **inchangé** (le vérifier sur sa fiche).

Ligne de journal attendue : **aucune**. Rien ne doit être écrit sur un refus.

Verdict : ☐ conforme ☐ non conforme

5.5 Suppression d'adresse email

ADM-EML-1 — Lever une suppression d'adresse

Gravité : majeure. Préconditions : un membre dont `emailSuppressedAt` est posé. Pour le provoquer en recette : envoyer un email vers une adresse de test qui rebondit dur, ou poser le champ à la main en base. Session **Support, Médiateur, Données personnelles** ou **super administrateur**.

Étapes : 1. Ouvrir la fiche du membre concerné. 2. Lire le bandeau ambre du haut. 3. Cliquer « Lever (adresse corrigée) ». 4. Recharger. 5. Recliquer « Lever (adresse corrigée) » (bouton disparu : refaire l'appel direct).

Résultat attendu : - Étape 2 → bandeau ambre « Adresse sur la liste de suppression depuis le {date} (rebond dur) : aucun email ne lui est envoyé. » (ou « (plainte) »). - Étape 3 → le bandeau disparaît. `emailSuppressedAt` repasse à `null` et les emails repartent vers ce compte. - Étape 5 → refus **400** « This address is not suppressed. ».

Ligne de journal attendue :

Action	Cible	Avant	Après
EMAIL_SUPPRESSION_LIFTED	USER · <id>	{ emailSuppressedAt: "<date>", reason: "..." }	{ emailSuppressedAt: null }

Verdict : ☐ conforme ☐ non conforme

5.6 Exports CSV

ADM-EXP-1 — Export nominatif des membres

Gravité : bloquante. Préconditions : session **super administrateur** ou **Données personnelles**.

Étapes : 1. Ouvrir `/users`. Poser un filtre (par exemple rôle « Voyageur »). 2. Repérer le bouton rouge « Exporter en CSV (données personnelles) ». 3. Cliquer. Lire l'avertissement du panneau. 4. Saisir un motif de **moins de 20 caractères**, cliquer « Télécharger ». 5. Saisir un motif d'au moins 20 caractères. Cliquer « Télécharger ». 6. Ouvrir le fichier téléchargé dans un tableur. 7. Refaire l'étape 1 avec une session **Médiateur**.

Résultat attendu : - Étape 3 → le panneau affiche « Export nominatif : le motif est écrit au journal avec les filtres et le nombre de lignes (RGPD). ». - Étape 4 → refus **400** « A reason of at least 20 characters is required for a personal-data export. ». - Étape 5 → fichier `utilisateurs-<date>.csv`. - Étape 6 → BOM UTF-8 (les accents s'affichent), colonnes `id`, `firstName`, `lastName`, `email`, `phoneE164`, `roles`, `adminRoles`, `accountStatus`, `carrierStatus`, `stripeReady`, `suspendedAt`, `suspensionUntil`, `createdAt`. **Les filtres de la liste sont appliqués** : le fichier ne contient que les Voyageurs. Borne : 5 000 lignes. - Contrôle de sécurité : une cellule commençant par `=`, `+`, `-` ou `@` doit être **neutralisée** (préfixe) pour ne pas s'exécuter comme formule. - Étape 7 → le bouton **n'apparaît pas** pour le Médiateur ; l'appel direct répond **403**.

Ligne de journal attendue :

Action	Cible	Après
EXPORTED	USER (sans identifiant)	{ domain: "users", personal: true, reason: "...", filters: {...}, rows: n }

Verdict : ☐ conforme ☐ non conforme

ADM-EXP-2 — Exports opérationnels : jamais d'email ni de téléphone

Gravité : bloquante. Préconditions : session **Finance**, **Médiateur** ou **super administrateur** (permission `exports.operational`).

Étapes : 1. Depuis `/trips`, cliquer « Exporter en CSV » (aucun motif n'est demandé). 2. Depuis `/tickets`, cliquer « Exporter en CSV ». 3. Depuis `/disputes`, cliquer « Exporter en CSV ». 4. Ouvrir les trois fichiers. 5. Chercher une adresse email ou un numéro de téléphone dans chacun.

Résultat attendu : - Étape 4 → colonnes attendues : - trajets : `id, status, originCity, originCountryCode, destinationCity, destinationCountryCode, departureAt, publishedAt, cancelledAt, carrierId, transportMode, capacityKg, reservedKg, pricePerKgCents, ticketVerificationStatus, hiddenByAdminAt, createdAt` ; - billets : `documentId, tripId, originCity, destinationCity, departureAt, carrierId, originalName, mimeType, status, submittedAt` ; - dossiers : `bookingId, kind, ticketNumber, category, openedAt, originCity, destinationCity, amountCents, currencyCode, shipperId, carrierId, carrierResponded, decidableAt`. - Étape 5 → **aucune** adresse email, **aucun** numéro de téléphone. Seuls des identifiants. Une seule occurrence est une anomalie **bloquante** (RG-ADM-32).

Lignes de journal attendues : trois lignes.

Action	Cible	Après
EXPORTED	TRIP (sans identifiant)	<code>{ domain: "trips", personal: false, filters, rows }</code>
EXPORTED	TRIP (sans identifiant)	<code>{ domain: "tickets", personal: false, filters, rows }</code>
EXPORTED	BOOKING (sans identifiant)	<code>{ domain: "arbitration", personal: false, filters, rows }</code>

Verdict : ☐ conforme ☐ non conforme

ADM-EXP-3 — Le Support n'exporte rien

Gravité : majeure.

Étapes : session **Support**, ouvrir `/users`, `/trips`, `/tickets`, `/disputes`.

Résultat attendu : **aucun** bouton d'export n'apparaît sur ces quatre écrans. Le Support n'a ni `exports.operational` ni `exports.personal`. Les appels directs répondent **403**.

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

5.7 Trajets : liste, fiche et masquage

ADM-TRJ-1 — La liste et ses filtres d'URL

Gravité : majeure.

Étapes : 1. Ouvrir `/trips`. Vérifier le sous-titre « Tous les trajets, filtrables. Masquer retire un trajet de la recherche sans l'annuler. ». 2. Chercher « Brazzaville » dans le champ « ville ou identifiant ». 3. Ouvrir

directement `/trips?status=PUBLISHED`, puis `/trips?hidden=1`, puis `/trips?ticketPending=1`, puis `/trips?hideProposed=1`. 4. Depuis la fiche de Thomas Nkounkou, cliquer « Ouvrir dans Trajets (fiches, masquage) ». 5. Relever les colonnes du tableau. 6. Cliquer « Charger la suite » si le total dépasse la page.

Résultat attendu : - Étape 3 → chacun des quatre paramètres **présélectionne** son filtre à l'ouverture : la case « masqués », la case « billet à vérifier », la case « masquage proposé », le statut du select. - `/trips?ticketPending=1` renvoie **le trajet Paris → Brazzaville à J+10** (le seul billet en attente du jeu d'essai). - Étape 4 → arrivée sur `/trips?carrierId=<id>` avec la pastille « un seul Voyageur · tous » ; le mot « tous » retire le filtre. - Étape 5 → colonnes « Corridor », « Départ », « Voyageur », « Statut », « Billet », « Deals ». Colonne Billet : « aucun billet », « à vérifier », « vérifié » ou « rejeté ». - Compteur : « {n} affiché(s) · {total} au total ».

Ligne de journal attendue : aucune pour la liste.

Verdict : ☐ conforme ☐ non conforme

ADM-TRJ-2 — Ouvrir une fiche trajet

Gravité : majeure.

Étapes : 1. Ouvrir la fiche du trajet Paris → Brazzaville à J+10. 2. Parcourir les cartes « Trajet », « Voyageur », « Documents ({n}) », « Réservations ({n}) », « Actions admin sur ce trajet ». 3. Cliquer les liens « dossier » et « argent » d'une réservation.

Résultat attendu : - En-tête : « Paris → Brazzaville », puis « {date de départ} · PLANE · PUBLISHED ». - Carte « Trajet » : capacité / réservé, créé, publié, annulé, billet. - Carte « Documents » : le billet en attente, avec son statut. - Carte « Réservations » : les cinq réservations du trajet (`bzv-pending`, `bzv-accepted`, `bzv-cancelled`, `bzv-declined`, `bzv-expired`) avec leur statut et leurs montants. - Étape 3 → « argent » ouvre `/deals/<id>`, « dossier » n'existe que pour un deal en litige.

Ligne de journal attendue :

Action	Cible
TRIP_VIEWED	TRIP · <id du trajet>

et, si l'on a cliqué « argent », `DEAL_MONEY_VIEWED` sur `BOOKING · <id>`.

Verdict : ☐ conforme ☐ non conforme

ADM-TRJ-3 — Proposer un masquage (Support)

Gravité : majeure.

Étapes : 1. Session **Support**. Ouvrir la fiche d'un trajet publié. Repérer la carte « Masquage ». 2. Lire le texte d'explication. 3. Saisir un motif de moins de 20 caractères : le bouton reste inactif. 4. Saisir « Annonce suspecte : photos empruntées à un autre profil ». Cliquer « Proposer ». 5. Recharger la fiche, puis ouvrir `/trips?hideProposed=1`. 6. Vérifier côté public que le trajet est **toujours visible**.

Résultat attendu : - Étape 2 → « Retire le trajet de la recherche et de sa page publique, sans l'annuler. Réservations en cours préservées, Voyageur prévenu. ». - Étape 4 → « Fait. ». - Étape 5 → bandeau ambre « Masquage proposé par {admin} le {date} : {motif} », badge ambre « masquage proposé » dans la liste, tuile d'accueil « Masquages proposés » à 1. - Étape 6 → **rien n'a changé pour le Voyageur ni pour le public**. Une proposition n'agit pas. - Le bouton « Masquer » **n'apparaît pas** pour le Support.

Ligne de journal attendue :

Action	Cible	Après
TRIP_HIDE_PROPOSED	TRIP · <id>	{ reason: "Annonce suspecte..." }

Verdict : ☐ conforme ☐ non conforme

ADM-TRJ-4 — Masquer et rétablir (Médiateur)

Gravité : bloquante. ► deux profils ☒

Étapes : 1. Session **Médiateur**. Ouvrir la même fiche trajet. 2. Motif d'au moins 20 caractères. Cliquer « Masquer ». 3. Recliquer « Masquer ». 4. Côté public (front, non connecté) : rechercher le corridor, puis ouvrir l'URL de la page publique du trajet. 5. Côté membre (compte du Voyageur) : ouvrir son trajet dans son espace. 6. Tenter de créer une réservation sur ce trajet par appel direct. 7. Lire Mailpit. 8. Revenir, saisir un motif, cliquer « Rétablir ». 9. Recliquer « Rétablir ».

Résultat attendu : - Étape 2 → « Fait. ». Badge rouge « masqué par Yamba », bandeau rouge « Masqué le {date} par {admin} — motif : {motif} ». La proposition ambre a disparu. - Étape 3 → refus **400** « This trip is already hidden. ». - Étape 4 → le trajet **est absent de la recherche** ; sa page publique répond **404**. - Étape 5 → le Voyageur **garde son trajet** dans son espace, avec un bandeau rouge. Le **statut du trajet est inchangé** (toujours PUBLISHED) : masquer n'est ni une pause ni une annulation, et Yamba n'annule jamais un trajet à la place du Voyageur. - Étape 6 → refus avec le code TRIP_NOT_BOOKABLE. Les réservations **déjà en cours** continuent normalement. - Étape 7 → ☒ email au Voyageur avec un motif **générique** (jamais le motif interne, qui reste au journal), un lien vers son trajet et l'adresse du support. - Étape 8 → le trajet revient dans la recherche et sa page publique répond de nouveau 200. - Étape 9 → refus **400** « This trip is not hidden. ».

Lignes de journal attendues :

Étape	Action	Cible	Après
2	TRIP_HIDDEN	TRIP · <id>	{ reason: "<motif interne>" }
8	TRIP_UNHIDDEN	TRIP · <id>	{ reason: "<motif>" }

Verdict : ☐ conforme ☐ non conforme

ADM-TRJ-5 — Personne ne masque son propre trajet

Gravité : bloquante. **Préconditions :** le compte Médiateur est le Voyageur d'un trajet publié (à poser depuis le front).

Étapes : 1. Session Médiateur, ouvrir la fiche de **son** trajet. 2. Chercher la carte « Masquage ». 3. Appel direct sur la route de masquage.

Résultat attendu : la carte « Masquage » est **absente** de l'écran ; l'appel direct répond **403** « You cannot act on your own trip. ».

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

5.8 Billets à vérifier (/tickets)

ADM-BIL-1 — La file et ses filtres

Gravité : majeure.

Étapes : 1. Ouvrir /tickets . Vérifier le sous-titre « Trajets à venir seulement, les plus anciens d'abord. Ouvrir un billet est journalisé. Compare les dates, les villes et le nom. ». 2. Compter les cartes. 3. Poser les filtres « origine », « destination », puis le select d'âge (« déposé il y a + de 1 j », « + de 3 j », « + de 7 j »). 4. Chercher une éventuelle ligne d'information en haut de la file.

Résultat attendu : - Étape 2 → **une** carte sur le jeu d'essai neuf : corridor « Paris → Brazzaville », départ à J+10, Voyageur Thomas Nkounkou, date de dépôt. - Étape 4 → la mention « {n} billet(s) de trajets partis sortis de la file. » n'apparaît que si la lecture a fait passer des billets en EXPIRED (un billet sur un trajet déjà parti n'a plus rien à prouver). Sur un jeu d'essai neuf, elle est absente. - Les billets des trajets **déjà partis** n'apparaissent jamais dans la file.

Ligne de journal attendue : aucune pour la simple ouverture de la file.

Verdict : ☐ conforme ☐ non conforme

ADM-BIL-2 — Ouvrir un billet est journalisé

Gravité : majeure.

Étapes : 1. Cliquer « Ouvrir le billet ({nom du fichier}) ». 2. Observer le nouvel onglet. 3. Vérifier immédiatement le journal.

Résultat attendu : - Un nouvel onglet s'ouvre sur l'URL ImageKit du document. - **Ce clic est une consultation de donnée personnelle** : il doit laisser une trace, même si aucune décision n'est prise.

Ligne de journal attendue :

Action	Cible	Après
DOCUMENT_VIEWED	TRIP · <id du trajet>	{ documentId: "<id>" }

Verdict : ☐ conforme ☐ non conforme

ADM-BIL-3 — Valider un billet

Gravité : majeure.  

Étapes : 1. Session Support ou Médiateur. Cliquer « Valider » sur le billet en attente. 2. Lire le message. 3. Ouvrir la fiche du trajet. 4. Ouvrir la page publique du trajet, côté visiteur. 5. Recliquer « Valider » (le billet a quitté la file : refaire l'appel direct). 6. Lire Mailpit.

Résultat attendu : - Étape 2 → « Billet vérifié, Voyageur prévenu. ». La carte sort de la file. - Étape 3 → le document passe en « vérifié », le trajet porte ticketVerificationStatus = VERIFIED . - Étape 4 → le badge « Billet vérifié » apparaît sur la page publique. **Rappel : c'est un signal de confiance, pas une barrière.** Aucune publication ni réservation n'est bloquée faute de billet vérifié. - Étape 5 → refus **400** « This ticket was already reviewed. » (verrou status: PENDING de l' updateMany). - Étape 6 →  email « Billet vérifié » au Voyageur, dans sa langue.

Ligne de journal attendue :

Action	Cible	Après
TICKET_VERIFIED	TRIP · <id>	{ documentId: "<id>", reason: null }

 Rejouer le jeu d'essai pour disposer à nouveau d'un billet en attente avant ADM-BIL-4.

Verdict : ☐ conforme ☐ non conforme

ADM-BIL-4 — Rejeter un billet avec un motif fermé

Gravité : majeure. 

Étapes : 1. Ouvrir le select « Rejeter : motif... » et relever toutes les options. 2. Cliquer « Rejeter » **sans** choisir de motif. 3. Choisir « Les dates ne correspondent pas au trajet ». Cliquer « Rejeter ». 4. Lire Mailpit. 5. Côté membre, redéposer un billet sur ce trajet. 6. Rouvrir /tickets.

Résultat attendu : - Étape 1 → quatre options exactement : « Document illisible », « Les dates ne correspondent pas au trajet », « Le nom ne correspond pas au compte », « Document non recevable ». Le motif est **fermé** : aucun texte libre. - Étape 2 → le bouton « Rejeter » est **inactif** tant qu'aucun motif n'est choisi. - Étape 3 → « Billet rejeté, Voyageur prévenu. ». Le document passe REJECTED, le trajet ticketVerificationStatus = REJECTED. - Étape 4 →  email « Billet non validé » au Voyageur, avec le libellé du motif. - Étape 6 → le nouveau dépôt fait **revenir** le trajet dans la file « à vérifier ». Un rejet n'est pas une condamnation définitive.

Ligne de journal attendue :

Action	Cible	Après
TICKET_REJECTED	TRIP · <id>	{ documentId: "<id>", reason: "DATES_MISMATCH" }

Verdict : ☐ conforme ☐ non conforme

5.9 Médiation : la file, le dossier, la décision

ADM-MED-1 — La file « À arbitrer »

Gravité : majeure.

Étapes : 1. Ouvrir /disputes. Vérifier le titre « À arbitrer » et le sous-titre, qui doit citer le **paramètre** : « ... passé le délai de réponse (paramètre « Litige : délai de réponse », 72 h par défaut) ... ». 2. Relever le compteur. 3. Relever les colonnes et les badges de la colonne « Décision ». 4. Poser successivement les filtres : type, origine, destination, âge, décidabilité. 5. Ouvrir /disputes?kind=RETENTION et /disputes?decidable=1.

Résultat attendu : - Étape 2 → « 3 affiché(s) · file entière : 2 litige(s) · 1 retenue(s) ». **Les compteurs de la file entière ne bougent pas** quand on filtre. - Étape 3 → colonnes « Dossier », « Motif », « Corridor », « Parties », « Montant », « Ouvert », « Décision ». Sur le jeu d'essai : - YAM-2041 — motif « Contenu manquant » — Paris → Brazzaville — « Chinwe (Exp.) · Thomas (Voy.) » — ouvert J+1 ; - YAM-2042 — motif « Contenu manquant » — Londres → Lagos — « Mai (Exp.) · Adebayo (Voy.) » ; - une ligne « Retenue » — motif « Annulation après le départ ». - Colonne « Décision » : « à trancher » pour la retenue, « attend le Voyageur · {n} h » pour un litige récent, « sans réponse · à trancher » passé le délai. - L'ancienneté « J+n » passe en **rouge à partir de J+5**. - Étape 5 → les deux paramètres d'URL **présélectionnent** leur filtre.

Ligne de journal attendue : aucune pour la file.

Verdict : ☐ conforme ☐ non conforme

ADM-MED-2 — Ouvrir un dossier de médiation

Gravité : bloquante.

Étapes : 1. Ouvrir le dossier `YAM-2041`. 2. Lire le bandeau de décidabilité. 3. Parcourir **tous** les blocs. 4. Chercher activement le **code de livraison** dans la page (Ctrl+F sur `742891`). 5. Chercher le lien vers la conversation.

Résultat attendu : - En-tête : le numéro de ticket, « Paris → Brazzaville · DISPUTED », lien « ← À arbitrer ». - Étape 2 → « Version du Voyageur attendue jusqu'au {date} — décision possible dès sa réponse ou à l'échéance. » (le jeu d'essai ne pose **aucune version du Voyageur**). - Étape 3 → blocs attendus : « Chronologie », « Argent », « Expéditeur », « Voyageur », « Colis déclaré », « Prise en charge · {date} », « Jalons du voyage », « Remise », « Signalement {ticket} · {catégorie} », « Trancher ». - Le bloc « Signalement » porte la description, la solution souhaitée (« Remboursement partiel »), l'engagement sur l'honneur et les photos. - Étape 4 → **le code de livraison n'apparaît nulle part**. Une occurrence est une anomalie **bloquante**. - Étape 5 → le lien « Lire la conversation des deux parties → », suivi de « Lecture journalisée. », n'apparaît **que** pour un profil portant `conversations.read` (Médiateur, Support, super administrateur). Il est absent pour la Finance.

Ligne de journal attendue :

Action	Cible	Après
<code>DISPUTE_VIEWED</code>	<code>BOOKING · <id du deal></code>	<code>{ kind, ticketNumber }</code>

Verdict : ☐ conforme ☐ non conforme

ADM-MED-3 — Les gardes du formulaire de décision

Gravité : bloquante.

Étapes : 1. Session **Support**, ouvrir `YAM-2041`, chercher le formulaire. 2. Session **Médiateur**, ouvrir `YAM-2042` (ouvert il y a 8 heures, donc avant l'échéance). 3. Session Médiateur, ouvrir `YAM-2041` (ouvert il y a plus de 24 heures) — si le délai n'est pas écoulé, abaisser temporairement `dispute.responseDelayHours` à 1 heure depuis `/settings` (super administrateur). 4. Choisir « Remboursement partiel » et saisir un montant de **0** puis un montant **égal au total**. 5. Saisir un motif de moins de 50 caractères. 6. Appel direct de la décision par un profil **Finance**.

Résultat attendu : - Étape 1 → à la place du formulaire : « Ton profil lit ce dossier mais ne tranche pas (médiateur ou super administrateur). ». - Étape 2 → « Décision possible à partir du {date} (délai de réponse laissé au Voyageur), ou dès sa réponse. ». L'appel direct répond **409** en portant la date `decidableAt`. - Étape 4 → refus : le montant partiel doit être **compris entre 0,01 et total – 0,01**. L'écran affiche « entre 0,01 et {total – 1 centime} ». - Étape 5 → le bouton « Voir le récapitulatif » reste **inactif**. Le compteur affiche « {n} / 50 min ». - Étape 6 → **403**.

Ligne de journal attendue : aucune — aucun de ces cas ne produit de décision.

Verdict : ☐ conforme ☐ non conforme

ADM-MED-4 — Trancher un litige : rejet

Gravité : bloquante.  **Préconditions :** session **Médiateur**, dossier `YAM-2041` décidable (délai écoulé, ou paramètre abaissé).

Étapes : 1. Ouvrir le dossier. Noter les montants du bloc « Argent » : payé par l'Expéditeur (total), net Voyageur, commission, prime. 2. Choisir « Rejet : le Voyageur est payé en entier ». Lire l'indice affiché. 3. Saisir un motif d'au moins 50 caractères. 4. Cliquer « Voir le récapitulatif ». 5. Vérifier les trois lignes du récapitulatif. 6. Cliquer « Valider définitivement ». 7. Lire le message de succès. 8. Ouvrir la fiche argent du deal. 9. Ouvrir les fiches de Chinwe Eze et de Thomas Nkounkou. 10. Retenter la décision sur le même dossier. 11. Lire Mailpit.

Résultat attendu : - Étape 2 → indice « Voyageur : {net} · Yamba garde {total – net} ». - Étape 5 → « Remboursé à l'Expéditeur (Chinwe) : 0,00 € », « Versé au Voyageur (Thomas) : {net} », « Conservé par Yamba : {commission + prime} », puis « Issue : Rejet... Motif : « ... » ». - Étape 7 → « Décision enregistrée », puis « {issue} · deal COMPLETED · remboursé 0,00 € · versé {net} ({statut du versement}) », et « Les deux parties sont prévenues (écran, notification, email). ». - Étape 8 → le deal passe **COMPLETED**, fermé par **ADMIN** ; le versement part (ou est rejoué par le cron s'il échoue — **un échec de versement ne bloque jamais une décision**). - Étape 9 → le compteur « Litiges perdus (interne) » de **Chinwe** (l'Expéditeur, condamné par un rejet) est incrémenté de 1. - Étape 10 → refus **409** : une décision est unique. - Étape 11 →  deux emails « Décision rendue », un par partie, chacun portant l'issue, **le montant qui le concerne** et le motif intégral. - Contrôle complémentaire : le deal clos par médiation **ne se note pas** (rating: null) — aucune invitation à noter ne part.

Ligne de journal attendue :

Action	Cible	Avant	Après
DISPUTE_RESOLVED	BOOKING · <id>	{ status: "DISPUTED", ticketNumber: "YAM-2041" }	{ finalStatus: "COMPLETED", outcome: "REJECT", refundCents: 0, carrierPayoutCents: <net> }

Un événement d'outbox `booking.dispute_resolved` est écrit **dans la même transaction** : le vérifier via « Charger la chronologie » sur la fiche argent.

 Rejouer le jeu d'essai avant `ADM-MED-5`.

Verdict : ☐ conforme ☐ non conforme

ADM-MED-5 — Trancher un litige : remboursement partiel

Gravité : bloquante. 

Étapes : 1. Dossier `YAM-2042` décidable. Noter le total payé par l'Expéditeur et le net Voyageur. 2. Choisir « Remboursement partiel ». Saisir un montant **inférieur au net Voyageur** (par exemple la moitié du total). 3. Motif d'au moins 50 caractères. « Voir le récapitulatif ». 4. Vérifier l'arithmétique du récapitulatif. 5. « Valider définitivement ». 6. Ouvrir la fiche argent, puis la fiche du Voyageur. 7. Côté membre (Expéditeur), ouvrir le portefeuille.

Résultat attendu : - Étape 4 → « Remboursé à l'Expéditeur : {montant saisi} », « Versé au Voyageur : max(0, net – montant) », « Conservé par Yamba : le reste ». Les trois lignes doivent totaliser **exactement** le montant payé par l'Expéditeur. - Étape 5 → deal **COMPLETED**. - Étape 6 → le compteur « Litiges perdus (interne) » du **Voyageur** est incrémenté : dès qu'il y a un remboursement, c'est le Voyageur qui est condamné. - Étape 7 →

l'Expéditeur voit le remboursement dans son portefeuille : part gardée « dépensée », part rendue « remboursée ».

- **L'ordre du serveur est remboursement puis versement.**

Ligne de journal attendue :

Action	Cible	Après
DISPUTE_RESOLVED	BOOKING · <id>	{ finalStatus: "COMPLETED", outcome: "PARTIAL_REFUND", refundCents: <montant>, carrierPayoutCents: <net - montant> }

 Rejouer le jeu d'essai.

Verdict : ☐ conforme ☐ non conforme

ADM-MED-6 — Trancher un litige : remboursement total

Gravité : bloquante. 

Étapes : 1. Dossier décidable. Choisir « Remboursement total : le Voyageur ne reçoit rien ». Lire l'indice. 2. Motif ≥ 50 caractères. Récapitulatif. Valider. 3. Ouvrir la fiche argent.

Résultat attendu : - Étape 1 → indice « Expéditeur : {total} (commission comprise) · Voyageur : 0 ». **La commission Yamba est rendue elle aussi.** - Étape 3 → le deal passe **CANCELLED**, fermé par ADMIN. Le Voyageur ne reçoit rien.

Ligne de journal attendue : DISPUTE_RESOLVED sur BOOKING · <id>, after: { finalStatus: "CANCELLED", outcome: "FULL_REFUND", refundCents: <total>, carrierPayoutCents: 0 }.

 Rejouer le jeu d'essai.

Verdict : ☐ conforme ☐ non conforme

5.10 Retenue d'annulation tardive

ADM-RET-1 — Arbitrer une retenue : compensation au Voyageur

Gravité : bloquante.  **Préconditions :** la retenue du jeu d'essai (deal `bzv-held`, Expéditeur Aminata Diallo). Session **Médiateur**.

Étapes : 1. Ouvrir `/disputes`, filtrer sur « retenues », ouvrir la ligne. 2. Vérifier l'en-tête : « Retenue à arbitrer ». 3. Lire le bloc « Argent » : montant retenu, remboursement déjà effectué, disposition. 4. Choisir « Compensation au Voyageur (prorata) ». Lire l'indice. 5. Motif ≥ 50 caractères. Récapitulatif. Valider. 6. Ouvrir la fiche argent du deal.

Résultat attendu : - Étape 3 → le deal est **CANCELLED**, remboursé à 50 %, retenue conservée avec la disposition `HELD_FOR_MEDIATION`. - Étape 4 → l'indice affiche « Voyageur : {montant} (prorata de sa part nette) ». **Le montant est calculé par le serveur**, pas saisi. - Étape 5 → validation. - Étape 6 → **le statut du deal ne change pas** (il reste CANCELLED) ; seule `retentionDisposition` passe à `CARRIER`. La différence entre la retenue et la compensation reste chez Yamba. - La ligne disparaît des files « À arbitrer » et « Retenues à arbitrer ».

Ligne de journal attendue :

Action	Cible	Avant	Après
RETENTION_ARBITRATED	BOOKING · <id>	{ retentionDisposition: "HELD_FOR_MEDIATION", retentionCents: <n> }	{ outcome: "CARRIER_COMPENSATION", refundCents: 0, carrierPayoutCents: <prorata> }

 Rejouer le jeu d'essai.

Verdict : ☐ conforme ☐ non conforme

ADM-RET-2 — Arbitrer une retenue : restitution à l'Expéditeur

Gravité : majeure. 

Étapes : 1. Même dossier, choisir « Restitution de la retenue à l'Expéditeur ». Lire l'indice. 2. Motif ≥ 50 caractères. Récapitulatif. Valider. 3. Vérifier côté membre (portefeuille d'Aminata).

Résultat attendu : - Étape 1 → « Expéditeur : {montant} remboursés » — la **retenue entière**, pas un prorata. Le Voyageur reçoit zéro. - Étape 3 → l'Expéditeur voit le complément de remboursement. - `retentionDisposition` passe à `SHIPPER`.

Ligne de journal attendue : `RETENTION_ARBITRATED` sur `BOOKING · <id>`, `after: { outcome: "SHIPPER_RESTITUTION", refundCents: <retenue>, carrierPayoutCents: 0 }`.

 Rejouer le jeu d'essai.

Verdict : ☐ conforme ☐ non conforme

5.11 Finances : les files d'exception (/finances)

ADM-FIN-1 — Les quatre onglets et leur contenu

Gravité : majeure. Préconditions : session **Finance**, **Médiateur** ou **super administrateur**.

Étapes : 1. Ouvrir `/finances`. Vérifier le sous-titre. 2. Parcourir les quatre onglets et relever l'indice affiché sous chacun. 3. Ouvrir directement `/finances?kind=REVERSED`, `?kind=HELD`, `?kind=PROPOSED_REFUNDS`, `?kind=NIMPORTEQUOI`. 4. Relever le contenu de chaque onglet sur le jeu d'essai. 5. Lire le pied de page.

Résultat attendu :

Onglet	Indice attendu	Contenu sur le jeu d'essai
Versements en échec	« Le cron rejoue seul (5 min, puis 30 min, 2 h, 1 jour). « Relancer » n'attend pas l'échéance. »	1 ligne : deal Paris → Brazzaville, motif « compte Stripe du Voyageur non prêt », « 4 tentative(s) · prochaine {date} », badge « Stripe non prêt »
Transferts renversés	« Stripe a renvoyé l'argent à la plateforme. Rien ne repart sans décision : re-verser ou abandonner, avec motif. »	1 ligne , état « transfert renversé par Stripe »
Retenues à arbitrer	« Annulation après le départ sans prise en charge : la retenue attend la médiation. »	1 ligne , état « retenue conservée »

Onglet	Indice attendu	Contenu sur le jeu d'essai
Remboursements proposés	« Gestes commerciaux proposés par Finance ou Support : seul un super administrateur applique, avec le motif. »	vide : « Rien à traiter. »

- Étape 3 → chaque valeur d'URL sélectionne son onglet ; une valeur inconnue retombe sur « Versements en échec ».
- Colonnes : « Deal », « Parties », « Montant », « État », « Depuis », puis l'action.
- Boutons d'action : « Relancer » (FAILED), « Décider » (REVERSED et PROPOSED_REFUNDS, vers /deals/<id>), « Arbitrer » (HELD, vers /disputes/<id>).
- Pied : « {n} ligne(s) · calculé le {date}. ».
- Le lien « Rapport mensuel et export → » est présent en haut à droite.
- Le message brut du fournisseur s'affiche en police à chasse fixe : il est réservé à l'admin.** Le Voyageur, lui, ne lit que « compte à finaliser » ou « en cours ».

Ligne de journal attendue : aucune pour la lecture des files.

Verdict : ☐ conforme ☐ non conforme

ADM-FIN-2 — Le Support ne voit pas les finances

Gravité : bloquante.

Étapes : session **Support** : relever le menu, puis ouvrir /finances par l'URL, puis appeler /api/admin/finances directement.

Résultat attendu : l'entrée « Finances » est **absente** du menu ; les tuiles d'accueil « Versements en échec », « Transferts renversés » et « Remboursements proposés » sont **absentes** ; l'appel direct répond **403**.

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

5.12 Fiche argent d'un deal (/deals/[id])

ADM-ARG-1 — Ce que montre la fiche argent

Gravité : majeure. **Préconditions** : session **Finance** ou **super administrateur**.

Étapes : 1. Depuis /finances, ouvrir la fiche argent du deal en échec de versement. 2. Parcourir toutes les cartes. 3. Comparer les montants avec le prix figé à la réservation. 4. Chercher le code de livraison dans la page. 5. Vérifier le format des identifiants Stripe.

Résultat attendu : - Cartes attendues, dans l'ordre : « Prix figé à la réservation », « Parties », « Paiement de l'Expéditeur », « Versement au Voyageur », « Remboursement manuel (geste commercial) », « Chronologie de l'argent », « Rapprochement avec le fournisseur », « Dates », « Tout ce qui est arrivé à ce deal », « Actions admin sur ce deal ». - Carte « Prix figé » : payé par l'Expéditeur, net Voyageur, commission Yamba, prime protection, modèle de prix. **Ces montants sont immuables** : ils ne sont jamais recalculés depuis le trajet. - Carte « Versement au Voyageur » : état « en échec », montant, motif « compte Stripe du Voyageur non prêt », détail brut du fournisseur, « 4 tentative(s) », prochaine relance. - Carte « Parties » : le compte Stripe du Voyageur avec la mention « virements activés » ou « virements NON activés ». - Étape 4 → **aucune trace du code de livraison**. Anomalie bloquante s'il apparaît. - Étape 5 → sur la **fiche argent**, intentId et chargeId sont **en clair** (c'est

nécessaire au rapprochement comptable) ; sur les autres fiches (membre, trajet), le compte Stripe est **masqué** (acct_...xxxx).

Ligne de journal attendue :

Action	Cible
DEAL_MONEY_VIEWED	BOOKING · <id du deal>

Verdict : ☐ conforme ☐ non conforme

ADM-ARG-2 — La chronologie complète du deal

Gravité : majeure. Préconditions : profil portant `deals.history.read` (Médiateur, Support, Finance, super administrateur).

Étapes : 1. Sur une fiche argent, descendre à la carte « Tout ce qui est arrivé à ce deal ». 2. Lire le texte d'avertissement. 3. Cliquer « Charger la chronologie ». 4. Relever les compteurs et les étiquettes de source. 5. Chercher, dans la chronologie, une photo, une adresse, un code de livraison.

Résultat attendu : - Étape 2 → « Événements (avec leur état de relais), actions admin, notifications et emails, dans l'ordre. Lecture seule, consultation journalisée. Jamais le code de livraison. ». - Étape 4 → « {n} événement(s) · {n} action(s) admin · {n} notification(s) · {n} email(s) », les étiquettes « événement », « admin », « notification », « email », et un badge rouge « {n} parqué(s) — relais à réparer » s'il existe un événement parqué. - Étape 5 → **rien** : les charges utiles sont en liste blanche. Ni photo, ni adresse, ni code. - L'état de relais de chaque événement s'affiche : publié / en attente / **parqué** (en rouge), avec le nombre d'essais et la dernière erreur.

Ligne de journal attendue :

Action	Cible
DEAL_HISTORY_VIEWED	BOOKING · <id>

Verdict : ☐ conforme ☐ non conforme

5.13 Rapprochement avec le fournisseur de paiement

ADM-RAP-1 — Rapprocher un deal avec le fournisseur Fake (local)

Gravité : majeure.

Étapes : 1. Sur une fiche argent, descendre à « Rapprochement avec le fournisseur ». Lire le texte. 2. Cliquer « Rapprocher maintenant ». 3. Lire le résultat. 4. Recharger la fiche et comparer les montants **avant / après**. 5. Sur un deal sans paiement (par exemple un deal `PENDING`), chercher le bouton.

Résultat attendu : - Étape 1 → « Lecture seule chez Stripe : l'état réel du paiement, des remboursements et du transfert, comparé à la base. Journalisé. Rien n'est modifié. ». - Étape 3 → en local, le fournisseur est **Fake** et les intents seedés (`pi_fake_seed_*`) n'existent pas chez lui : la divergence attendue est « **Paiement introuvable chez le fournisseur** » (`INTENT_NOT_FOUND`). **Ce n'est pas une anomalie** : c'est le comportement attendu sur un jeu d'essai. - Étape 4 → **absolument rien n'a changé en base**. Le rapprochement compare, il ne corrige pas. Toute correction est un geste humain journalisé. - Étape 5 → « Aucun paiement à rapprocher. » ; l'appel direct répond **400** « This deal has no payment to reconcile. ».

Ligne de journal attendue :

Action	Cible	Après
DEAL_RECONCILED	BOOKING · <id>	{ provider: "FAKE", divergences: ["INTENT_NOT_FOUND"] }

Verdict : ☐ conforme ☐ non conforme

ADM-RAP-2 — Détecter un remboursement parti sans écriture »»

Gravité : bloquante. »»

Objet : vérifier que le rapprochement remonte bien REFUND_NOT_RECORDED — un remboursement effectué chez Stripe et absent de la base — ainsi que TRANSFER_REVERSED_NOT_MARKED et TRANSFER_AMOUNT_MISMATCH.

»» **Non jouable en recette locale.** Il faut un compte **Stripe réel** (mode test au minimum) avec un PaymentIntent réellement capturé, puis un remboursement provoqué **depuis le tableau de bord Stripe** sans passer par Yamba. L'environnement de recette utilise le fournisseur Fake, qui ne connaît pas les intents seedés.

Substitut acceptable : faire vérifier par le développement, dans les tests unitaires du deal-service, la couverture des neuf codes de divergence : CAPTURE_NOT_RECORDED, CAPTURE_RECORDED_NOT_LIVE, REFUND_NOT_RECORDED, REFUND_RECORDED_NOT_LIVE, TRANSFER_MISSING, TRANSFER_AMOUNT_MISMATCH, TRANSFER_REVERSED_NOT_MARKED, TRANSFER_MARKED_REVERSED_BUT_LIVE_OK, INTENT_NOT_FOUND.

Verdict : ☐ »» non applicable ☐ conforme (si un environnement Stripe est disponible)

5.14 Versements : rejeu et renversement

ADM-VER-1 — Relancer un versement en échec

Gravité : bloquante. Préconditions : session **Finance** ou **Médiateur** (permission payouts.retry). Le versement en échec du jeu d'essai est **immédiatement rejouable** (prochaine relance datée d'hier).

Étapes : 1. Depuis /finances?kind=FAILED, cliquer « Relancer » sur la ligne. 2. Lire le message. 3. Recharger et relever le compteur de tentatives. 4. Cliquer « Relancer » **deux fois de suite très rapidement**. 5. Ouvrir la fiche argent et vérifier le montant et l'identifiant du transfert. 6. Depuis un deal ACCEPTED (non terminé), tenter la relance par appel direct.

Résultat attendu : - Étape 2 → soit « Versement envoyé. » (état SENT), soit « Toujours en échec : {motif}. » avec le compteur et la prochaine relance. En local avec le fournisseur Fake, l'un ou l'autre est acceptable selon la configuration : les deux sont des résultats valides. - Étape 4 → **le double clic ne verse jamais deux fois**. C'est **le même versement** : même montant figé, même clé d'idempotence chez le fournisseur. - Étape 6 → refus **400** « Only a completed or late-cancelled deal has a payout. ». Sur un deal dont le versement n'est ni FAILED ni PENDING : **400** « Nothing to retry... ». - Un admin **partie** au deal reçoit **403** et voit le bouton inerte (allowedActions à false).

Ligne de journal attendue : une ligne **par clic**, y compris quand la relance échoue.

Action	Cible	Après
PAYOUT_RETRIED	BOOKING · <id>	{ outcome: "SENT" \ "FAILED", reason: "...", transferId: "..." }

Verdict : ☐ conforme ☐ non conforme

ADM-VER-2 — Clore un renversement : re-verser

Gravité : bloquante.  **Préconditions :** session **Finance** ou **Médiateur** (permission `payouts.resolve`). Le deal `bzv-reversed` du jeu d'essai.

Étapes : 1. Depuis `/finances?kind=REVERSED`, cliquer « Décider » pour ouvrir la fiche argent. 2. Lire le texte du sous-formulaire de renversement. 3. Saisir un motif de moins de 20 caractères : les boutons restent inactifs. 4. Saisir « RIB corrigé par le Voyageur, transfert à relancer ». Cliquer « Re-verser ». 5. Lire le message. 6. Recliquer « Re-verser ».

Résultat attendu : - Étape 2 → « Transfert renversé par Stripe : l'argent est revenu à la plateforme. Décide, avec un motif (20 caractères au moins). ». - Étape 5 → « Nouveau transfert envoyé. » ou « Re-versement en échec : {motif} — il sera rejoué. ». Point capital : le re-versement utilise une **nouvelle clé d'idempotence** (ce n'est pas le même versement qu' ADM-VER-1), avec le **même exécuteur** de versement. - La carte « Versement au Voyageur » affiche « Renversement clos : re-versé, par {admin}, motif ». - La ligne disparaît de la file « Transferts renversés ». - Étape 6 → refus **400** « This payout is not an open reversal. ».

Ligne de journal attendue :

Action	Cible	Après
<code>PAYOUT_REVERSAL_RESOLVED</code>	<code>BOOKING · <id></code>	<code>{ outcome: "RESENT", reason: "RIB corrigé..." }</code>

 Rejouer le jeu d'essai avant `ADM-VER-3`.

Verdict : ☐ conforme ☐ non conforme

ADM-VER-3 — Clore un renversement : abandonner

Gravité : majeure. 

Étapes : 1. Même fiche, saisir « Compte du Voyageur fermé, manque à gagner assumé ». Cliquer « Abandonner ». 2. Vérifier la carte « Versement au Voyageur » et la file.

Résultat attendu : - « Renversement abandonné, clos. ». La clôture est `WRITTEN_OFF` : le manque à gagner est **assumé et tracé**, pas caché. - La ligne quitte la file « Transferts renversés ».

Ligne de journal attendue : `PAYOUT_REVERSAL_RESOLVED` sur `BOOKING · <id>`, `after: { outcome: "WRITTEN_OFF", reason: "..." }`.

 Rejouer le jeu d'essai.

Verdict : ☐ conforme ☐ non conforme

5.15 Remboursement manuel en deux gestes

ADM-REM-1 — Proposer un remboursement manuel

Gravité : bloquante. **Préconditions :** session **Finance** ou **Support** (permission `refunds.manual.propose`). Un deal **COMPLETED** ou **CANCELLED** dont l'argent a été débité (par exemple `bzv-completed`).

Étapes : 1. Ouvrir la fiche argent du deal. Descendre à « Remboursement manuel (geste commercial) ». Lire le texte. 2. Relever le plafond annoncé. 3. Saisir un montant **supérieur au plafond**. Cliquer « Proposer ». 4. Saisir un montant valide (par exemple 5,00 €) et un motif de **moins de 50 caractères**. 5. Saisir un motif d'au moins 50 caractères. Cliquer « Proposer ». 6. Recharger la fiche. 7. Ouvrir `/finances?kind=PROPOSED_REFUNDS` et `/home`. 8. Chercher le bouton « Rembourser maintenant » avec ce profil.

Résultat attendu : - Étape 1 → « Hors litige, sur un deal fermé et débité. Le Voyageur n'est pas touché : c'est Yamba qui rend l'argent. Plafond : {montant} (payé – déjà remboursé). Motif de 50 caractères au moins. Un super administrateur applique. ». - Étape 3 → refus **400** « At most n cents can still be refunded... ». - Étape 4 → bouton inactif tant que le motif fait moins de 50 caractères. - Étape 5 → « Remboursement proposé, en attente d'un super administrateur. ». - Étape 6 → bandeau « Proposé : {montant} par {admin} le {date} — {motif} ». - Étape 7 → la file « Remboursements proposés » compte **1** ; la tuile d'accueil du même nom aussi. - Étape 8 → le bouton « Rembourser maintenant » **n'existe pas** pour Finance ni pour Support : `refunds.manual.apply` est réservé au super administrateur.

Ligne de journal attendue :

Action	Cible	Après
REFUND_MANUAL_PROPOSED	BOOKING · <id>	{ amountCents: 500, reason: "..." }

Verdict : ☐ conforme ☐ non conforme

ADM-REM-2 — Appliquer un remboursement manuel (super administrateur seul)

Gravité : bloquante.  **deux profils**  **Préconditions :** la proposition d' ADM-REM-1 . Session **super administrateur**.

Étapes : 1. Ouvrir la même fiche argent. Lire le bandeau de proposition. 2. Saisir le montant et un motif d'au moins 50 caractères. Cliquer « Rembourser maintenant ». 3. Lire le message. 4. Recharger : vérifier la carte « Paiement de l'Expéditeur » (remboursé, `refundId`) et la carte « Versement au Voyageur ». 5. Vérifier le portefeuille de l'Expéditeur côté membre. 6. Lire Mailpit. 7. Cliquer « Charger la chronologie ».

Résultat attendu : - Étape 3 → « Remboursé {montant} (cumul {montant}). L'Expéditeur est prévenu par email. ». - Étape 4 → le remboursement est enregistré avec son `refundId`, le cumul est mis à jour, la proposition a disparu. **Le versement du Voyageur n'est pas touché** : c'est Yamba qui porte le geste commercial. - Étape 5 → le portefeuille de l'Expéditeur affiche « partiellement remboursé ». - Étape 6 →  email standard « Remboursement émis » à l'Expéditeur. - Étape 7 → un événement `booking.refund_issued` d'acteur **ADMIN** apparaît dans la chronologie. - **Ordre du serveur : l'argent d'abord** (`provider.refund`), puis **une** transaction conditionnelle sur le cumul. Si le fournisseur refuse, la réponse est **400** « The refund could not be issued by the payment provider. » et **rien** n'est écrit en base.

Ligne de journal attendue :

Action	Cible	Après
REFUND_MANUAL_APPLIED	BOOKING · <id>	{ amountCents, totalRefundedCents, refundId, reason }

 Rejouer le jeu d'essai.

Verdict : ☐ conforme ☐ non conforme

ADM-REM-3 — Un profil Finance ne peut pas appliquer, même par appel direct

Gravité : bloquante.

Étapes : session Finance, appel direct sur la route d'application du remboursement manuel.

Résultat attendu : 403. Aucun mouvement chez le fournisseur, aucun changement en base.

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

5.16 Rapport mensuel et export finances (/finances/report)

ADM-RPT-1 — Le rapport et ses passifs

Gravité : majeure. Préconditions : session **Finance** ou **super administrateur**.

Étapes : 1. Depuis /finances , cliquer « Rapport mensuel et export → ». 2. Vérifier le titre « Rapport mensuel » et le sous-titre. 3. Lire la section « Aujourd'hui (passifs, jamais un revenu) ». 4. Lire la section « Par mois ». Changer le sélecteur de période (3 / 6 / 12 / 24 mois). 5. Lire le pied de la section.

Résultat attendu : - Étape 3 → cinq tuiles : « Dû aux Voyageurs » (indice « PENDING + FAILED »), « Gelé par un litige », « Renversé, à décider », « Retenues à arbitrer », « Remboursements proposés ». Sur le jeu d'essai neuf, aucune n'est nulle. - **Ces cinq montants sont des passifs, jamais un revenu.** Une tuile étiquetée « revenu » ici serait une anomalie majeure. - Étape 4 → colonnes « Mois », « Devise », « Encaissé », « Remboursé », « Versé », « Revenu (commission + prime) », « Retenues nées », « Deals terminés / annulés ». - Étape 5 → « Du {date} au {date} · calculé le {date}. Un deal capturé en mars et terminé en avril compte dans les deux mois, chaque fait à sa date. ». C'est la règle de datation à vérifier : chaque fait compte à **sa propre date**, mois **UTC**. - Les frais Stripe ne figurent nulle part : ils ne sont pas en base.

Ligne de journal attendue : aucune pour la lecture du rapport.

Verdict : ☐ conforme ☐ non conforme

ADM-RPT-2 — L'export CSV finances

Gravité : bloquante. Préconditions : permission `finances.export` — **Finance et super administrateur seulement.**

Étapes : 1. Descendre à « Export CSV par deal (journalisé) ». Lire le texte. 2. Saisir une période de plus de 366 jours. Cliquer « Télécharger le CSV ». 3. Saisir une période valide (le mois courant). Télécharger. 4. Ouvrir le fichier. 5. Vérifier l'en-tête de réponse `X-Row-Count` . 6. Ouvrir la même page avec une session **Médiateur**.

Résultat attendu : - Étape 2 → refus **400** « The period cannot exceed 366 days. ». Une période invalide (fin avant début) → 400 également. - Étape 3 → fichier `yamba-finances-<du>-<au>.csv` . - Étape 4 → une ligne **par deal ayant un fait d'argent dans la période**, avec au minimum : `dealId`, `status`, `originCity`, `destinationCity`, `departureAt`, `shipperId`, `carrierId`, `currency`, `totalShipperCents`, `transportCents`, `commissionCents`, `premiumCents`, `capturedAt`, `refundAmountCents`, `refundedAt`, `refundId`, `payoutStatus`, `payoutAmountCents`, `payoutSentAt`, `transferId`, `retentionCents`, `retentionDisposition`, `completedAt`, `completedBy`, `closedAt`, `closedBy`, `disputeTicket`, `paymentIntentId`, `chargeId` . - Étape 5 → l'en-tête `X-`

Row-Count porte le nombre de lignes. - Étape 6 → le **Médiateur ne voit pas le bloc d'export** (il a `finances.read` mais pas `finances.export`) ; l'appel direct répond **403**.

Ligne de journal attendue :

Action	Cible	Après
FINANCE_EXPORTED	BOOKING (sans identifiant)	{ from, to, rows, filename }

Verdict : ☐ conforme ☐ non conforme

ADM-RPT-3 — Le revenu reconnu suit sa règle

Gravité : majeure.

Étapes : 1. Relever, pour le mois courant, la valeur de la colonne « Revenu (commission + prime) ». 2. Depuis `/deals/<id>` d'un deal **COMPLETED**, relever commission et prime. 3. Trancher un litige en **remboursement total** (`ADM-MED-6`), puis recharger le rapport.

Résultat attendu : - Le revenu reconnu est **la somme des commissions et des primes des deals terminés** du mois, et rien d'autre. - Une retenue conservée, un versement dû, un transfert renversé et un remboursement proposé n'y figurent **jamais** : ce sont des passifs. - Étape 3 → un remboursement total rend la commission : le deal passe `CANCELLED` et ne contribue plus au revenu reconnu.

Ligne de journal attendue : aucune pour la lecture.

Verdict : ☐ conforme ☐ non conforme

5.17 Pilotage et drilldown (`/pilotage`)

ADM-PIL-1 — Les courbes d'activité

Gravité : majeure. **Préconditions :** session **Finance**, **Médiateur** ou **super administrateur** (`pilotage.read`).

Étapes : 1. Ouvrir `/pilotage`. Relever les trois tuiles de tête. 2. Onglet « Activité » : relever les huit courbes et leurs indices. 3. Basculer le sélecteur « par » entre « semaine » et « mois ». 4. Basculer le sélecteur « sur » (1 / 3 / 6 / 12 / 24 mois). 5. Survoler une courbe. 6. Lire la mention de calcul en haut à droite.

Résultat attendu : - Étape 1 → « Comptes », « Voyageurs prêts (Stripe) », « Trajets publiés à venir ». - Étape 2 → huit courbes exactement : « Inscriptions » (comptes créés), « Trajets publiés » (date de publication), « Demandes » (réservations demandées), « Acceptations » (acceptées par le Voyageur), « Livraisons » (code de livraison validé), « Deals terminés » (fin de transaction), « Annulations » (deals annulés), « Litiges » (litiges ouverts). - Étape 3 → « semaine » bascule la période à 3 mois, « mois » à 12 mois. Les semaines commencent le **lundi**, en **UTC**. - Les libellés de période sont lisibles (« 29 juin → 5 juil. 2026 », « Juillet 2026 »), le code ISO restant en rappel discret dans le tableau. - Étape 5 → un repère et la valeur s'affichent ; le dernier point est étiqueté. - Étape 6 → « calculé le {date} », suivi de « (cache) » quand la réponse vient du cache Redis de 60 secondes.

Ligne de journal attendue : aucune pour les courbes.

Verdict : ☐ conforme ☐ non conforme

ADM-PIL-2 — Les courbes de finances

Gravité : majeure.

Étapes : 1. Onglet « Finances ». Relever les cinq courbes. 2. Utiliser le sélecteur de devise s'il apparaît. 3. Comparer le total de la courbe « Revenu reconnu » avec le rapport mensuel.

Résultat attendu : - Cinq courbes : « Encaissé » (débits), « Remboursé » (aux Expéditeurs, toutes causes), « Versé aux Voyageurs » (transferts partis), « Revenu reconnu » (commission + prime des deals terminés), « Retenues nées » (annulations tardives). - Le sélecteur de devise n'apparaît que s'il y a **plus d'une** devise. - Étape 3 → **les mêmes règles de datation que le rapport mensuel**. Le rapport reste la référence comptable ; le pilotage est une lecture.

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

ADM-PIL-3 — Le drilldown, et la journalisation des seules inscriptions

Gravité : bloquante.

Étapes : 1. Cliquer « Agrandir » sur la courbe « Deals terminés ». 2. Cliquer un point de la courbe, puis une ligne du tableau. 3. Lire le panneau latéral « Éléments de la période ». 4. Vérifier le journal. 5. Revenir aux courbes (« ← Toutes les courbes »), agrandir « Inscriptions » et ouvrir un point. 6. Vérifier le journal de nouveau.

Résultat attendu : - Étape 1 → la courbe passe en pleine largeur, avec un tableau « Période | {mesure} | Variation » (variation en vert ou rouge) et l'aide « Cliquez un point pour voir les éléments de la période. ». - Étape 3 → la liste des deals de la période avec libellé, statut, montant, date et lien vers la fiche ; le compteur « {n} élément(s) · 200 premiers affichés · du {date} au {date} ». La liste est **bornée à 200**. - Étape 4 → **aucune** ligne de journal pour un drilldown sur « Deals terminés », « Trajets publiés », etc. - Étape 6 → **une** ligne apparaît pour le drilldown sur « Inscriptions » : c'est une liste de **personnes**, donc une lecture sensible.

Ligne de journal attendue :

Action	Cible	Après
PILOTAGE_DRILLDOWN_VIEWED	USER (sans identifiant)	{ metric: "signups", period: "...", count: n }

Verdict : ☐ conforme ☐ non conforme

ADM-PIL-4 — Les corridors et la demande sans offre

Gravité : majeure. Préconditions : Redis actif. Pour créer une demande sans offre : depuis le **front public**, chercher plusieurs fois un corridor inexistant (par exemple « Nantes → Cotonou »).

Étapes : 1. Descendre à la section « Corridors ». Relever les colonnes. 2. Changer la fenêtre (7 / 30 / 90 / 365 jours). 3. Depuis le front public, lancer trois recherches sur un corridor inexistant. 4. Consulter deux fois la page publique d'un trajet, avec le même navigateur, le même jour. 5. Attendre 60 secondes (cache), recharger /pilotage.

Résultat attendu : - Étape 1 → colonnes « Corridor », « Trajets », « Demandes », « Acceptées », « €/kg moyen », « Litiges », « Vues », « Recherches », « Sans résultat ». - Étape 3 → une ligne apparaît pour le corridor cherché, **en ambre**, avec le badge « demande sans offre » : des recherches sans résultat et aucun trajet. -

Étape 4 → la colonne « Vues » n'augmente que de **1** : une vue compte **une fois par visiteur et par jour**. Rien de l'adresse du visiteur n'est conservé. - Le texte explicatif est présent : « Un corridor avec des recherches sans résultat et aucun trajet est une demande sans offre : c'est là qu'il faut recruter des Voyageurs. ». - **Contrôle de robustesse** : couper Redis, recharger la recherche publique et `/pilotage`. Les pages membres répondent **sans compteur**, le pilotage **sans vues ni recherches**. Aucune page ne casse. Relancer Redis ensuite.

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

5.18 Conversations (`/conversations/[bookingId]`)

ADM-CNV-1 — Lire un fil depuis un dossier

Gravité : bloquante. **Préconditions** : session **Médiateur** ou **Support**. Le fil du jeu d'essai est sur le deal `bzv-accepted`.

Étapes : 1. Depuis `/reports`, file « Messages », cliquer « Lire la conversation → ». 2. Vérifier le titre et le sous-titre. 3. Lire la mention sur le numéro de téléphone. 4. Parcourir les blocs « Rendez-vous », « Numéro révélé », « Fil ({n} messages) ». 5. Chercher un numéro de téléphone dans le fil. 6. Chercher un bouton d'écriture, de suppression ou de modification. 7. Ouvrir `/conversations/<id d'un deal sans conversation>`.

Résultat attendu : - Étape 2 → titre « Conversation du deal », sous-titre « Paris → Brazzaville · ACCEPTED · Expéditeur Pauline Lemaire · Voyageur Thomas Nkounkou », liens « ← Dossier du deal » et « ← Signalements ». - Étape 3 → « Lecture journalisée. Le numéro de téléphone n'apparaît jamais ici : seules les révélations sont tracées. ». - Étape 4 → bloc « Rendez-vous » : « Remise », lieu « Paris CDG, terminal 2E, comptoirs d'enregistrement », statut « proposé », « (par Voyageur) ». Bloc « Numéro révélé » : « Personne n'a encore vu le numéro de l'autre. ». Bloc « Fil (2 messages) » : le message de l'Expéditeur à gauche, celui du Voyageur à droite. - Le message du Voyageur porte le badge ambre « coordonnées détectées » ou le marquage rouge de signalement, avec le motif, l'auteur, la date, le statut et les précisions. - Étape 5 → **aucun numéro**. - Étape 6 → **aucun** : l'écran est en lecture seule. Un admin n'écrit jamais dans un fil de membres. - Étape 7 → **404** « Ce deal n'a pas de conversation. » (le fil naît à l'acceptation).

Ligne de journal attendue :

Action	Cible	Après
CONVERSATION_VIEWED	CONVERSATION · <code><id></code>	{ bookingId: " <code><id></code> ", messages: 2 }

Verdict : ☐ conforme ☐ non conforme

ADM-CNV-2 — La Finance ne lit aucune conversation

Gravité : bloquante.

Étapes : session **Finance**. Ouvrir un dossier de médiation, chercher le lien « Lire la conversation des deux parties → ». Puis appeler directement `/api/admin/conversations/<bookingId>`.

Résultat attendu : le lien est **absent** du dossier ; l'appel direct répond **403**. C'est une garde de vie privée délibérée : la Finance n'a rien à lire dans un échange entre membres.

Ligne de journal attendue : aucune. Un refus n'écrit rien — donc aucune ligne `CONVERSATION_VIEWED` ne doit apparaître.

Verdict : ☐ conforme ☐ non conforme

ADM-CNV-3 — Les révélations de numéro sont tracées

Gravité : majeure. Préconditions : un deal où le numéro a été révélé côté membre (au plus tôt 2 heures avant le rendez-vous de remise). À poser depuis le front, ou à sauter si le scénario membre n'est pas joué.

Étapes : 1. Faire révéler le numéro côté membre. 2. Rouvrir la conversation dans le back-office.

Résultat attendu : le bloc « Numéro révélé » affiche « Voyageur a vu le numéro le {date} » (ou « Expéditeur ... »), et un message système « Numéro affiché » apparaît au centre du fil. **Le numéro lui-même n'apparaît toujours pas.**

Ligne de journal attendue : `CONVERSATION_VIEWED` à chaque ouverture.

Verdict : ☐ conforme ☐ non conforme

5.19 Signalements : deux files (/reports)

ADM-SIG-1 — La file « Trajets et membres »

Gravité : majeure. Préconditions : session **Médiateur**, **Support** ou **super administrateur**. Le jeu d'essai ne pose **aucun** signalement de trajet ou de membre : il faut en créer.

Étapes : 1. Depuis le **front membre**, connecté en tant qu'Aminata Diallo, ouvrir le profil public de Thomas Nkounkou et cliquer « Signaler ce profil » avec le motif « Tentative d'arnaque ». 2. Recommencer avec le **même** compte sur la **même** cible. 3. Répéter le signalement avec deux autres comptes membres différents. 4. Dans le back-office, ouvrir /reports . Vérifier le titre et le sous-titre. 5. Relever la ligne du signalement. 6. Cliquer la cible.

Résultat attendu : - Étape 2 → refus **409** : pas deux signalements ouverts du même auteur sur la même cible. - Étape 4 → la page porte deux sections : « Trajets et membres » puis « Messages » (ancrage `#messages` , avec la mention « Lis la conversation avant de décider (lecture journalisée). »). - Étape 5 → onglets « à traiter » / « traité » / « sans suite », compteur « {n} signalement(s) ». Chaque carte porte : le motif (« Tentative d'arnaque »), l'auteur (prénom) et la date, le type de cible (« Membre »), la cible cliquable, les précisions, un champ « Note pour le journal (facultatif) », et les boutons « Traité » et « Sans suite ». - Après le **troisième** signalement ouvert sur la même cible, la carte porte le badge rouge « **Prioritaire · 3 ouverts** ». - Si le membre visé est « À surveiller » ou « À risque », un badge de niveau s'affiche (« Standard » et « Compte neuf » ne sont pas affichés). - Étape 6 → arrivée sur la fiche membre (ou la fiche trajet pour une cible « Trajet »). - Point capital : **l'auteur du signalement n'est jamais révélé à la cible**, et il n'apprend pas la suite donnée.

Ligne de journal attendue : `USER_VIEWED` à l'ouverture de la fiche cible. La lecture de la file n'écrit rien.

Verdict : ☐ conforme ☐ non conforme

ADM-SIG-2 — Traiter un signalement de trajet ou de membre

Gravité : bloquante.

Étapes : 1. Saisir une note : « Compte restreint le {date} après vérification ». 2. Cliquer « Traité ». 3. Basculer sur l'onglet « traité ». 4. Recliquer « Traité » sur le même signalement (par appel direct). 5. Sur un autre signalement, cliquer « Sans suite » sans note.

Résultat attendu : - Étape 2 → « Signalement traité (journalisé). ». La carte sort de « à traiter ». - Étape 3 → la carte apparaît dans « traité ». Le libellé de l'onglet et du statut est bien « **traité** » (et non un code brut). - Étape 4 → refus **409** « This report has already been reviewed. ». - Étape 5 → « Signalement classé sans suite (journalisé). ». La note est **facultative** : aucune longueur minimale. - **Aucun email** n'est envoyé à la décision. L'accusé de réception à l'auteur est parti à la création, côté membre.

Lignes de journal attendues :

Geste	Action	Cible	Avant	Après
« Traité »	REPORT_REVIEWED	REPORT · <id>	{ status: "OPEN", ... }	{ status: "REVIEWED", note: "..." }
« Sans suite »	REPORT_REVIEWED	REPORT · <id>	{ status: "OPEN", ... }	{ status: "DISMISSED", note: null }

La décision et la ligne de journal sont écrites dans **une seule** transaction (`updateMany` conditionnel).

Verdict : ☐ conforme ☐ non conforme

ADM-SIG-3 — La file « Messages » et sa décision

Gravité : bloquante. Préconditions : le signalement de message du jeu d'essai (motif « Veut sortir de Yamba »).

Étapes : 1. Ouvrir `/reports`, section « Messages ». 2. Relever le contenu de la carte. 3. Cliquer « Lire la conversation → ». 4. Revenir, cliquer « Fiche de {prénom} → ». 5. Saisir une note, cliquer « Traité ». 6. Recliquer « Traité » par appel direct. 7. Envoyer ce signalement de message à `PATCH /api/admin/reports/<id>` (la route des trajets et membres).

Résultat attendu : - Étape 2 → motif « Veut sortir de Yamba », auteur du signalement et son rôle (« Pauline (Expéditeur) »), corridor, **citation du message signalé** (auteur, rôle, date, texte), précisions « Il propose de régler hors de Yamba. », liens « Lire la conversation → » et « Fiche de ... → ». - Étape 5 → « Signalement traité (journalisé). ». - Étape 6 → **409**. - Étape 7 → **404** : un signalement de message vit dans le message-service, pas dans l'auth-service. Les deux files sont servies par deux services distincts.

Ligne de journal attendue :

Action	Cible	Avant	Après
MESSAGE_REPORT_REVIEWED	REPORT · <id>	{ status: "OPEN" }	{ status: "REVIEWED", note: "..." }

Verdict : ☐ conforme ☐ non conforme

ADM-SIG-4 — Un signalement ne sanctionne rien tout seul

Gravité : bloquante.

Étapes : 1. Créer trois signalements ouverts sur le même membre (ADM-SIG-1). 2. Attendre, recharger `/users/<id de la cible>` et `/trips`. 3. Vérifier le statut du compte visé et la visibilité de ses trajets.

Résultat attendu : rien n'a changé. Le compte reste `ACTIVE`, ses trajets restent visibles, aucun email ne lui est parti. La priorité dans la file `éclairé` la décision ; elle ne la prend pas. Une sanction ou un masquage automatique serait une anomalie **bloquante**.

Ligne de journal attendue : aucune ligne de sanction ou de masquage.

Verdict : ☐ conforme ☐ non conforme

ADM-SIG-5 — Le Support et le Médiateur seuls décident

Gravité : majeure.

Étapes : ouvrir `/reports` avec les profils **Finance**, **Exploitation** et **Données personnelles**.

Résultat attendu : l'entrée « Signalements » est **absente** du menu pour ces trois profils ; l'ouverture directe et les appels répondent **403**. `reports.review` appartient au Médiateur, au Support et au super administrateur.

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

5.20 Paramètres de la plateforme (`/settings`)

ADM-PAR-1 — La page, ses groupes et ses trois classes

Gravité : majeure. Préconditions : `seed-settings.ts` joué (toutes les valeurs par défaut). Session **super administrateur**.

Étapes : 1. Ouvrir `/settings`. Lire la barre d'état du haut. 2. Relever les titres de groupe, dans l'ordre. 3. Relever les colonnes du tableau d'un groupe. 4. Cliquer le libellé d'un paramètre pour ouvrir son panneau d'explication. 5. Descendre à la section « Modifiables par déploiement seulement ». 6. Cliquer « Documentation des paramètres » et parcourir la page `/settings/docs`.

Résultat attendu : - Étape 1 → « Version {n} · toutes les valeurs sont celles par défaut » et le bouton « Tout réinitialiser ({n}) » (inactif ou absent si rien ne diffère). - Étape 2 → douze groupes : « Prix et commission », « Garantie Yamba », « Annulation », « Notation », « Litiges », « Réputation », « Messagerie », « Alertes d'exploitation », « Documents », « Données personnelles », « Conservation », « Confiance (TrustScore interne) ». - Étape 3 → « Paramètre », « En vigueur », « Nouvelle valeur », « Défaut », « Portée », puis la colonne « historique ». - Étape 4 → le panneau montre la description, « Exemple : ... », « Bornes : {min} à {max} · lu par {consommateurs}. » et, le cas échéant, « Cette valeur figure dans les CGU : mettre le texte à jour après modification. ». - Étape 5 → un bloc en **lecture seule** : « Invariants de sécurité : visibles ici pour la vue d'ensemble, jamais depuis une page web. » (classe B). - Étape 6 → la page de documentation reprend le même texte, à une seule source, et liste en fin de page la **classe C** (« Prévus, pas encore lus par le code »), avec l'explication « Un curseur qui ne commande rien serait une illusion de contrôle... ». - **Règle à vérifier :** aucun curseur ne doit exister pour une clé que le code ne lit pas.

Ligne de journal attendue : aucune pour la lecture.

Verdict : ☐ conforme ☐ non conforme

ADM-PAR-2 — Modifier une clé métier et voir l'effet en moins de 30 secondes

Gravité : bloquante. ☒ **Préconditions :** session **super administrateur**.

Étapes : 1. Groupe « Prix et commission », saisir une nouvelle valeur pour la commission (par exemple 12 % → 15 %). Lire l'aperçu chiffré. 2. Observer le panneau collant en bas. 3. Saisir un motif de moins de 20 caractères, puis d'au moins 20. 4. Cliquer « Enregistrer (journalisé, email aux super administrateurs) ». 5. Chronométrer, puis appeler `GET /api/trips/pricing/params` depuis le front public. 6. Lire Mailpit. 7. Recharger `/settings` et lire la barre d'état. 8. Ouvrir « historique » sur la clé modifiée. 9. Vérifier qu'une réservation **déjà créée** garde son prix.

Résultat attendu : - Étape 1 → l'aperçu affiche « Sur un transport de 20 € : commission {x} €, total Expéditeur {y} € ». - Étape 2 → panneau « À valider — 1 modification(s) », avec la ligne « {libellé} : {avant} → {après} » et la mention « figure dans les CGU » si la clé y figure. - Étape 3 → le compteur affiche « {n}/20 » ; le bouton reste inactif sous 20 caractères. - Étape 4 → « 1 paramètre(s) modifié(s) — version {v}, journalisé, super administrateurs prévenus. ». - Étape 5 → la nouvelle valeur est servie **en moins de 30 secondes** (le lecteur de paramètres a un cache mémoire de 30 s). - Étape 6 → ☒ un email « Paramètres de la plateforme modifiés » arrive à **tous** les super administrateurs, dans leur langue. - Étape 7 → « Version {n+1} · dernière écriture le {date} par {prénom} {initiale}. · 1 valeur(s) modifiée(s) par rapport au défaut », et le badge ambre « modifiée » sur la ligne. - Étape 8 → l'historique affiche « {date} · {admin} · modifié : {avant} → {après} · « {motif} » ». - Étape 9 → **rien n'est rétroactif** : une réservation garde le prix figé à sa création, un litige ouvert garde son échéance. - La mention « Paramètres modifiés le ... » apparaît sur `/home`.

Ligne de journal attendue : une ligne par clé, écrite dans la même transaction que l'écriture.

Action	Cible	Avant	Après
SETTING_CHANGED	SETTINGS · pricing.commissionPct	{ key, value: 12, version: n }	{ key, value: 15, reason: "...", version: n+1 }

Verdict : ☐ conforme ☐ non conforme

ADM-PAR-3 — Une modification de trois clés écrit trois lignes

Gravité : majeure.

Étapes : 1. Modifier **trois** clés en une seule fois (par exemple trois seuils d'alerte, en session Exploitation). 2. Vérifier que le panneau annonce « À valider — 3 modification(s) ». 3. Enregistrer avec un seul motif. 4. Ouvrir `/audit`, filtrer sur l'action « Paramètre modifié ».

Résultat attendu : **trois** lignes `SETTING_CHANGED`, une par clé, portant chacune le **même** motif et la **même** version. Une seule ligne agrégée serait une anomalie **majeure** : le journal doit permettre de retrouver l'historique d'une clé précise.

Verdict : ☐ conforme ☐ non conforme

ADM-PAR-4 — Les gardes : bornes, cohérence, portée

Gravité : bloquante.

Étapes et résultats attendus :

#	Geste	Réponse attendue
1	Saisir une commission de 50 % (hors bornes 5–20 %)	400 « Some values are out of bounds. »
2	Saisir un plancher de taille M inférieur à celui de taille S	400 de cohérence ($S \leq M \leq L$)
3	Saisir une prime de Garantie supérieure à son plafond	400 de cohérence (plafond $\geq$ prime)
4	Saisir un intervalle de relance inférieur au délai de relance	400 de cohérence
5	Session Exploitation : écrire une clé de portée métier	403 « Your admin profile cannot change: {clé}. »
6	Session super administrateur : écrire une clé de portée exploitation	accepté (le super administrateur passe partout)
7	Session Support ou Finance : écrire n'importe quelle clé	403 (ils ont <code>settings.read</code> seulement)
8	Envoyer une requête mêlant une clé métier et une clé exploitation en session Exploitation	403 , en nommant la ou les clés refusées
9	Envoyer un motif de moins de 20 caractères	400
10	Envoyer une requête sans changement effectif	400
11	Envoyer une clé inconnue	400

Ligne de journal attendue : aucune dans les onze cas de refus. La portée est jugée **avant** toute écriture : rien ne doit être écrit partiellement.

Verdict : ☐ conforme ☐ non conforme

ADM-PAR-5 — Le verrou de version (deux admins en même temps)

Gravité : bloquante. ➤ deux profils

Étapes : 1. Ouvrir `/settings` dans **deux** sessions admin (A = super administrateur, B = Exploitation). 2. Dans A, saisir une valeur **sans** enregistrer. 3. Dans B, modifier une autre clé et **enregistrer**. 4. Dans A, saisir le motif et enregistrer à son tour.

Résultat attendu : - Étape 4 → refus **409** : « Les paramètres ont changé entre-temps : la page est rechargée, refais ta modification. » (message serveur « The settings changed meanwhile: reload and try again. »). - La page se recharge sur la version courante ; les saisies en attente de A sont **perdues** et la modification est à refaire. C'est voulu : mieux vaut perdre une saisie qu'écraser silencieusement le travail d'un collègue.

Ligne de journal attendue : seulement les lignes de l'écriture **réussie** de B. L'écriture refusée de A n'écrit rien.

Verdict : ☐ conforme ☐ non conforme

ADM-PAR-6 — Remettre une clé par défaut, puis tout réinitialiser

Gravité : majeure. ☒

Étapes : 1. Sur une clé modifiée, cliquer « remettre » dans la colonne « Défaut », puis enregistrer avec un motif. 2. Modifier trois clés, puis cliquer « Tout réinitialiser ({n}) ». 3. Lire le panneau de confirmation. 4. Saisir un motif d'au moins 20 caractères, cliquer « Confirmer la réinitialisation ». 5. Lire Mailpit. 6. Rejouer la réinitialisation alors que tout est déjà au défaut. 7. Session **Exploitation** : cliquer « Tout réinitialiser » alors que des clés **métier** sont modifiées.

Résultat attendu : - Étape 1 → « remettre » est **une modification comme une autre** : même motif, même journal, même email. - Étape 3 → le panneau est intitulé « Tout remettre par défaut — voici exactement ce qui va changer » et liste **la liste exacte** des clés touchées, « {libellé} : {avant} → {après} (défaut, {règle}) ». - Étape 4 → « {n} paramètre(s) remis par défaut — version {v}, journalisé. ». - Étape 5 → ✉ email « Paramètres de la plateforme réinitialisés » aux super administrateurs. - Étape 6 → refus **400** : rien à remettre. - Étape 7 → seules les clés que **le profil peut écrire** sont proposées et remises. Les clés métier restent inchangées.

Ligne de journal attendue : une ligne `SETTINGS_RESET` **par clé remise**, cible `SETTINGS` · <clé>.

Verdict : ☐ conforme ☐ non conforme

ADM-PAR-7 — Le repli sûr : une base de paramètres absente

Gravité : bloquante.

Étapes : 1. Relever le comportement courant d'une règle métier (par exemple la commission appliquée par le wizard de réservation). 2. Exécuter `npx tsx --env-file=.env packages/libs/prisma/scripts/seed-settings.ts` : le document `PlatformSettings` est **supprimé**. 3. Attendre 30 secondes, puis recharger les écrans membres et le back-office. 4. Ouvrir `/settings`.

Résultat attendu : - Étape 3 → **la plateforme se comporte exactement comme à l'origine** : chaque service repart sur les valeurs par défaut du catalogue. Aucune erreur, aucun écran cassé. Le lecteur de paramètres est fail-safe : un document illisible ou absent ne fait jamais lever d'exception. - Étape 4 → la barre d'état affiche « Version 0 » et « toutes les valeurs sont celles par défaut ». - **Aucune ligne de journal** n'est écrite par le script : c'est un geste de préparation de recette, pas un geste admin. En production, la remise à zéro passe **obligatoirement** par la page, qui journalise.

Verdict : ☐ conforme ☐ non conforme

5.21 Données personnelles et effacement RGPD

ADM-RGP-1 — Le registre des demandes est journalisé à la lecture

Gravité : majeure. Préconditions : session **Données personnelles** ou **super administrateur**.

Étapes : 1. Ouvrir `/privacy`. Lire le sous-titre. 2. Relever les colonnes. 3. Sur un jeu d'essai neuf, lire l'état vide. 4. Vérifier immédiatement le journal.

Résultat attendu : - Étape 1 → « Le registre des demandes (export, effacement) : la preuve du délai légal d'un mois. Un effacement à la demande d'un membre se fait depuis sa fiche (« Effacer ce compte »). Cette consultation est journalisée. ». - Étape 2 → « Quand », « Membre », « Demande », « Canal », « Issue », « Détail ». Les valeurs attendues : « Export » / « Effacement » ; « par le membre » / « par l'admin ({nom}) » ; badges « faite » / « refusée ». - Étape 3 → « Aucune demande pour l'instant. ». - Étape 4 → **la simple consultation a écrit une ligne**.

Ligne de journal attendue :

Action	Cible	Après
<code>DATA_REQUESTS_VIEWED</code>	USER (sans identifiant)	<code>{ rows: n }</code>

Verdict : ☐ conforme ☐ non conforme

ADM-RGP-2 — Un effacement refusé et ses bloqueurs

Gravité : bloquante. **Préconditions :** session **Données personnelles** ou **super administrateur**. Cible : **Thomas Nkounkou** (Voyageur avec des deals en cours et des trajets publiés).

Étapes : 1. Ouvrir la fiche de Thomas. Descendre à la carte « Effacer ce compte (RGPD) ». Lire le texte. 2. Saisir un motif de moins de 20 caractères. 3. Saisir un motif valide mais taper `effacer` en minuscules dans le champ de confirmation. 4. Saisir « Demande reçue par email le {date}, identité vérifiée » et `EFFACER`. Cliquer « Effacer définitivement ». 5. Lire le message de refus. 6. Ouvrir `/privacy`.

Résultat attendu : - Étape 1 → « Immédiat et irréversible. Anonymise l'identité et les coordonnées, supprime adresses, alertes, favoris, justificatifs ; conserve réservations, litiges, avis et messages sans le nom. Refusé tant qu'un deal vit. Le motif (demande reçue le..., canal) part au journal et au registre des demandes. ». - Étape 2 → bouton inactif (motif ≥ 20 caractères, maximum 500). - Étape 3 → le champ met automatiquement en majuscules ; il doit valoir **exactement** `EFFACER`. - Étape 5 → refus **409** avec la traduction des bloqueurs : « Refusé pour l'instant : un deal en cours, un trajet publié ou en pause. ». La liste des bloqueurs est **fermée** : « un deal en cours », « une demande en attente », « un versement dû ou en échec », « une retenue en médiation », « un trajet publié ou en pause », « un profil admin (à révoquer d'abord) ». - Étape 6 → **le refus est inscrit au registre DataRequest** avec son issue « refusée » et les motifs.

Ligne de journal attendue : aucune ligne `ACCOUNT_ERASED`. Un refus n'écrit pas au journal admin — seul le registre en garde trace. **Consigner ce point :** c'est une divergence connue, laissée à l'arbitrage (le registre suffit-il comme preuve ?).

Verdict : ☐ conforme ☐ non conforme

ADM-RGP-3 — Effacer un compte à la demande

Gravité : bloquante.  **Préconditions :** un compte **sans** deal vivant, sans trajet publié, sans versement dû et **sans profil admin** — par exemple un compte membre créé pour l'occasion depuis le front, avec une adresse, un avatar et un favori.

Étapes : 1. Session **Données personnelles**. Ouvrir la fiche du compte. 2. Motif ≥ 20 caractères, confirmation `EFFACER`, « Effacer définitivement ». 3. Lire le message de succès. 4. Rouvrir la fiche (ou rechercher le compte dans `/users`). 5. Vérifier en base : `User`, `CarrierPage`, `ErasedAccount`, adresses, favoris, notifications. 6. Vérifier qu'une réservation portée par ce compte est **conservée**. 7. Côté membre, tenter de se connecter avec les anciens identifiants. 8. Lire Mailpit. 9. Ouvrir `/privacy`. 10. Tenter d'effacer **son propre** compte admin.

Résultat attendu : - Étape 3 → « Compte effacé : identité et coordonnées supprimées, réservations conservées sans nom, journal écrit, email de confirmation envoyé à l'ancienne adresse. ». - Étape 4 → le membre apparaît comme « Membre supprimé » ; un second effacement répond **404** « User not found. ». - Étape 5 → **une seule transaction** a : mis le prénom à « Membre » et le nom à « supprimé » ; remplacé l'email par `erased+<id>@anonymised.invalid` et le slug par `deleted-<id>` (**jamais null** sur un champ unique, sous peine de collision) ; effacé mot de passe, téléphones, genre, date de naissance, secret TOTP et rôles client ; posé `isDeleted` et `deletedAt` ; anonymisé la `CarrierPage` et **déplacé** `stripeAccountId` dans `ErasedAccount` (obligations comptables : le compte Stripe Connect n'est **pas** supprimé) ; supprimé adresses, identités OAuth, avatar, abonnements, alertes route, favoris, notifications et justificatifs de trajet (fichiers `ImageKit` compris). - Étape 6 → réservations, litiges, avis, messages, rendez-vous, révélations de numéro, signalements et journal admin sont **conservés**, l'auteur devenant « Membre supprimé ». Le `ConsentLog` est gardé **sans IP ni user-agent**. - Étape 7 → la connexion répond **401** avec le code `ACCOUNT_DELETED`. Toutes ses sessions ont été révoquées. - Étape 8 →  un email de confirmation, **sans lien**, part à l'ancienne adresse. Ensuite, **plus aucun email ne part** vers ce compte : tout résolveur de destinataire doit ignorer `isDeleted`. - Étape 9 → une ligne

apparaît au registre : type « Effacement », canal « par l'admin ({nom}) », issue « faite ». - Étape 10 → **403** « You cannot erase your own account from the back-office. ».

Ligne de journal attendue :

Action	Cible	Après
ACCOUNT_ERASED	USER · <id>	{ reason: "...", stripeAccountKept: true, ... }

Cette ligne est écrite **dans la transaction d'effacement**.

 Le compte est irrécupérable : ne jouer ce scénario que sur un compte créé pour lui.

Verdict : ☐ conforme ☐ non conforme

ADM-RGP-4 — Le tiers destinataire est oublié

Gravité : majeure. **»»** partiellement

Objet : vérifier que le nom, le téléphone et l'email du destinataire d'un colis sont effacés `privacy.recipientRetentionDays` jours (défaut **30**) après la fin du deal, jamais avant.

Étapes : 1. Sur un deal `COMPLETED` du jeu d'essai, vérifier que le destinataire est encore renseigné (fiche argent, dossier). 2. Abaisser `privacy.recipientRetentionDays` à **0** depuis `/settings` (portée exploitation). 3. Attendre le passage du cron `recipient-redaction` du deal-service (03:40) ou le déclencher. 4. Recharger la fiche du deal. 5. Remettre le paramètre à 30.

Résultat attendu : après le passage du cron, les coordonnées du destinataire ont disparu de la réservation. Le lien de suivi destinataire meurt en même temps.

»» Sans possibilité de déclencher le cron à la demande, ce scénario n'est pas jouable dans la journée : le noter comme non applicable et le faire vérifier en tests unitaires.

Lignes de journal attendues : deux `SETTING_CHANGED` (l'abaissement et le retour à 30). Le cron lui-même n'écrit pas au journal admin.

Verdict : ☐ conforme ☐ non conforme ☐ **»»**

5.22 État des services (`/status`)

ADM-ETA-1 — Les six services et leurs dépendances

Gravité : majeure. **Préconditions :** tous les services démarrés. `status.read` est ouvert à **tous** les profils.

Étapes : 1. Ouvrir `/status`. Lire le bandeau de synthèse. 2. Relever les six cartes de service. 3. Laisser la page ouverte 35 secondes et observer la mention « Relu il y a {n} s ». 4. Arrêter un service (par exemple `message-service`), attendre le rafraîchissement. 5. Relancer le service.

Résultat attendu : - Étape 1 → « Tous les services répondent et leurs dépendances sont saines. Relu il y a {n} s. » en vert. - Étape 2 → six cartes : gateway, auth, trip, deal, notification, message. Chacune verte avec « OK », la version, « démarré il y a {n} min » et les dépendances « ✓ mongo ({n} ms) », « ✓ redis ({n} ms) ». - Étape 3 → la page se relit **toutes les 30 secondes** tant qu'elle est ouverte. - Étape 4 → le bandeau passe en rouge : « 1 service(s) en difficulté : message. Relu il y a {n} s. » ; la carte du service passe rouge avec « Injoignable — {erreur} ». - Une dépendance en panne (Redis coupé, par exemple) donne une carte **ambre** « Dégradé » avec «

X redis ({n} ms) — {erreur} ». Chaque /health répond **toujours** HTTP 200, avec ok ou degraded : le code HTTP ne sert pas de signal ici. - **Ce n'est pas un outil de supervision** : le sous-titre le dit explicitement.

Ligne de journal attendue : aucune. La lecture de l'état des services n'est pas journalisée.

Verdict : ☐ conforme ☐ non conforme

ADM-ETA-2 — Les battements de cron

Gravité : majeure.

Étapes : 1. Descendre à « Crons — dernier battement ». Relever les colonnes. 2. Sur une plateforme fraîchement démarrée, lire l'état vide. 3. Attendre le passage des crons courts (expire-bookings, payout-bookings, unread-reminder, toutes les 5 minutes) et recharger. 4. Chercher la mention « en retard ? ». 5. Vider Redis, puis recharger.

Résultat attendu : - Étape 1 → colonnes « Service », « Cron », « Dernier passage », « Durée », « Résultat ». - Étape 2 → « Aucun battement enregistré : les crons n'ont pas encore tourné depuis le déploiement (ou Redis est vide). ». - Étape 3 → les treize crons attendus apparaissent au fil de leurs passages :

Service	Cron	Expression
auth-service	onboarding-reminder	0 * * * *
trip-service	complete-trips	15 3 * * *
deal-service	expire-bookings	*/5 * * * *
deal-service	payout-bookings	*/5 * * * *
deal-service	rating	17 * * * *
deal-service	ops-alerts	5 * * * *
deal-service	ops-digest	0 8 * * *
deal-service	recipient-redaction	40 3 * * *
deal-service	outbox-retention	55 3 * * *
message-service	unread-reminder	*/5 * * * *
message-service	conversation-retention	30 3 * * *
message-service	outbox-retention	55 3 * * *
notification-service	retention	50 3 * * *

- Étape 4 → la mention ambre « en retard ? » apparaît quand un battement a plus de **deux fois** l'intervalle attendu.
- Étape 5 → l'écran redevient vide : les battements vivent dans Redis (clés yamba:cron:<service>:<nom>, durée 7 jours). C'est un point de fragilité assumé.
- Point d'attention structurel :** un cron qui n'est pas enveloppé par le mécanisme de battement est **invisible** ici. Un cron absent du tableau alors qu'il est censé tourner est une anomalie **majeure**.

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

ADM-ETA-3 — Le bloc outbox et le bloc emails

Gravité : majeure.

Étapes : 1. Relever le bloc « Outbox ». 2. Arrêter Redpanda. Provoquer une écriture métier (accepter une demande côté membre, par exemple). 3. Recharger `/status`. 4. Poser un événement destiné au parking : `npm run tsx --env-file=.env packages/libs/prisma/scripts/seed-outbox.ts --with-poison`. 5. Attendre que le relais épuise ses tentatives, puis recharger. 6. Relever le bloc « Emails (24 h) ». 7. Relancer Redpanda.

Résultat attendu : - Étape 1 → « {n} événement(s) non publié(s), le plus ancien il y a {...}. » puis « {n} parqué(s) (≥ {seuil} tentatives). ». - Étape 3 → le nombre d'événements non publiés **augmente** et l'âge du plus ancien grandit : le relais ne publie plus. **Aucune donnée n'est perdue** : l'événement est écrit dans la même transaction que le geste métier et attend. - Étape 5 → le compteur « parqué(s) » passe en **rouge**. Un événement parqué n'est **jamais** purgé par la rétention. - Étape 6 → « {n} envoyé(s) » et « {n} en échec » (en rouge si supérieur à zéro). - Étape 7 → les événements en attente repartent d'eux-mêmes ; le compteur redescend.

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

5.23 Maintenance

ADM-MNT-1 — Annoncer une maintenance sans rien bloquer

Gravité : majeure. ☒ **Préconditions :** session **Exploitation** ou **super administrateur** (`maintenance.write`).

Étapes : 1. Ouvrir `/status`, bloc « Maintenance ». Lire l'état courant. 2. Renseigner « Annoncer pour le (optionnel) » avec une date dans deux heures. 3. Saisir un message FR et un message EN (≤ 300 caractères chacun). 4. Laisser la case « Activer la lecture seule maintenant » **décochée**. 5. Saisir un motif d'au moins 20 caractères, cliquer « Enregistrer l'annonce ». 6. Ouvrir le front membre et le back-office. 7. Côté membre, publier un trajet ou envoyer un message. 8. Lire Mailpit.

Résultat attendu : - Étape 1 → « Aucune maintenance en cours ni annoncée. ». - Étape 5 → « Enregistré : journal écrit, super administrateurs prévenus, le gateway applique dans les 10 s. ». - Étape 6 → un bandeau **ambre** « Maintenance annoncée le {date} — {message} · état des services » apparaît sur **les deux fronts**. - Étape 7 → **rien n'est bloqué** : une annonce prévient, elle ne coupe pas. - Étape 8 → ☒ email « Maintenance planifiée sur Yamba » à tous les super administrateurs. - L'état affiché devient « Maintenance annoncée le {date} : le bandeau est affiché, rien n'est bloqué. Dernière modification le {date} par {admin} (version {n}). ».

Ligne de journal attendue :

Action	Cible	Avant	Après
MAINTENANCE_CHANGED	SETTINGS · maintenance	{ ..., version: n }	{ ..., reason: "...", version: n+1 }

Verdict : ☐ conforme ☐ non conforme

ADM-MNT-2 — Passer la plateforme en lecture seule

Gravité : bloquante. ☒

Étapes : 1. Cocher « Activer la lecture seule maintenant », motif d'au moins 20 caractères, cliquer « Passer en lecture seule ». 2. Chronométrer, puis recharger le front membre. 3. Côté membre, **lire** une annonce, une conversation, son tableau de bord. 4. Côté membre, tenter d'**écrire** : réserver, publier, envoyer un message. 5. Côté membre, se déconnecter puis se reconnecter. 6. Ouvrir le back-office et naviguer. 7. Appeler la sonde publique `GET /api/status`. 8. Lire Mailpit.

Résultat attendu : - Étape 2 → **le gateway relit l'état toutes les 10 secondes** : l'effet est visible en moins de 10 secondes. Bandeau **rouge** « Plateforme en lecture seule — {message} » sur les deux fronts. - Étape 3 → **toutes les lectures passent**. - Étape 4 → chaque écriture (POST / PUT / PATCH / DELETE) répond **503** avec le code `MAINTENANCE` et l'en-tête `Retry-After: 300`. - Étape 5 → **la connexion reste ouverte** : `/api/auth/*` est exempté. - Étape 6 → **le back-office fonctionne normalement** : `/api/admin/*` est exempté. C'est indispensable pour pouvoir lever la maintenance. - Étape 7 → **HTTP 200** avec l'état « maintenance ». Une maintenance planifiée **n'est pas une panne** : le moniteur externe ne doit réveiller personne. - Étape 8 → ✉ email « Maintenance activée sur Yamba » aux super administrateurs.

Ligne de journal attendue : `MAINTENANCE_CHANGED` sur `SETTINGS` · `maintenance`, avec le motif et la version.

Verdict : ☐ conforme ☐ non conforme

ADM-MNT-3 — Lever la maintenance

Gravité : bloquante. ✉

Étapes : 1. Décocher « Activer la lecture seule maintenant ». Motif ≥ 20 caractères. Cliquer « Lever la maintenance ». 2. Attendre 10 secondes, recharger le front membre. 3. Côté membre, refaire une écriture. 4. Lire Mailpit.

Résultat attendu : les bandeaux disparaissent des deux fronts, les écritures repassent en moins de 10 secondes, ✉ un email « Maintenance levée sur Yamba » part aux super administrateurs.

Ligne de journal attendue : `MAINTENANCE_CHANGED` sur `SETTINGS` · `maintenance`.

Verdict : ☐ conforme ☐ non conforme

ADM-MNT-4 — Le verrou de version et l'interrupteur d'environnement

Gravité : majeure.

Étapes : 1. ► **deux profils** : ouvrir `/status` dans deux sessions habilitées. Dans B, changer l'état de maintenance. Dans A, enregistrer à son tour. 2. Arrêter le gateway, poser `MAINTENANCE_MODE=on` (avec `MAINTENANCE_MESSAGE_FR` / `_EN`) dans son environnement, le relancer. 3. Ouvrir `/status`. 4. Tenter de lever la maintenance depuis l'écran. 5. Retirer la variable et relancer le gateway. 6. Session **Support**, ouvrir `/status`.

Résultat attendu : - Étape 1 → refus **409** : « L'état a changé entre-temps : la page est rechargée. » (message serveur « The maintenance state changed meanwhile... »). - Étape 3 → le badge « **forcée par l'environnement du gateway** » s'affiche à côté du titre « Maintenance ». - Étape 4 → **impossible** : l'interrupteur d'environnement l'emporte sur la base. C'est prévu pour le jour où Mongo lui-même est la panne. - Étape 6 → Le Support **lit** la page (`status.read` est ouvert à tous les profils) mais voit « Profil Exploitation ou super administrateur pour modifier. » à la place du formulaire.

Ligne de journal attendue : seulement pour l'écriture réussie de l'étape 1. L'interrupteur d'environnement, lui, n'écrit **rien** au journal : c'est un geste d'exploitation hors application, à consigner ailleurs.

Verdict : ☐ conforme ☐ non conforme

5.24 Journal d'audit (/audit)

ADM-JRN-1 — Le journal et ses six filtres serveur

Gravité : bloquante. Préconditions : session **Finance** ou **super administrateur** (audit.read). Plusieurs gestes admin déjà joués.

Étapes : 1. Ouvrir /audit. Vérifier le titre « Journal des actions admin » et le sous-titre « Qui a fait quoi, sur quoi, quand. Écrit dans la même transaction que chaque geste. ». 2. Relever les filtres disponibles et leurs libellés. 3. Filtrer sur une **période** (« Du » / « Au »). 4. Filtrer sur une **action** (le select propose les actions présentes dans les lignes chargées, en français). 5. Filtrer sur un **type de cible**. 6. Coller un **identifiant de cible** (placeholder « 24 caractères »). 7. Filtrer sur une **IP** (placeholder « 10.0.0.1 »). 8. Utiliser le champ « Contient (lignes chargées, détail compris) » (placeholder « mot, identifiant, motif... »). 9. Lire la barre sous les filtres. 10. Cliquer « Tout effacer ». 11. Cliquer une cellule « Qui », « Action », « Cible », « IP ».

Résultat attendu : - Étape 2 → six filtres **serveur** : « Du », « Au », « Action », « Type de cible », « Identifiant de cible », « IP ». Le select « Type de cible » propose : USER, BOOKING, DISPUTE, TRIP, SESSION, SETTINGS, REPORT, MAINTENANCE, EXPORT. - Étape 8 → la recherche « contient » ne porte **que sur les lignes déjà chargées**. L'écran le dit : « La recherche « contient » ne porte que sur les lignes déjà chargées : le détail est du JSON, il ne s'indexe pas. ». - Étape 9 → « {n} ligne(s) affichée(s) », complété de « sur {n} chargées » quand la recherche libre est active, puis « Filtres serveur : {liste} ». Le bouton « Tout effacer » n'apparaît que si un filtre est renseigné. - Étape 11 → chaque valeur est **cliquable** et pose le filtre correspondant (info-bulles « Filtrer sur cet auteur », « Filtrer sur cette action », « Filtrer sur cette cible », « Filtrer sur cette IP »). - Colonnes : « Quand », « Qui », « Action », « Cible », « Détail », « IP ». - États vides : « Aucune action journalisée. » sans filtre, « Aucune action ne correspond à ces filtres. » avec filtres. - Pagination : « Charger la suite ».

Ligne de journal attendue : aucune. Lire le journal ne se journalise pas.

Verdict : ☐ conforme ☐ non conforme

ADM-JRN-2 — Tous les libellés d'action sont en français

Gravité : cosmétique, mais à consigner.

Étapes : 1. Ouvrir /audit sans filtre, dérouler plusieurs pages. 2. Relever la colonne « Action » : chercher un **code brut** en majuscules avec des tirets bas. 3. Vérifier en particulier « Signalement traité » et « Message signalé traité ».

Résultat attendu : toutes les actions s'affichent avec un libellé français. Aucune n'apparaît sous sa forme technique. Les 43 libellés attendus incluent notamment : « Connexion admin », « Déconnexion », « 2FA activée », « Code de secours utilisé », « Session révoquée », « Admin invité », « Invitation acceptée », « Profil admin modifié », « Accès admin retiré », « Fiche consultée », « Suspension proposée », « Compte restreint », « Compte suspendu », « Compte rétabli », « Suppression d'adresse levée », « Compte effacé (RGPD) », « Registre RGPD consulté », « Trajet consulté », « Masquage proposé », « Trajet masqué », « Trajet rétabli », « Document ouvert », « Billet vérifié », « Billet rejeté », « Dossier consulté », « Litige tranché », « Retenue arbitrée », « Fiche argent consultée », « Rapprochement Stripe », « Versement joué », « Renversement clos », « Export finances », « Remboursement manuel proposé », « Remboursement manuel appliqué », « Chronologie consultée », « Liste d'inscriptions consultée (pilotage) », « Export CSV », « Conversation consultée », « Message signalé traité », « **Signalement traité** », « Paramètre modifié », « Paramètre réinitialisé », « État de maintenance modifié ».

Point de non-régression. Le libellé de `REPORT_REVIEWED` (« Signalement traité ») **manquait** : le journal affichait le code brut. Voir `ADM-NRG-3`.

Verdict : ☐ conforme ☐ non conforme

ADM-JRN-3 — Le journal est complet et fidèle

Gravité : bloquante.

Objet : vérifier que chacun des gestes joués dans ce cahier a bien laissé **sa** ligne, avec le bon auteur et la bonne cible.

Étapes : 1. Filtrer sur l'auteur = le compte **Médiateur**. Dérouler. 2. Vérifier que chaque geste de ce cahier joué avec ce compte y figure : lecture de fiche, décision de litige, sanction, masquage, relance de versement. 3. Ouvrir une ligne de décision et lire la colonne « Détail ». 4. Filtrer sur `targetType = SETTINGS` et vérifier une ligne par clé. 5. Comparer l'horodatage d'une ligne avec l'heure du geste. 6. Vérifier la colonne « IP ».

Résultat attendu : - Toutes les lignes attendues sont présentes, aucune ligne parasite. - Le « Détail » est lisible : les clés du `after` séparées par « · », jamais un JSON brut illisible. - L'auteur est l'admin qui a agi, pas un compte technique. - L'horodatage correspond à la seconde près. - L'IP et le user-agent (tronqué à 200 caractères) sont renseignés. - **Aucune ligne pour un geste refusé** (403 / 400 / 409).

Verdict : ☐ conforme ☐ non conforme

ADM-JRN-4 — Le journal n'est ni purgé ni accessible au Support

Gravité : bloquante.

Étapes : 1. Session **Support** puis **Médiateur** : chercher l'entrée « Journal » du menu, ouvrir `/audit` par l'URL, appeler `/api/admin/audit`. 2. Vérifier qu'aucune purge de rétention ne touche `AdminAction` (contrôle documentaire : `retention.*` ne porte aucune clé sur le journal admin). 3. Depuis une fiche membre, vérifier la carte « Actions admin sur ce compte ».

Résultat attendu : - Étape 1 → **403** pour les deux profils. `audit.read` appartient à la Finance et au super administrateur. - Étape 2 → le journal admin n'est **jamais** purgé (les autres domaines le sont : notifications 1 an, traces d'emails 1 an, événements consommés 90 jours, outbox publiés 90 jours, conversations 1 an, destinataire 30 jours). - Étape 3 → le Support et le Médiateur, sans accès au journal global, voient tout de même le **journal filtré sur la cible** en bas des fiches membre, trajet et argent. C'est le chemin prévu pour eux.

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

5.25 Comptes admin (`/admins`)

ADM-CPT-1 — La liste des comptes admin

Gravité : majeure. Préconditions : session **super administrateur** (`admins.manage` n'appartient à aucun autre profil).

Étapes : 1. Ouvrir `/admins`. Vérifier le titre et le sous-titre « Super administrateur seulement. Un compte invité naît sans rôle client et définit son mot de passe par le lien reçu (48 h). ». 2. Relever les colonnes. 3. Relever les états affichés.

Résultat attendu : - Colonnes : « Nom », « Email », « Profils (cumulables) », « État », puis l'action. - Colonne « État » : « invitation en attente » (compte sans mot de passe), « 2FA active », ou « 2FA à activer », suivi de la date de création. - Les profils sont des **cases à cocher cumulables**, avec un indice par profil. - La tuile d'accueil « Invitations admin en attente » compte les comptes admin sans mot de passe.

Ligne de journal attendue : aucune pour la lecture.

Verdict : ☐ conforme ☐ non conforme

ADM-CPT-2 — Inviter un nouvel admin

Gravité : bloquante. ☒

Étapes : 1. Dans le formulaire « Inviter », relever les champs et les six cases de profil avec leurs indices. 2. Décocher **tous** les profils. 3. Saisir une adresse **inconnue**, un prénom, un nom, cocher « Support » **et** « Finance ». Cliquer « Envoyer l'invitation ». 4. Lire le message. 5. Lire Mailpit. 6. Ouvrir le lien reçu, saisir deux mots de passe **différents**. 7. Saisir deux fois le même mot de passe de 8 caractères au moins, sans le nom ni l'email. Cliquer « Enregistrer et me connecter ». 8. Se connecter avec ce compte et vérifier qu'il n'a **aucun** rôle client. 9. Rejouer le lien d'invitation. 10. Ouvrir `/invite` **sans** paramètre `token`.

Résultat attendu : - Étape 1 → champs « email », « Prénom », « Nom », tous requis ; six cases : « Super administrateur » (tout, comptes admin, remboursements manuels), « Médiateur » (litiges, sanctions, masquage, versements), « Support » (fiches, billets, propositions), « Finance » (finances, exports, pilotage, journal), « Exploitation » (paramètres d'exploitation...), « Données personnelles » (demandes RGPD, effacement...). Note : « Les permissions se cumulent. Un compte créé ici n'a aucun rôle client (ni publier ni réserver). ». Profil coché par défaut : « Support ». - Étape 2 → **impossible** : au moins un profil reste coché. - Étape 4 → « Compte créé, invitation envoyée (48 h). ». Une nouvelle ligne « invitation en attente » apparaît. - Étape 5 → ☒ email « Ton accès au back-office Yamba », lien vers `/invite?token=...`, valable **48 heures**, dans la langue du destinataire, nommant **les deux** profils. - Étape 6 → refus côté écran : « Les deux mots de passe diffèrent. ». - Étape 7 → succès, redirection vers `/login`. Le parcours se poursuit par l'enrôlement 2FA (ADM-SEC-2). - Étape 8 → **aucun rôle client** : le compte ne publie ni ne réserve tant qu'il ne passe pas par le parcours client. - Étape 9 → refus **400** « This invitation link is invalid or expired. » : le jeton est à usage unique. - Étape 10 → « Lien d'invitation incomplet. », le formulaire n'est pas rendu.

Lignes de journal attendues :

Geste	Action	Cible	Après
Invitation	ADMIN_INVITED	USER · <id de l'invité>	{ adminRoles: ["SUPPORT","FINANCE"], existingAccount: false }
Mot de passe posé	ADMIN_INVITE_ACCEPTED	USER · <id de l'invité>	— (écrite sous l'identité de l'invité)

Verdict : ☐ conforme ☐ non conforme

ADM-CPT-3 — Inviter une adresse déjà connue

Gravité : majeure. ☒

Étapes : 1. Inviter une adresse qui correspond à un **compte membre existant** (par exemple `aminata.shipper@seed.yamba.dev`), profil « Support ». 2. Lire le message. 3. Lire Mailpit. 4. Vérifier que le compte conserve son rôle client. 5. Réinviter la même adresse alors qu'elle a déjà un profil admin.

Résultat attendu : - Étape 2 → « Profils posés sur un compte existant, email envoyé. ». - Étape 3 → ✉ email « Accès au back-office Yamba accordé », avec un lien vers `/login` (pas de mot de passe à poser : le compte en a déjà un). - Étape 4 → le rôle client (`SHIPPER`) est **conservé**. - Étape 5 → refus **400** « This account already has an admin profile. ».

Ligne de journal attendue :

Action	Cible	Après
ADMIN_INVITED	USER · <id>	{ adminRoles: ["SUPPORT"], existingAccount: true }

Verdict : ☐ conforme ☐ non conforme

ADM-CPT-4 — Modifier les profils et retirer un accès

Gravité : bloquante.

Étapes : 1. Sur la ligne d'un admin, cocher un profil supplémentaire. 2. Décocher tous ses profils sauf un, puis tenter de décocher le dernier. 3. Sur **sa propre** ligne, tenter de changer ses profils, puis de cliquer « Retirer ». 4. S'il ne reste qu'un super administrateur, tenter de décocher son profil `SUPER_ADMIN`. 5. Sur la ligne d'un autre admin, cliquer « Retirer » et lire la confirmation du navigateur. 6. Confirmer. Puis vérifier : le compte dans `/users`, ses sessions admin, sa 2FA. 7. Depuis la session de l'admin retiré (si elle était ouverte), naviguer.

Résultat attendu : - Étape 1 → la liste est **remplacée en entier** par la nouvelle sélection (ce n'est pas une union avec l'ancienne). - Étape 2 → au moins un profil reste coché. - Étape 3 → **403** dans les deux cas. - Étape 4 → **403** « The last super administrator cannot be downgraded / revoked. ». - Étape 5 → confirmation du navigateur : « Retirer l'accès admin de {prénom} {nom} ? Sa 2FA et ses sessions admin sont supprimées. ». - Étape 6 → tous ses profils sont vidés, le rôle ADMIN est retiré, **le secret TOTP et les codes de secours sont effacés**, et ses sessions admin tombent. Le compte membre, lui, subsiste. - Étape 7 → renvoi immédiat à `/login` : le middleware refuse un compte sans profil admin.

Lignes de journal attendues :

Geste	Action	Cible	Avant	Après
Cocher / décocher	ADMIN_ROLE_CHANGED	USER · <id>	{ adminRoles: [...] }	{ adminRoles: [...] }
« Retirer »	ADMIN_REVOKED	USER · <id>	{ adminRoles: [...] }	—

Verdict : ☐ conforme ☐ non conforme

ADM-CPT-5 — Un admin qui a perdu son application d'authentification

Gravité : majeure.

Objet : vérifier que la **seule** procédure documentée fonctionne, puisqu'il n'existe **aucun écran** pour régénérer des codes de secours ni réinitialiser la 2FA.

Étapes : 1. Sur `/admins`, « Retirer » le compte concerné, puis le réinviter avec ses profils. 2. Ou, en variante par script : `sh npx tsx --env-file=.env packages/libs/prisma/scripts/grant-admin.ts <email> --revoke npx`

tsx --env-file=.env packages/libs/prisma/scripts/grant-admin.ts <email> --role MEDIATOR 3.
Reconnecter le compte.

Résultat attendu : la connexion propose de nouveau l'écran d'enrôlement (code QR), puisque le secret TOTP a été effacé. **Attention :** la variante par script vide les profils entre les deux commandes — il faut les repréciser.

Ligne de journal attendue : par l'écran, ADMIN_REVOKED puis ADMIN_INVITED ; par le script, aucune (c'est un geste hors application, à consigner ailleurs).

Remarque de recette. Cette procédure brouille la lecture du journal : elle ressemble à une révocation pour faute. Le noter comme une limite connue.

Verdict : ☐ conforme ☐ non conforme

5.26 Mes sessions (/sessions)

ADM-SES-1 — Mon compte admin : ce qui existe et ce qui n'existe pas

Gravité : mineure.

Étapes : 1. Chercher une page « Mon compte » dans le menu. 2. Lire la barre latérale : nom, profils, avertissement de codes de secours, bouton de déconnexion. 3. Ouvrir /sessions et vérifier le contenu (voir ADM-SEC-10). 4. Chercher un moyen de changer son mot de passe, son email, ou de régénérer ses codes de secours depuis le back-office.

Résultat attendu : - Étape 1 → il n'existe pas de page « Mon compte » : l'identité de l'admin vit dans la barre latérale. - Étape 2 → la barre affiche « Yamba · Admin », le prénom et le nom, le libellé des profils cumulés (« Support + Finance »), l'avertissement « Il te reste {n} code(s) de secours. » quand il en reste deux ou moins, et « Se déconnecter ». - Étape 4 → aucun de ces gestes n'existe dans le back-office. Le mot de passe d'un compte admin se change par le **parcours membre**, sous la fenêtre de confirmation renforcée, puisque c'est le même compte.

Ligne de journal attendue : ADMIN_LOGOUT sur déconnexion.

Verdict : ☐ conforme ☐ non conforme

6. Cas de bout en bout

Ces enchaînements se jouent d'une traite, dans l'ordre. Ils vérifient ce qu'aucun scénario isolé ne montre : la **cohérence** entre les écrans, les services et le journal. Chacun se conclut par une lecture du journal filtré, qui doit raconter l'histoire complète.

Rejouer le jeu d'essai avant chaque cas.

ADM-E2E-1 — Un litige, de la file à la décision, jusqu'à l'argent

Gravité : bloquante. ▶ **deux profils**   **Objet :** vérifier la chaîne complète d'une médiation, et que la décision se répercute sur l'argent et sur les compteurs internes des deux parties.

#	Acteur	Geste	Résultat attendu	Ligne de journal
1	—	Rejouer le jeu d'essai	2 litiges, 1 retenue en file	—
2	Super administrateur	Abaiss ^{er} <code>dispute.responseDelayHours</code> à 1 h, motif ≥ 20	Le dossier YAM-2041 devient décidable	SETTING_CHANGED · SETTINGS · <code>dispute.responseDelayHours</code>
3	Médiateur	Ouvrir <code>/home</code>	Tuile « Litiges à trancher » = 2, en ambre	—
4	Médiateur	Cliquer la tuile	Arrivée sur <code>/disputes</code> , compteur « 3 affiché(s) · file entière : 2 litige(s) · 1 retenue(s) »	—
5	Médiateur	Ouvrir YAM-2041	Dossier complet ; bandeau « délai passé, décision possible sans sa version »	DISPUTE_VIEWED · BOOKING · <code><id></code>
6	Médiateur	Cliquer « Lire la conversation des deux parties → »	Le fil s'affiche, sans aucun numéro de téléphone	CONVERSATION_VIEWED · CONVERSATION · <code><id></code>
7	Médiateur	Revenir, cliquer le lien « Fiche argent complète »	Prix figé, versement FROZEN (gelé par le litige)	DEAL_MONEY_VIEWED · BOOKING · <code><id></code>
8	Médiateur	Revenir au dossier, choisir « Remboursement partiel », montant = moitié du total, motif ≥ 50	Récapitulatif dont les trois lignes totalisent le montant payé	—
9	Médiateur	« Valider définitivement »	« Décision enregistrée · deal COMPLETED · remboursé ... · versé ... »	DISPUTE_RESOLVED · BOOKING · <code><id></code>
10	—	Mailpit	✉ deux emails « Décision rendue », un par partie, chacun avec son montant et le motif intégral	—
11	Médiateur	Rouvrir la fiche du Voyageur	« Litiges perdus (interne) » incrémenté de 1 ; le score de risque augmente de 25 points	USER_VIEWED
12	Médiateur	Rouvrir <code>/home</code>	Tuile « Litiges à trancher » = 1	—
13	Finance	Ouvrir <code>/finances/report</code>	Le remboursement apparaît au mois courant ; le revenu reconnu du deal terminé est comptabilisé	—
14	Finance	Ouvrir <code>/deals/<id></code> , « Charger la chronologie »	Un événement <code>booking.dispute_resolved</code> figure dans la chronologie, publié ou en attente	DEAL_HISTORY_VIEWED
15	Super administrateur	Remettre <code>dispute.responseDelayHours</code> à 72, motif ≥ 20	Version incrémentée	SETTING_CHANGED
16	Finance	Ouvrir <code>/audit</code> , filtrer sur la cible = l'identifiant du deal	Toutes les lignes ci-dessus, dans l'ordre chronologique, avec le bon auteur	—

Contrôle final : le dossier ne peut plus être tranché (409), aucune invitation à noter n'est partie (un deal clos par médiation ne se note pas), et le fil de discussion est passé en lecture seule pendant le litige.

Verdict : ☐ conforme ☐ non conforme

ADM-E2E-2 — Une sanction proposée, appliquée, puis levée

Gravité : bloquante. ▶ **deux profils** ⓘ  **Objet :** vérifier le circuit à deux temps et le fait que les effets d'une sanction passent **par les lectures** des autres services, jamais par une écriture croisée.

#	Acteur	Geste	Résultat attendu	Ligne de journal
1	Support	Ouvrir la fiche de Marc Tremblay	Fiche complète, compte « Actif »	USER_VIEWED
2	Support	« Proposer » Restreint, motif ≥ 20	Bandeau ambre ; rien ne change pour Marc	USER_SUSPENSION_PROPOSED
3	Support	Ouvrir /home	Tuile « Sanctions proposées » = 1	—
4	Marc (front)	Publier un trajet, réserver	Tout fonctionne : une proposition n'agit pas	—
5	Médiateur	Ouvrir la même fiche	Le bandeau de proposition est visible, avec le nom du Support	USER_VIEWED
6	Médiateur	« Appliquer », motif ≥ 20, sans date de fin	Badge « Restreint » ; le bandeau ambre disparaît	USER_RESTRICTED
7	Marc (front)	Publier un trajet	403 ACCOUNT_RESTRICTED	—
8	Marc (front)	Réserver un colis	403 ACCOUNT_RESTRICTED	—
9	Marc (front)	Ouvrir un deal déjà en cours	Il continue normalement	—
10	—	Mailpit	✉ « Ton compte Yamba est restreint », motif générique , adresse de contestation	—
11	Médiateur	Passer la sanction à « Suspendu », motif ≥ 20	Badge « Suspendu » ; ses sessions membre sont révoquées	USER_SUSPENDED
12	Visiteur (front public)	Rechercher le corridor de Marc	Ses trajets sortent de la recherche . En base, leur statut est resté PUBLISHED : c'est un filtre de lecture	—
13	—	Mailpit	✉ email au membre et email au support « [Yamba ops] SUSPENDED : Marc Tremblay a n deal(s) en cours »	—
14	Médiateur	« Lever », motif ≥ 20	Badge « Actif », champs de sanction effacés	USER_REINSTATED
15	Marc (front)	Se reconnecter, publier	Tout refonctionne ; ses trajets sont de nouveau dans la recherche	—
16	—	Mailpit	✉ « Ton compte Yamba est rétabli »	—
17	Finance	/audit , filtrer sur la cible = identifiant de Marc	Les cinq lignes de gestes plus les consultations	—

Verdict : ☐ conforme ☐ non conforme

ADM-E2E-3 — Un membre signalé trois fois devient prioritaire

Gravité : majeure. ▶ **deux profils** ⓘ  **Objet :** vérifier la priorité à trois signalements et le fait qu'un signalement ne sanctionne rien tout seul.

#	Acteur	Geste	Résultat attendu	Ligne de journal
1	Aminata (front)	Signaler le profil public de Thomas, motif « Tentative d'arnaque »	Accusé de réception « merci, on regarde »	— (geste membre)
2	Aminata (front)	Recommencer sur la même cible	409 : pas deux signalements ouverts du même auteur	—
3	João, Chinwe (front)	Signaler la même cible	Trois signalements ouverts au total	—
4	Thomas (front)	Ouvrir son espace	Il n'apprend rien : ni le signalement, ni son auteur	—
5	Support	Ouvrir /home	Tuile « Trajets et membres signalés » = 3	—
6	Support	Ouvrir /reports	Badge rouge « Prioritaire · 3 ouverts » sur la ligne	—
7	Support	Cliquer la cible	Fiche de Thomas ; le score de risque a augmenté (+8 par signalement ouvert)	USER_VIEWED
8	Support	Vérifier le statut du compte et ses trajets	ACTIVE , trajets visibles : rien d'automatique	—
9	Support	« Proposer » Restreint, motif ≥ 20	Bandeau ambre	USER_SUSPENSION_PROPOSED
10	Médiateur	« Appliquer »	Compte restreint, email au membre	USER_RESTRICTED
11	Support	Revenir sur /reports , note « restreint le {date} », « Traité » ×3	Les trois cartes passent dans l'onglet « traité »	REPORT_REVIEWED ×3
12	Support	Onglet « à traiter »	Vide ; la tuile d'accueil revient à 0	—
13	—	Mailpit	✉ aucun email n'est parti aux auteurs des signalements : ils n'apprennent pas la suite	—

Verdict : ☐ conforme ☐ non conforme

ADM-E2E-4 — Un changement de paramètre et son effet en moins de 30 secondes

Gravité : bloquante. ▶ **deux profils** ✉  **Objet** : vérifier la chaîne complète d'un réglage : garde de portée, motif, journal par clé, email, propagation, non-rétroactivité.

#	Acteur	Geste	Résultat attendu	Ligne de journal
1	Aminata (front)	Préparer une réservation jusqu'à l'écran de prix, sans payer	Le total affiché est calculé avec la commission en vigueur	—
2	Exploitation	Ouvrir /settings , tenter de modifier la commission	Champ verrouillé, mention « super administrateur seul » ; appel direct → 403 nommant la clé	—

#	Acteur	Geste	Résultat attendu	Ligne de journal
3	Super administrateur	Modifier la commission (12 % → 15 %)	Panneau « À valider — 1 modification(s) », mention « figure dans les CGU »	—
4	Super administrateur	Motif de 15 caractères	Bouton inactif, compteur « 15/20 »	—
5	Super administrateur	Motif ≥ 20, « Enregistrer »	« 1 paramètre(s) modifié(s) — version {v}, journalisé, super administrateurs prévenus. »	SETTING_CHANGED · SETTINGS · pricing.commissionPct
6	—	Chronomètre + GET /api/trips/pricing/params	La nouvelle valeur est servie en moins de 30 secondes	—
7	—	Mailpit	☒ « Paramètres de la plateforme modifiés » à tous les super administrateurs	—
8	Aminata (front)	Reprendre son écran de prix et payer	Le total attendu ne correspond plus : elle revoit le prix avant de payer	—
9	—	Ouvrir une réservation antérieure	Son prix est inchangé : rien n'est rétroactif, le snapshot est immuable	—
10	Super administrateur	Ouvrir /home	Bandeau « Paramètres modifiés le {date} par {nom} : {clé} »	—
11	Super administrateur	/settings, « historique » sur la clé	« {date} · {admin} · modifié : 12 → 15 · « {motif} » »	—
12	Super administrateur	Cliquer « remettre », enregistrer avec motif	La valeur revient à 12 % ; une remise est une modification comme une autre	SETTING_CHANGED
13	Finance	/audit, filtrer targetType = SETTINGS	Deux lignes, une par écriture	—

Verdict : ☐ conforme ☐ non conforme

ADM-E2E-5 — Une mise en lecture seule et sa levée

Gravité : bloquante.  **Objet :** vérifier qu'une maintenance ferme les écritures sans fermer la connexion, le back-office, ni la sonde publique.

#	Acteur	Geste	Résultat attendu	Ligne de journal
1	Exploitation	/status → annoncer pour dans 2 h, messages FR et EN, motif ≥ 20	« Enregistré : journal écrit, super administrateurs prévenus, le gateway applique dans les 10 s. »	MAINTENANCE_CHANGED
2	Membre (front)	Recharger	Bandeau ambre d'annonce ; rien n'est bloqué	—

#	Acteur	Geste	Résultat attendu	Ligne de journal
3	—	Mailpit	☒ « Maintenance planifiée sur Yamba »	—
4	Exploitation	Cocher « Activer la lecture seule maintenant », motif ≥ 20, « Passer en lecture seule »	Enregistré	MAINTENANCE_CHANGED
5	Membre (front)	Recharger après 10 s	Bandeau rouge « Plateforme en lecture seule »	—
6	Membre (front)	Lire une annonce, une conversation, son tableau de bord	Toutes les lectures passent	—
7	Membre (front)	Réserver, publier, envoyer un message	503 MAINTENANCE , en-tête <code>Retry-After: 300</code>	—
8	Membre (front)	Se déconnecter puis se reconnecter	Fonctionne : <code>/api/auth/*</code> est exempté	—
9	Exploitation	Naviguer dans le back-office, écrire un paramètre	Fonctionne : <code>/api/admin/*</code> est exempté — c'est ce qui permet de lever la maintenance	SETTING_CHANGED
10	—	<code>GET /api/status</code>	HTTP 200 , état « maintenance » : ce n'est pas une panne, personne n'est réveillé	—
11	—	Mailpit	☒ « Maintenance activée sur Yamba »	—
12	Exploitation	Décocher, motif ≥ 20, « Lever la maintenance »	Bandeaux disparus, écritures rétablies en moins de 10 s	MAINTENANCE_CHANGED
13	—	Mailpit	☒ « Maintenance levée sur Yamba »	—
14	Finance	<code>/audit</code> , <code>targetType = SETTINGS</code> , cible <code>maintenance</code>	Trois lignes, chacune avec son motif et sa version	—

Verdict : ☐ conforme ☐ non conforme

ADM-E2E-6 — Une demande d'effacement RGPD reçue par email

Gravité : bloquante. ☒  **Objet** : dérouler la procédure telle qu'elle se joue réellement : une demande arrive par email au support, un refus est d'abord opposé, puis l'effacement se fait une fois les bloqueurs levés.

#	Acteur	Geste	Résultat attendu	Ligne de journal
1	—	Créer un compte membre de test depuis le front, avec adresse, avatar, un favori et une alerte route ; lui faire réserver un colis (deal <code>ACCEPTED</code>)	Compte complet, un deal vivant	—
2	Données personnelles	Ouvrir <code>/privacy</code>	Registre vide ou avec les demandes antérieures	DATA_REQUESTS_VIEWED
3	Données personnelles	Ouvrir la fiche du membre	Carte « Effacer ce compte (RGPD) » présente	USER_VIEWED

#	Acteur	Geste	Résultat attendu	Ligne de journal
4	Données personnelles	Motif « Demande reçue par email le {date}, identité vérifiée », EFFACER, « Effacer définitivement »	409 « Refusé pour l'instant : un deal en cours. »	aucune ligne ACCOUNT_ERASED
5	Données personnelles	Ouvrir /privacy	Une ligne « Effacement · par l'admin ({nom}) · refusée · deal en cours »	DATA_REQUESTS_VIEWED
6	Membre + Voyageur (front)	Terminer ou annuler le deal, régler le versement	Plus aucun bloqueur	—
7	Données personnelles	Reprendre l'effacement	« Compte effacé : identité et coordonnées supprimées, réservations conservées sans nom, journal écrit, email de confirmation envoyé à l'ancienne adresse. »	ACCOUNT_ERASED · USER · <id>
8	—	Vérifier en base	Prénom « Membre », nom « supprimé », email erased+<id>@anonymised.invalid, slug deleted-<id> (jamais null), isDeleted posé ; adresses, avatar, favoris, alertes, notifications supprimés ; stripeAccountId déplacé dans ErasedAccountId	—
9	—	Ouvrir la réservation du membre	Elle existe toujours, l'auteur devient « Membre supprimé »	—
10	Membre (front)	Tenter de se connecter	401 ACCOUNT_DELETED	—
11	—	Mailpit	✉ un seul email de confirmation, sans lien , à l'ancienne adresse. Ensuite, plus rien ne part vers ce compte	—
12	Données personnelles	Ouvrir /privacy	Une ligne « Effacement · par l'admin · faite »	DATA_REQUESTS_VIEWED
13	Données personnelles	Tenter d'effacer son propre compte	403 « You cannot erase your own account from the back-office. »	aucune

Verdict : ☐ conforme ☐ non conforme

ADM-E2E-7 — Un versement en échec, du bandeau d'alerte à la clôture

Gravité : bloquante. ▶ **deux profils**  **Objet :** dérouler la file Finances de bout en bout, y compris le remboursement manuel à deux gestes.

#	Acteur	Geste	Résultat attendu	Ligne de journal
1	Exploitation	Abaisser alerts.payoutFailedHours à 1 h, motif ≥ 20	Enregistré	SETTING_CHANGED
2	Finance	Ouvrir /home	Le bandeau annonce « n alertes de seuil · 1 critique » avec un lien vers /alerts	—

#	Acteur	Geste	Résultat attendu	Ligne de journal
3	Finance	Ouvrir /alerts	Carte critique PAYOUT_FAILED_48H , badge « 1 concerné », « Aller traiter → »	—
4	Finance	Cliquer « Aller traiter → »	Arrivée sur /finances? kind=FAILED , onglet présélectionné	—
5	Finance	Lire la ligne	Motif « compte Stripe du Voyageur non prêt », détail brut du fournisseur, « 4 tentative(s) », badge « Stripe non prêt »	—
6	Finance	Cliquer « Relancer »	« Versement envoyé. » ou « Toujours en échec : {motif}. »	PAYOUT_RETRIED
7	Finance	Cliquer « Relancer » deux fois de suite	Aucun double versement : même montant figé, même clé d'idempotence	PAYOUT_RETRIED (une par clic)
8	Finance	Ouvrir la fiche argent, « Rapprocher maintenant »	Divergence INTENT_NOT_FOUND avec le fournisseur Fake ; rien n'est modifié en base	DEAL_MONEY_VIEWED puis DEAL_RECONCILED
9	Finance	Onglet « Transferts renversés », « Décider »	Fiche argent du deal renversé	DEAL_MONEY_VIEWED
10	Finance	« Re-verser », motif ≥ 20	« Nouveau transfert envoyé. » ; la ligne quitte la file	PAYOUT_REVERSAL_RESOLVED (RESENT)
11	Finance	Sur un deal terminé, « Proposer » un remboursement de 5,00 €, motif ≥ 50	« Remboursement proposé, en attente d'un super administrateur. »	REFUND_MANUAL_PROPOSED
12	Finance	Chercher « Rembourser maintenant »	Absent : réservé au super administrateur	—
13	Super administrateur	Ouvrir la même fiche, « Rembourser maintenant »	« Remboursé 5,00 € (cumul ...). L'Expéditeur est prévenu par email. » ; le versement du Voyageur n'est pas touché	REFUND_MANUAL_APPLIED
14	Expéditeur (front)	Portefeuille	« partiellement remboursé »	—
15	Finance	/finances/report	Le remboursement apparaît au mois courant ; les passifs ont diminué	—
16	Exploitation	Remettre alerts.payoutFailedHours à 48	L'alerte disparaît d'elle-même	SETTING_CHANGED

Verdict : ☐ conforme ☐ non conforme

ADM-E2E-8 — Un billet, un masquage, et la lecture croisée

Gravité : majeure. ▶ **deux profils**  **Objet :** vérifier la chaîne Support → Médiateur sur l'offre, et l'effet d'un masquage lu par trois services.

#	Acteur	Geste	Résultat attendu	Ligne de journal
1	Support	/home → tuile « Billets à vérifier »	1	—
2	Support	/tickets → « Ouvrir le billet »	Le document s'ouvre dans un onglet	DOCUMENT_VIEWED · TRIP · <id>
3	Support	« Rejeter : motif... » → « Les dates ne correspondent pas au trajet » → « Rejeter »	« Billet rejeté, Voyageur prévenu. » ; ✉ email au Voyageur avec le libellé du motif	TICKET_REJECTED
4	Support	Ouvrir la fiche du trajet, « Proposer » un masquage, motif ≥ 20	Bandeau ambre ; le trajet reste public	TRIP_VIEWED puis TRIP_HIDE_PROPOSED
5	Support	/home	Tuile « Masquages proposés » = 1	—
6	Support	Chercher le bouton « Masquer »	Absent	—
7	Médiateur	Ouvrir la même fiche, « Masquer », motif ≥ 20	Badge rouge « masqué par Yamba » ; ✉ email au Voyageur avec un motif générique	TRIP_HIDDEN
8	Visiteur (front public)	Rechercher le corridor, ouvrir la page du trajet	Absent de la recherche ; page publique 404	—
9	Expéditeur (front)	Tenter de réserver sur ce trajet	Refus TRIP_NOT_BOOKABLE	—
10	Voyageur (front)	Ouvrir son trajet	Toujours présent, bandeau rouge ; statut inchangé (PUBLISHED) : Yamba n'annule jamais un trajet	—
11	Expéditeur (front)	Ouvrir une réservation déjà en cours sur ce trajet	Elle continue normalement	—
12	Voyageur (front)	Redéposer un billet	Le trajet revient dans la file « Billets à vérifier »	—
13	Médiateur	« Rétablir », motif ≥ 20	Le trajet revient dans la recherche ; ✉ email « de nouveau visible »	TRIP_UNHIDDEN
14	Finance	/audit , filtrer sur la cible = identifiant du trajet	Six lignes : consultation, document, rejet, proposition, masquage, rétablissement — avec deux auteurs distincts	—

Verdict : ☐ conforme ☐ non conforme

7. Non-régression

Ces scénarios vérifient des correctifs déjà livrés. Ils sont **courts** et se rejouent à chaque livraison : ce sont les défauts qui ont déjà coûté une fois.

ADM-NRG-1 — Les sous-titres périmés

Gravité : cosmétique. Objet : plusieurs écrans annonçaient encore des fonctions « à venir » alors qu'elles sont livrées.

Étapes : ouvrir chacun des écrans et lire le sous-titre **en entier**.

Écran	Ce que le sous-titre ne doit plus contenir	Ce qu'on attend
/home	« Les courbes et les finances arrivent avec le pilotage (C-PR6) »	« Ce qui attend une action, selon ton profil. Les chiffres de fond se lisent dans Pilotage, l'argent dans Finances. »
/finances	« Le rapport mensuel et l'export arrivent avec C-PR5b »	« ... Le rapport mensuel et son export sont plus bas. »
/disputes	« 72 h » en dur, sans mention du paramètre	« ... passé le délai de réponse (paramètre « Litige : délai de réponse », 72 h par défaut) ; la date exacte est affichée sur chaque dossier. »
/pilotage	« Les alertes de seuil arrivent avec C-PR6b »	un sous-titre sans cette mention (les alertes ont leur page /alerts)
/disputes/[id], formulaire « Trancher »	« 72 h laissées au Voyageur » en dur	un texte qui renvoie au paramètre , l'échéance affichée restant calculée à partir de sa valeur

Résultat attendu : aucun de ces cinq écrans ne mentionne une fonction « à venir » déjà livrée, ni un délai en dur qui contredit un paramètre réglable.

À vérifier en priorité : le sous-titre de /pilotage est le dernier de la liste à avoir été corrigé. S'il contient encore « Les alertes de seuil arrivent avec C-PR6b », c'est une **non-conformité cosmétique** à consigner : les alertes sont livrées et ont leur propre entrée de menu.

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

ADM-NRG-2 — Les filtres d'URL de la file d'arbitrage

Gravité : mineure. Objet : /disputes ignorait les paramètres d'URL : les liens d'alerte déposaient l'opérateur sur la file entière, sans filtre.

Étapes : 1. Ouvrir /disputes?decidable=1. Regarder l'état du select de décidabilité. 2. Ouvrir /disputes?kind=RETENTION. Regarder l'état du select de type. 3. Ouvrir /disputes?olderThanDays=7, puis /disputes?originCity=Paris, puis /disputes?destinationCity=Brazzaville. 4. Combiner : /disputes?kind=DISPUTE&decidable=1&olderThanDays=3. 5. Depuis /alerts, cliquer « Aller traiter → » sur une alerte de litige ou de retenue.

Résultat attendu : - Étape 1 → le select affiche « décidables maintenant » et la liste est déjà filtrée. - Étape 2 → le select de type affiche « retenues ». - Étape 3 → chaque paramètre présélectionne son filtre. - Étape 4 → les trois filtres s'appliquent ensemble. - Étape 5 → l'opérateur arrive **sur la bonne sous-file**, pas sur la file entière.

Ligne de journal attendue : aucune.

Verdict : ☐ conforme ☐ non conforme

ADM-NRG-3 — Le libellé du signalement traité

Gravité : cosmétique. Objet : l'action `REPORT_REVIEWED` n'avait pas de libellé français : le journal et les fiches affichaient le code brut.

Étapes : 1. Traiter un signalement de trajet ou de membre (`ADM-SIG-2`). 2. Ouvrir `/audit` et filtrer sur le type de cible `REPORT`. 3. Lire la colonne « Action ». 4. Ouvrir le select « Action » du filtre et chercher l'entrée correspondante.

Résultat attendu : la colonne « Action » affiche « **Signalement traité** », jamais `REPORT_REVIEWED`. Le select de filtre propose le même libellé. À côté, l'action des messages affiche « Message signalé traité ».

Ligne de journal attendue : `REPORT_REVIEWED` sur `REPORT` · `<id>` (le **code** en base, le **libellé** à l'écran).

Verdict : ☐ conforme ☐ non conforme

ADM-NRG-4 — La clé React de la page Paramètres

Gravité : mineure. Objet : le tableau des paramètres rendait chaque ligne dans un fragment **sans clé** ; React perdait l'association ligne ↔ état lors d'un filtrage ou d'un rechargement, ce qui pouvait faire migrer une saisie d'une ligne à l'autre.

Étapes : 1. Ouvrir `/settings` avec la console du navigateur ouverte. 2. Chercher un avertissement React du type « Each child in a list should have a unique "key" prop ». 3. Saisir une nouvelle valeur dans **une seule** ligne d'un groupe. 4. Déplier « historique » sur une **autre** ligne du même groupe. 5. Déplier puis replier le panneau d'explication de plusieurs paramètres, dans le désordre. 6. Vérifier le panneau collant « À valider ».

Résultat attendu : - Étape 2 → **aucun** avertissement de clé manquante. - Étape 4 et 5 → la valeur saisie **reste sur sa ligne**. Aucune saisie ne migre, aucun panneau ne s'ouvre sur le mauvais paramètre. - Étape 6 → le panneau annonce exactement « À valider — 1 modification(s) », avec le bon libellé et le bon couple avant → après.

Ligne de journal attendue : aucune tant que rien n'est enregistré. Si une modification est enregistrée, vérifier que la ligne `SETTING_CHANGED` porte bien **la clé saisie**, et pas une clé voisine — c'est le risque réel derrière ce défaut d'apparence cosmétique.

Verdict : ☐ conforme ☐ non conforme

ADM-NRG-5 — Les alertes ont quitté l'accueil

Gravité : mineure. Objet : les neuf règles s'affichaient toutes sur l'accueil : avec plusieurs alertes ouvertes, la page devenait un mur qu'il fallait dérouler avant d'atteindre les compteurs.

Étapes : 1. Créer au moins deux alertes actives (abaisser deux seuils, voir `ADM-ALR-2`). 2. Ouvrir `/home`. 3. Ouvrir `/alerts` par le menu. 4. Vérifier l'entrée de menu avec un profil **sans** `kpi.read` (Données personnelles). 5. Remettre les seuils.

Résultat attendu : - Étape 2 → l'accueil n'affiche qu'**un résumé d'une ligne** : « {n} alertes de seuil · {n} critiques · la plus grave : {titre} · Voir les alertes → ». Les compteurs « À traiter » restent visibles **sans dérouler**.

- Étape 3 → la page dédiée groupe les alertes par gravité (« Critiques · {n} » puis « À surveiller · {n} »), affiche le code de chaque règle et le tableau « Seuils utilisés ». - Étape 4 → l'entrée « Alertes » est **absente** du menu du profil Données personnelles. - Une régression consisterait à voir réapparaître le détail des neuf règles sur /home .

Ligne de journal attendue : deux `SETTING_CHANGED` par seuil (abaissement puis retour).

Verdict : ☐ conforme ☐ non conforme

ADM-NRG-6 — Le journal se filtre et se fouille

Gravité : majeure. Objet : /audit n'avait ni filtre ni recherche : retrouver « qui a touché à ce compte le 12 » demandait de dérouler des centaines de lignes.

Étapes : 1. Ouvrir /audit . Compter les filtres. 2. Poser un filtre par période, puis par auteur, puis par action, puis par type de cible, puis par identifiant, puis par IP. 3. Vérifier que la barre affiche « Filtres serveur : {liste} ». 4. Utiliser « Contient (lignes chargées, détail compris) » et lire la note d'avertissement. 5. Cliquer une valeur de la colonne « Qui », puis « Cible ». 6. Cliquer « Tout effacer ». 7. Lire la colonne « Détail ».

Résultat attendu : - Étape 1 → **six** filtres serveur plus un champ de recherche locale. - Étape 3 → les filtres réellement appliqués côté serveur sont **nommés**. Une valeur mal formée (identifiant trop court, date invalide) est **ignorée**, pas rejetée par une erreur. - Étape 4 → la note dit clairement que la recherche libre ne porte que sur les lignes déjà chargées. - Étape 5 → chaque valeur cliquable pose son filtre. - Étape 7 → le détail est **lisible** (« clé : valeur · clé : valeur »), pas un bloc de JSON brut.

Ligne de journal attendue : aucune. Lire le journal ne se journalise pas — le vérifier explicitement.

Verdict : ☐ conforme ☐ non conforme

ADM-NRG-7 — Les cinq écarts documentaires connus

Gravité : documentaire. Objet : ces écarts sont **attendus**. Le testeur les constate et les consigne sans les traiter comme des anomalies fonctionnelles.

#	Constat attendu	Verdict attendu
1	L'export nominatif fonctionne aussi pour le profil Données personnelles , alors que plusieurs documents disent « super administrateur seul »	Le code fait foi : conforme, écart documentaire
2	Le nom d'une règle d'alerte garde son seuil historique (<code>PAYOUT_FAILED_48H</code>) même quand le paramètre vaut 1 h	Conforme, écart assumé
3	Un refus d'effacement (409) est inscrit au registre <code>DataRequest</code> mais pas au journal admin	Conforme en l'état ; à arbitrer : le registre suffit-il comme preuve ?
4	La tuile « Sanctions proposées » de l'accueil mène à /users sans filtre : il n'existe pas de filtre serveur « proposition en cours »	Conforme en l'état ; gêne d'usage à signaler
5	Il n'existe aucun écran pour régénérer des codes de secours ni réinitialiser la 2FA	Conforme en l'état ; procédure « retirer / réinviter » documentée en <code>ADM-CPT-5</code>

Verdict : ☐ constaté ☐ divergent (préciser)

8. Consignation

8.1 Tableau de suivi

À remplir au fil de la recette. Une ligne par scénario joué.

Identifiant	Titre court	Gravité	Profil(s)	Écran	Journal	Verdict	Anomalie n°	Date
ADM-SEC-1	Première étape de connexion	bloquante	Médiateur	☐	☐			
ADM-SEC-2	Premier enrôlement (code QR)	bloquante	tous	☐	☐			
ADM-SEC-3	Code TOTP et anti-rejeu	bloquante		☐	☐			
ADM-SEC-4	Code de secours	majeure		☐	☐			
ADM-SEC-5	Blocage après cinq échecs	bloquante		☐	☐			
ADM-SEC-6	Délai de pré-authentification	mineure		☐	☐			
ADM-SEC-7	Sessions membre et admin séparées	bloquante		☐	☐			
ADM-SEC-8	Expiration par inactivité	majeure		☐	☐			
ADM-SEC-9	Durée de vie absolue	majeure		☐	☐			
ADM-SEC-10	Révoquer une session	majeure		☐	☐			
ADM-PRM-1	Profil Super administrateur	bloquante		☐	☐			
ADM-PRM-2	Profil Médiateur	bloquante		☐	☐			
ADM-PRM-3	Profil Support	bloquante		☐	☐			
ADM-PRM-4	Profil Exploitation	bloquante		☐	☐			
ADM-PRM-5	Profil Finance	bloquante		☐	☐			
ADM-PRM-6	Profil Données personnelles	bloquante		☐	☐			
ADM-PRM-7	Cumul Support + Finance	majeure		☐	☐			
ADM-PRM-8	Conflits d'intérêts	bloquante		☐	☐			
ADM-PRM-9	Gardes serveur systématiques	bloquante		☐	☐			
ADM-ACC-1	Compteurs d'accueil	majeure		☐	☐			
ADM-ACC-2	Compteurs filtrés par profil	bloquante		☐	☐			
ADM-ACC-3	Résumé d'alertes et bandeau paramètres	mineure		☐	☐			
ADM-ALR-1	Page des alertes	majeure		☐	☐			
ADM-ALR-2	Faire apparaître une alerte	majeure		☐	☐			
ADM-ALR-3	Email quotidien au support	mineure		☐	☐			

Identifiant	Titre court	Gravité	Profil(s)	Écran	Journal	Verdict	Anomalie n°	Date
ADM-ALR-4	Liens d'alerte	mineure		☐	☐			
ADM-USR-1	Recherche multi-indices	majeure		☐	☐			
ADM-USR-2	Fiche membre	majeure		☐	☐			
ADM-USR-3	TrustScore	mineure		☐	☐			
ADM-SNC-1	Proposer une sanction	bloquante		☐	☐			
ADM-SNC-2	Appliquer une restriction	bloquante		☐	☐			
ADM-SNC-3	Suspendre avec deals en cours	bloquante		☐	☐			
ADM-SNC-4	Lever une sanction	majeure		☐	☐			
ADM-SNC-5	Support ne peut pas appliquer	bloquante		☐	☐			
ADM-EML-1	Lever une suppression d'adresse	majeure		☐	☐			
ADM-EXP-1	Export nominatif	bloquante		☐	☐			
ADM-EXP-2	Exports opérationnels	bloquante		☐	☐			
ADM-EXP-3	Support n'exporte rien	majeure		☐	☐			
ADM-TRJ-1	Liste des trajets et filtres d'URL	majeure		☐	☐			
ADM-TRJ-2	Fiche trajet	majeure		☐	☐			
ADM-TRJ-3	Proposer un masquage	majeure		☐	☐			
ADM-TRJ-4	Masquer et rétablir	bloquante		☐	☐			
ADM-TRJ-5	Jamais son propre trajet	bloquante		☐	☐			
ADM-BIL-1	File des billets	majeure		☐	☐			
ADM-BIL-2	Ouvrir un billet	majeure		☐	☐			
ADM-BIL-3	Valider un billet	majeure		☐	☐			
ADM-BIL-4	Rejeter avec motif fermé	majeure		☐	☐			
ADM-MED-1	File « À arbitrer »	majeure		☐	☐			
ADM-MED-2	Ouvrir un dossier	bloquante		☐	☐			
ADM-MED-3	Gardes de la décision	bloquante		☐	☐			
ADM-MED-4	Litige : rejet	bloquante		☐	☐			
ADM-MED-5	Litige : remboursement partiel	bloquante		☐	☐			
ADM-MED-6	Litige : remboursement total	bloquante		☐	☐			
ADM-RET-1	Retenue : compensation Voyageur	bloquante		☐	☐			
ADM-RET-2	Retenue : restitution Expéditeur	majeure		☐	☐			
ADM-FIN-1	Les quatre files d'exception	majeure		☐	☐			
ADM-FIN-2	Support sans finances	bloquante		☐	☐			
ADM-ARG-1	Fiche argent	majeure		☐	☐			

Identifiant	Titre court	Gravité	Profil(s)	Écran	Journal	Verdict	Anomalie n°	Date
ADM-ARG-2	Chronologie complète	majeure		☐	☐			
ADM-RAP-1	Rapprochement (Fake)	majeure		☐	☐			
ADM-RAP-2	Divergences Stripe réelles	bloquante		☐	☐	»»		
ADM-VER-1	Relancer un versement	bloquante		☐	☐			
ADM-VER-2	Renversement : re-verser	bloquante		☐	☐			
ADM-VER-3	Renversement : abandonner	majeure		☐	☐			
ADM-REM-1	Proposer un remboursement manuel	bloquante		☐	☐			
ADM-REM-2	Appliquer un remboursement manuel	bloquante		☐	☐			
ADM-REM-3	Finance ne peut pas appliquer	bloquante		☐	☐			
ADM-RPT-1	Rapport mensuel	majeure		☐	☐			
ADM-RPT-2	Export CSV finances	bloquante		☐	☐			
ADM-RPT-3	Revenu reconnu	majeure		☐	☐			
ADM-PIL-1	Courbes d'activité	majeure		☐	☐			
ADM-PIL-2	Courbes de finances	majeure		☐	☐			
ADM-PIL-3	Drilldown et journalisation	bloquante		☐	☐			
ADM-PIL-4	Corridors et demande sans offre	majeure		☐	☐			
ADM-CNV-1	Lire un fil	bloquante		☐	☐			
ADM-CNV-2	Finance sans conversation	bloquante		☐	☐			
ADM-CNV-3	Révélations de numéro	majeure		☐	☐			
ADM-SIG-1	File trajets et membres	majeure		☐	☐			
ADM-SIG-2	Traiter un signalement	bloquante		☐	☐			
ADM-SIG-3	File des messages	bloquante		☐	☐			
ADM-SIG-4	Aucun automatisme	bloquante		☐	☐			
ADM-SIG-5	Support et Médiateur seuls	majeure		☐	☐			
ADM-PAR-1	Page des paramètres	majeure		☐	☐			
ADM-PAR-2	Modifier une clé métier	bloquante		☐	☐			
ADM-PAR-3	Trois clés, trois lignes	majeure		☐	☐			
ADM-PAR-4	Bornes, cohérence, portée	bloquante		☐	☐			
ADM-PAR-5	Verrou de version	bloquante		☐	☐			
ADM-PAR-6	Remise par défaut	majeure		☐	☐			
ADM-PAR-7	Repli sûr	bloquante		☐	☐			
ADM-RGP-1	Registre journalisé	majeure		☐	☐			
ADM-RGP-2	Effacement refusé	bloquante		☐	☐			
ADM-RGP-3	Effacement effectif	bloquante		☐	☐			
ADM-RGP-4	Oubli du tiers destinataire	majeure		☐	☐			

Identifiant	Titre court	Gravité	Profil(s)	Écran	Journal	Verdict	Anomalie n°	Date
ADM-ETA-1	Six services	majeure		☐	☐			
ADM-ETA-2	Battements de cron	majeure		☐	☐			
ADM-ETA-3	Outbox et emails	majeure		☐	☐			
ADM-MNT-1	Annoncer une maintenance	majeure		☐	☐			
ADM-MNT-2	Lecture seule	bloquante		☐	☐			
ADM-MNT-3	Lever la maintenance	bloquante		☐	☐			
ADM-MNT-4	Verrou et interrupteur d'environnement	majeure		☐	☐			
ADM-JRN-1	Six filtres serveur	bloquante		☐	☐			
ADM-JRN-2	Libellés en français	cosmétique		☐	☐			
ADM-JRN-3	Journal complet et fidèle	bloquante		☐	☐			
ADM-JRN-4	Ni purgé ni ouvert au Support	bloquante		☐	☐			
ADM-CPT-1	Liste des comptes admin	majeure		☐	☐			
ADM-CPT-2	Inviter un admin	bloquante		☐	☐			
ADM-CPT-3	Inviter une adresse connue	majeure		☐	☐			
ADM-CPT-4	Modifier et retirer	bloquante		☐	☐			
ADM-CPT-5	2FA perdue	majeure		☐	☐			
ADM-SES-1	Mon compte admin	mineure		☐	☐			
ADM-E2E-1	Litige de bout en bout	bloquante		☐	☐			
ADM-E2E-2	Sanction de bout en bout	bloquante		☐	☐			
ADM-E2E-3	Trois signalements	majeure		☐	☐			
ADM-E2E-4	Paramètre et effet en 30 s	bloquante		☐	☐			
ADM-E2E-5	Lecture seule et levée	bloquante		☐	☐			
ADM-E2E-6	Effacement RGPD	bloquante		☐	☐			
ADM-E2E-7	Versement en échec	bloquante		☐	☐			
ADM-E2E-8	Billet et masquage	majeure		☐	☐			
ADM-NRG-1	Sous-titres périmés	cosmétique		☐	☐			
ADM-NRG-2	Filtres d'URL d'arbitrage	mineure		☐	☐			
ADM-NRG-3	Libellé du signalement traité	cosmétique		☐	☐			
ADM-NRG-4	Clé React des paramètres	mineure		☐	☐			
ADM-NRG-5	Alertes déplacées	mineure		☐	☐			
ADM-NRG-6	Journal filtrable	majeure		☐	☐			
ADM-NRG-7	Écarts documentaires	documentaire		☐	☐			

Les deux colonnes **Écran** et **Journal** sont cochées séparément. Un scénario n'est « conforme » que si **les deux** le sont.

8.2 Fiche d'anomalie

Une fiche par anomalie, numérotée ANO-ADM-<n> .

```
ANO-ADM-<n>
Scénario ..... ADM-XXX-n
Gravité ..... bloquante | majeure | mineure | cosmétique | documentaire
Profil admin ..... SUPER_ADMIN | MEDIATOR | SUPPORT | FINANCE | OPS | PRIVACY (+ cumuls)
Écran / route ..... /xxx · appel API : METHOD /api/admin/...
Attendu (écran) ....
Observé (écran) ....
Attendu (journal) .. action / cible / avant / après
Observé (journal) .. (coller la ligne, ou « aucune ligne »)
Reproductible ..... oui / non / intermittent
Effet de bord ..... argent déplacé ? email parti ? donnée personnelle exposée ?
Jeu d'essai ..... rejoué le ... · seed-output.json joint : oui / non
Environnement ..... branche, date, fournisseur de paiement, Redpanda actif ?
Pièces jointes ..... capture, extrait de journal, corps de réponse HTTP
```

Deux mentions obligatoires dans toute fiche du back-office :

1. **La ligne de journal** — présente, absente, ou différente de l'attendu. Une anomalie « l'écran fait bien X mais rien n'est journalisé » est **bloquante** par nature.
2. **L'effet réel** — un geste d'argent qui échoue à l'écran a-t-il **quand même** bougé chez le fournisseur de paiement ? Le vérifier avant de classer l'anomalie.

8.3 Critères de sortie

La recette de la partie admin est **prononcée conforme** quand :

#	Critère	Seuil
1	Anomalies bloquantes	zéro ouverte
2	Anomalies majeures	zéro ouverte sur les domaines argent, sanction, effacement et permissions ; les autres corrigées ou acceptées par écrit
3	Anomalies mineures et cosmétiques	listées, chacune arbitrée (corriger / accepter / reporter)
4	Anomalies documentaires	consignées et transmises pour correction des documents
5	Matrice des permissions	les six profils joués, chacun avec son menu vérifié, un geste réussi et un refus 403 serveur constaté
6	Journal	chaque geste d'écriture de ce cahier a produit sa ligne, avec le bon auteur, la bonne cible et le bon avant / après
7	Refus	aucun refus (403 / 400 / 409) n'a produit de ligne de journal
8	Données sensibles	le code de livraison n'apparaît sur aucun écran, dans aucun export, dans aucune chronologie ; aucun numéro de téléphone dans une conversation ; aucun email ni téléphone dans un export opérationnel
9	Circuits à deux temps	sanction, masquage et remboursement manuel vérifiés avec deux profils distincts
10	Cas de bout en bout	les huit joués jusqu'au bout, chacun terminé par une lecture du journal filtré

#	Critère	Seuil
11	Non-régression	les sept scénarios rejoués
12	Scénarios ►►	listés avec leur raison, et l'engagement du développement sur la couverture de substitution (tests unitaires)

Signatures

Rôle	Nom	Date	Verdict global
Testeur			☐ conforme ☐ conforme avec réserves ☐ non conforme
Responsable produit			
Développement			

Fin du cahier de recette — partie admin. Voir [RECETTE-01-MEMBRE.md](#) pour les parcours Expéditeur et Voyageur, [RECETTE-03-API.md](#) pour les contrats d'API, [RECETTE-04-EXPLOITATION.md](#) pour l'infrastructure.